

CIS IBM Cloud Foundations Benchmark

v2.0.0 - 11-21-2025

Terms of Use

Please see the below link for our current terms of use:

<https://www.cisecurity.org/cis-securesuite/cis-securesuite-membership-terms-of-use/>

For information on referencing and/or citing CIS Benchmarks in 3rd party documentation (including using portions of Benchmark Recommendations) please contact CIS Legal (legalnotices@cisecurity.org) and request guidance on copyright usage.

NOTE: It is **NEVER** acceptable to host a CIS Benchmark in **ANY** format (PDF, etc.) on a 3rd party (non-CIS owned) site.

Table of Contents

Terms of Use	1
Table of Contents	2
Overview	6
Important Usage Information	6
Key Stakeholders	6
Apply the Correct Version of a Benchmark	7
Exceptions	7
Remediation	8
Summary	8
Target Technology Details	9
Intended Audience.....	9
Consensus Guidance	10
Typographical Conventions.....	11
Recommendation Definitions.....	12
Title.....	12
Assessment Status.....	12
Automated	12
Manual.....	12
Profile	12
Description.....	12
Rationale Statement	12
Impact Statement.....	13
Audit Procedure.....	13
Remediation Procedure.....	13
Default Value.....	13
References	13
CIS Critical Security Controls® (CIS Controls®)	13
Additional Information.....	13
Profile Definitions	14
Acknowledgements	15
Recommendations	16
1 Identity and Access Management (IAM).....	16
1.1 Monitor account owner for frequent, unexpected, or unauthorized logins (Manual)	17
1.2 Ensure API keys unused for 180 days are detected and optionally disabled (Manual)	19
1.3 Ensure API keys are rotated every 90 days (Manual)	21

1.4 Restrict user API key creation and service ID creation in the account via IAM roles (Manual).....	23
1.5 Ensure no owner account API key exists (Manual)	25
1.6 Ensure multi-factor authentication (MFA) is enabled for all users in account (Manual)	27
1.7 Ensure multi-factor authentication (MFA) is enabled for the account owner and all administrative users (Manual).....	29
1.8 Ensure multi-factor authentication (MFA) is enabled at the account level (Manual)	31
1.9 Ensure contact email is valid (Manual)	33
1.10 Ensure contact phone number is valid (Manual)	35
1.11 Ensure Trusted Profiles are used in place of ServiceIDs wherever feasible (Manual)	37
1.12 Ensure Context-Based Restrictions are implemented to enforce secure, conditional access to critical resources based on network location, IP range, or identity attributes (Manual)	39
1.13 Ensure limitations on External Identity Interactions are Enabled (Manual)	41
1.14 Ensure IAM users with the same level of access are members of access groups and IAM policies are assigned only to access groups or Trusted Profiles (Manual)	43
1.15 Ensure a support access group has been created to manage incidents with IBM Support (Manual).....	45
1.16 Ensure Minimal Number of Users are Granted Administrative Privileges (Manual).....	47
1.17 Ensure Minimal Number of Service IDs are Granted Administrative Privileges (Manual)	50
1.18 Ensure IAM Does Not Allow Public Access to Cloud Services (Manual)	53
1.19 Ensure Inactive User Accounts are Suspend (Manual).....	56
1.20 Enable audit logging for IBM Cloud Identity and Access Management (Manual)	58
2 Storage	60
2.1 Cloud Object Storage	61
2.1.1 Cloud Object Storage Encryption.....	62
2.1.1.1 Ensure Cloud Object Storage encryption is done with customer managed keys (Manual).....	63
2.1.1.2 Ensure Cloud Object Storage Encryption is set to On with BYOK (Manual).....	65
2.1.1.3 Ensure Cloud Object Storage Encryption is set to On with KYOK (Manual).....	68
2.1.2 Ensure network access for Cloud Object Storage is restricted to specific IP range (Manual).....	71
2.1.3 Ensure network access for Cloud Object Storage is set to be exposed only on Private end-points (Manual)	74
2.1.4 Ensure Cloud Object Storage bucket access is restricted by using IAM and S3 access control (Manual)	77
2.1.5 Ensure Public (anonymous) Access to IBM Cloud Object Storage buckets is Disabled (Manual).....	80
2.2 Block and File Storage	82
2.2.1 Cloud Block Storage Encryption	83
2.2.1.1 Ensure IBM Cloud® Block Storage for Virtual Private Cloud is encrypted with BYOK (Manual).....	84
2.2.1.2 Ensure IBM Cloud® Block Storage for Virtual Private Cloud is encrypted with KYOK (Manual).....	86
2.2.2 Cloud File Storage Encryption.....	88
2.2.2.1 Ensure IBM Cloud® File Storage for Virtual Private Cloud is encrypted with provider managed keys (Manual)	89
2.2.2.2 Ensure IBM Cloud® File Storage for Virtual Private Cloud is encrypted with BYOK (Manual).....	91
2.2.2.3 Ensure IBM Cloud® File Storage for Virtual Private Cloud is encrypted with KYOK (Manual).....	93
2.2.3 Ensure boot volumes are encrypted with Customer managed keys (Manual).....	95
2.2.4 Ensure secondary volumes are encrypted with customer managed keys (Manual)	97
2.2.5 Ensure unattached volumes are encrypted with customer managed keys (Manual).....	99
3 Maintenance, Monitoring and Analysis of Audit Logs	101

3.1 Ensure auditing is configured in the IBM Cloud account (Manual).....	102
3.2 Ensure data retention for audit events (Manual)	108
3.3 Ensure that events are collected and processed to identify anomalies or abnormal events (Manual).....	114
3.4 Ensure alerts are defined on custom views to notify of unauthorized requests, critical account actions, and high-impact operations in your account (Manual)	124
3.5 Ensure the account owner can login only from a list of authorized countries/IP ranges (Manual).....	131
3.6 Ensure Activity Tracker data is encrypted at rest (Manual).....	135
4 IBM Cloud Databases Family	137
4.1 Ensure IBM Cloud Databases disk encryption is enabled with customer managed keys (Manual).....	138
4.2 Ensure network access to IBM Cloud Databases service is set to be exposed on “Private end points only” (Manual)	142
4.3 Ensure incoming connections are limited to allowed sources (Manual).....	145
5 Cloudant.....	149
5.1 Ensure IBM Cloudant encryption is enabled with customer managed keys (Manual)	150
6 Networking	155
6.1 IBM Cloud Internet Services	156
6.1.1 Enable TLS 1.2 at minimum for all inbound traffic on IBM Cloud Internet Services Proxy (Manual).....	157
6.1.2 Ensure Web application firewall is ENABLED in IBM Cloud Internet Services (CIS) (Manual).....	160
6.1.3 Ensure DDoS protection is Active on IBM Cloud Internet Services (Manual)	164
6.2 IBM Virtual Private Cloud (VPC)	169
6.2.1 Ensure no VPC access control lists allow ingress from 0.0.0.0/0 to port 22 (Manual) ..	170
6.2.2 Ensure the default security group of every VPC restricts all traffic (Manual)	172
6.2.3 Ensure no VPC security groups allow ingress from 0.0.0.0/0 to port 3389 (Manual)....	174
6.2.4 Ensure no VPC security groups allow ingress from 0.0.0.0/0 to port 22 (Manual).....	176
6.2.5 Ensure no VPC access control lists allow ingress from 0.0.0.0/0 to port 3389 (Manual)	178
7 Containers.....	180
7.1 IBM Cloud Kubernetes Service	181
7.1.1 Ensure data in Kubernetes secrets is encrypted using a Key Management Service (KMS) provider (Manual).....	182
7.1.2 Ensure TLS 1.2+ for all inbound traffic at IBM Cloud Kubernetes Service Ingress (Automated)	186
7.1.3 Ensure IBM Cloud Kubernetes Service worker nodes are updated to the latest version to ensure patching of vulnerabilities (Automated)	190
7.1.4 Ensure IBM Cloud Kubernetes Service cluster has image pull secrets enabled (Automated)	193
7.1.5 Ensure IBM Cloud Kubernetes Service clusters have the monitoring service enabled (Automated)	195
7.1.6 Ensure IBM Cloud Kubernetes Service clusters have the logging service enabled (Manual).....	199
8 Security and Compliance	204
8.1 Key Management	205
8.1.1 IBM Key Protect for IBM Cloud	206
8.1.1.1 Ensure IBM Key Protect has automated rotation for customer managed keys enabled (Automated)	207
8.1.1.2 Ensure Keys in the IBM Cloud® Key Protect Service are configured for high availability (Manual).....	212
8.1.1.3 Ensure all data stores are encrypted in the IBM Cloud® (Manual)	215

8.2 IBM Cloud Secrets Manager	218
8.2.1 Ensure certificates imported into or generated through IBM Cloud® Secrets Manager are automatically renewed before expiration (Automated)	219
8.2.2 Ensure access settings to secrets follow least privilege rule and allow access for a limited time to applications and non-administrative users as needed (Manual)	222
8.2.3 Ensure notification service is enabled in the IBM Cloud Secrets Manager to notify life cycle events (Manual)	226
8.2.4 Ensure secrets stored in the IBM Cloud® Secrets Manager are rotated periodically (Automated)	228
9 IBM Power Virtual Server on IBM Cloud (PowerVS)	230
9.1 Ensure the Default Network Security Group of Every Workspace Restricts All Traffic (Manual)	231
9.2 Ensure no workspace security groups allow ingress from 0.0.0.0/0 to port 3389 (Manual)	233
9.3 Ensure no workspace network security groups allow ingress from 0.0.0.0/0 to port 22 (Manual)	235
9.4 Ensure no workspace network security groups allow inbound traffic from the Internet from 0.0.0.0/0 to any infrastructure ports (Manual)	237
9.5 Ensure no workspace network security groups allow inbound traffic from the Internet from 0.0.0.0/0 to any administrative ports (Manual)	239
9.6 Ensure no workspace network security groups allow inbound traffic from the Internet from 0.0.0.0/0 to any fileshare port (Manual)	241
9.7 Ensure no workspace network security groups allow inbound traffic from the Internet allowing access from 0.0.0.0/0 to telnet port (23) or RSH port (514) (Manual)	243
<i>Appendix: Summary Table</i>	<i>245</i>
<i>Appendix: CIS Controls v7 IG 1 Mapped Recommendations</i>	<i>252</i>
<i>Appendix: CIS Controls v7 IG 2 Mapped Recommendations</i>	<i>254</i>
<i>Appendix: CIS Controls v7 IG 3 Mapped Recommendations</i>	<i>257</i>
<i>Appendix: CIS Controls v7 Unmapped Recommendations</i>	<i>261</i>
<i>Appendix: CIS Controls v8 IG 1 Mapped Recommendations</i>	<i>262</i>
<i>Appendix: CIS Controls v8 IG 2 Mapped Recommendations</i>	<i>265</i>
<i>Appendix: CIS Controls v8 IG 3 Mapped Recommendations</i>	<i>269</i>
<i>Appendix: CIS Controls v8 Unmapped Recommendations</i>	<i>273</i>
<i>Appendix: Change History</i>	<i>274</i>

Overview

All CIS Benchmarks™ (Benchmarks) focus on technical configuration settings used to maintain and/or increase the security of the addressed technology, and they should be used in **conjunction** with other essential cyber hygiene tasks like:

- Monitoring the base operating system and applications for vulnerabilities and quickly updating with the latest security patches.
- End-point protection (Antivirus software, Endpoint Detection and Response (EDR), etc.).
- Logging and monitoring user and system activity.

In the end, the Benchmarks are designed to be a key **component** of a comprehensive cybersecurity program.

Important Usage Information

All Benchmarks are available free for non-commercial use from the [CIS Website](#). They can be used to manually assess and remediate systems and applications. In lieu of manual assessment and remediation, there are several tools available to assist with assessment:

- [CIS Configuration Assessment Tool \(CIS-CAT® Pro Assessor\)](#)
- [CIS Benchmarks™ Certified 3rd Party Tooling](#)

These tools make the hardening process much more scalable for large numbers of systems and applications.

NOTE: Some tooling focuses only on the Benchmark Recommendations that can be fully automated (skipping ones marked **Manual**). It is important that **ALL** Recommendations (**Automated** and **Manual**) be addressed since all are important for properly securing systems and are typically in scope for audits.

Key Stakeholders

Cybersecurity is a collaborative effort, and cross functional cooperation is imperative within an organization to discuss, test, and deploy Benchmarks in an effective and efficient way. The Benchmarks are developed to be best practice configuration guidelines applicable to a wide range of use cases. In some organizations, exceptions to specific Recommendations will be needed, and this team should work to prioritize the problematic Recommendations based on several factors like risk, time, cost, and labor. These exceptions should be properly categorized and documented for auditing purposes.

Apply the Correct Version of a Benchmark

Benchmarks are developed and tested for a specific set of products and versions and applying an incorrect Benchmark to a system can cause the resulting pass/fail score to be incorrect. This is due to the assessment of settings that do not apply to the target systems. To assure the correct Benchmark is being assessed:

- **Deploy the Benchmark applicable to the way settings are managed in the environment:** An example of this is the Microsoft Windows family of Benchmarks, which have separate Benchmarks for Group Policy, Intune, and Stand-alone systems based upon how system management is deployed. Applying the wrong Benchmark in this case will give invalid results.
- **Use the most recent version of a Benchmark:** This is true for all Benchmarks, but especially true for cloud technologies. Cloud technologies change frequently and using an older version of a Benchmark may have invalid methods for auditing and remediation.

Exceptions

The guidance items in the Benchmarks are called recommendations and not requirements, and exceptions to some of them are expected and acceptable. The Benchmarks strive to be a secure baseline, or starting point, for a specific technology, with known issues identified during Benchmark development are documented in the Impact section of each Recommendation. In addition, organizational, system specific requirements, or local site policy may require changes as well, or an exception to a Recommendation or group of Recommendations (e.g. A Benchmark could Recommend that a Web server not be installed on the system, but if a system's primary purpose is to function as a Webserver, there should be a documented exception to this Recommendation for that specific server).

In the end, exceptions to some Benchmark Recommendations are common and acceptable, and should be handled as follows:

- The reasons for the exception should be reviewed cross-functionally and be well documented for audit purposes.
- A plan should be developed for mitigating, or eliminating, the exception in the future, if applicable.
- If the organization decides to accept the risk of this exception (not work toward mitigation or elimination), this should be documented for audit purposes.

It is the responsibility of the organization to determine their overall security policy, and which settings are applicable to their unique needs based on the overall risk profile for the organization.

Remediation

CIS has developed [Build Kits](#) for many technologies to assist in the automation of hardening systems. Build Kits are designed to correspond to Benchmark's "Remediation" section, which provides the manual remediation steps necessary to make that Recommendation compliant to the Benchmark.

When remediating systems (changing configuration settings on deployed systems as per the Benchmark's Recommendations), please approach this with caution and test thoroughly.

The following is a reasonable remediation approach to follow:

- CIS Build Kits, or internally developed remediation methods should never be applied to production systems without proper testing.
- Proper testing consists of the following:
 - Understand the configuration (including installed applications) of the targeted systems. Various parts of the organization may need different configurations (e.g., software developers vs standard office workers).
 - Read the Impact section of the given Recommendation to help determine if there might be an issue with the targeted systems.
 - Test the configuration changes with representative lab system(s). If issues arise during testing, they can be resolved prior to deploying to any production systems.
 - When testing is complete, initially deploy to a small sub-set of production systems and monitor closely for issues. If there are issues, they can be resolved prior to deploying more broadly.
 - When the initial deployment above is completed successfully, iteratively deploy to additional systems and monitor closely for issues. Repeat this process until the full deployment is complete.

Summary

Using the Benchmarks Certified tools, working as a team with key stakeholders, being selective with exceptions, and being careful with remediation deployment, it is possible to harden large numbers of deployed systems in a cost effective, efficient, and safe manner.

NOTE: As previously stated, the PDF versions of the CIS Benchmarks™ are available for free, non-commercial use on the [CIS Website](#). All other formats of the CIS Benchmarks™ (MS Word, Excel, and [Build Kits](#)) are available for CIS [SecureSuite](#)® members.

CIS-CAT® Pro is also available to CIS [SecureSuite](#)® members.

Target Technology Details

This security configuration Benchmark covers foundational elements of IBM Cloud. The recommendations detailed here are important security considerations when designing your infrastructure on IBM Cloud Services.

To obtain the latest version of this guide, please visit <http://benchmarks.cisecurity.org>. If you have questions, comments, or have identified ways to improve this guide, please write us at BenchmarkInfo@cisecurity.org.

Intended Audience

This document is intended for system and application administrators, security specialists, auditors, help desk, platform deployment, and/or DevOps personnel who plan to develop, deploy, assess, or secure solutions on the IBM Cloud Platform.

Consensus Guidance

This CIS Benchmark™ was created using a consensus review process comprised of a global community of subject matter experts. The process combines real world experience with data-based information to create technology specific guidance to assist users to secure their environments. Consensus participants provide perspective from a diverse set of backgrounds including consulting, software development, audit and compliance, security research, operations, government, and legal.

Each CIS Benchmark undergoes two phases of consensus review. The first phase occurs during initial Benchmark development. During this phase, subject matter experts convene to discuss, create, and test working drafts of the Benchmark. This discussion occurs until consensus has been reached on Benchmark recommendations. The second phase begins after the Benchmark has been published. During this phase, all feedback provided by the Internet community is reviewed by the consensus team for incorporation in the Benchmark. If you are interested in participating in the consensus process, please visit <https://workbench.cisecurity.org/>.

Typographical Conventions

The following typographical conventions are used throughout this guide:

Convention	Meaning
<code>Stylized Monospace font</code>	Used for blocks of code, command, and script examples. Text should be interpreted exactly as presented.
<code>Monospace font</code>	Used for inline code, commands, UI/Menu selections or examples. Text should be interpreted exactly as presented.
<code><Monospace font in brackets></code>	Text set in angle brackets denote a variable requiring substitution for a real value.
<i>Italic font</i>	Used to reference other relevant settings, CIS Benchmarks and/or Benchmark Communities. Also, used to denote the title of a book, article, or other publication.
Bold font	Additional information or caveats things like Notes , Warnings , or Cautions (usually just the word itself and the rest of the text normal).

Recommendation Definitions

The following defines the various components included in a CIS recommendation as applicable. If any of the components are not applicable it will be noted, or the component will not be included in the recommendation.

Title

Concise description for the recommendation's intended configuration.

Assessment Status

An assessment status is included for every recommendation. The assessment status indicates whether the given recommendation can be automated or requires manual steps to implement. Both statuses are equally important and are determined and supported as defined below:

Automated

Represents recommendations for which assessment of a technical control can be fully automated and validated to a pass/fail state. Recommendations will include the necessary information to implement automation.

Manual

Represents recommendations for which assessment of a technical control cannot be fully automated and requires all or some manual steps to validate that the configured state is set as expected. The expected state can vary depending on the environment.

Profile

A collection of recommendations for securing a technology or a supporting platform. Most benchmarks include at least a Level 1 and Level 2 Profile. Level 2 extends Level 1 recommendations and is not a standalone profile. The Profile Definitions section in the benchmark provides the definitions as they pertain to the recommendations included for the technology.

Description

Detailed information pertaining to the setting with which the recommendation is concerned. In some cases, the description will include the recommended value.

Rationale Statement

Detailed reasoning for the recommendation to provide the user a clear and concise understanding on the importance of the recommendation.

Impact Statement

Any security, functionality, or operational consequences that can result from following the recommendation.

Audit Procedure

Systematic instructions for determining if the target system complies with the recommendation.

Remediation Procedure

Systematic instructions for applying recommendations to the target system to bring it into compliance according to the recommendation.

Default Value

Default value for the given setting in this recommendation, if known. If not known, either not configured or not defined will be applied.

References

Additional documentation relative to the recommendation.

CIS Critical Security Controls® (CIS Controls®)

The mapping between a recommendation and the CIS Controls is organized by CIS Controls version, Safeguard, and Implementation Group (IG). The Benchmark in its entirety addresses the CIS Controls safeguards of (v7) "5.1 - Establish Secure Configurations" and (v8) "4.1 - Establish and Maintain a Secure Configuration Process" so individual recommendations will not be mapped to these safeguards.

Additional Information

Supplementary information that does not correspond to any other field but may be useful to the user.

Profile Definitions

The following configuration profiles are defined by this Benchmark:

- **Level 1**

Items in this profile intend to:

- be practical and prudent;
- provide security focused best practice hardening of a technology; and
- limit impact to the utility of the technology beyond acceptable means.

- **Level 2**

This profile extends the "Level 1" profile. Items in this profile exhibit one or more of the following characteristics:

- are intended for environments or use cases where security is more critical than manageability and usability
- acts as defense in depth measure
- may impact the utility or performance of the technology
- may include additional licensing, cost, or addition of third party software

Acknowledgements

This Benchmark exemplifies the great things a community of users, vendors, and subject matter experts can accomplish through consensus collaboration. The CIS community thanks the entire consensus team with special recognition to the following individuals who contributed greatly to the creation of this guide:

Contributor

Mike Wicks
Dave Archer
Mark Seaborn
Venkat Kanduri
Noel Adimi
Mala Anand
Lesley Nuttall
Brian Countryman
Eric Vermeer
Andrew Hately

Editor

Zeeshan Khan
Maria Luisa Lopez de Silanes Ruiz
Shaun Kelley
JOSHUA MINTZ
Michael Breslin
Neil Taylor
Nikhil Gupta
Alex Parker
Ben Lopez
Shawn Authement
Luis Casco-Arias
Patricia Casey
Kayla McDonald
Janet Van
Alex Greer
Venky Nerkunam
Bernal Murillo
Brian Griffin

Recommendations

1 Identity and Access Management (IAM)

Identity and Access Management (IAM) can be used to manage access to platform activities as well as services labeled as "IAM-enabled" in the catalog. You can use IAM access policies to assign access to identities, such as users and service IDs, in your account. IAM supports attribute-based policies that can assign access to a group of resources based on attributes such as their resource group or access tags, and it also supports grouping mechanisms for IDs such as access groups and trusted profiles to simplify access management for groups of users.

1.1 Monitor account owner for frequent, unexpected, or unauthorized logins (Manual)

Profile Applicability:

- Level 1

Description:

Monitor login activity of the account owner to prevent unauthorized usage of the privileged account.

Rationale:

The owner of an IBM Cloud account by default has administrative privileges across the account. There may be other users also assigned administrative privileges to the account.

To prevent unauthorized or unintended usage, login credentials should never be shared and users in an organization should be granted least privilege to complete their required tasks. To manage the account, administrators are granted permissions to manage services and Cloud resources. Therefore, access by the account owner to the account to run tasks should be minimum. By monitoring the number of times that the account owner and administrative users log in to the account, you can:

- Monitor administrative access to the IBM Cloud account
- Identify abnormal behavior
- Enforce that administrators and operators of the services in your Cloud account are the ones managing the Cloud resources with their controlled and limited permissions.

When a user logs in to the account, a security login event is generated. The event reports who has logged in successfully in the account. You can use these security events to monitor the number of times that administrative privilege users have logged in to the account and generate an alert if the number exceeds a threshold that you set in a period of time that you specify.

Monitoring login activity of users with administrative privileges can help prevent unauthorized or unintended actions taken in the account. Account switching may result in multiple login events being logged and this should be taken into account.

Audit:

Before you can monitor and manage IBM event data with IBM Cloud Logs, you must provision an instance of the IBM Cloud Logs service.

Refer to the IBM Cloud Logs documentation to provision and start using an instance of IBM Cloud Logs <https://cloud.ibm.com/docs/cloud-logs?topic=cloud-logs-getting-started>.

Remediation:

Complete the following steps to monitor how many times an account owner logs in to the account:

First, you need to identify the email of the account owner.

1. In the Cloud UI, go to **Manage, Access (IAM)**, then select **Users**.
2. Identify the users identified with administrator privileges.
3. Select the account owner. Then, click **Details**.
4. Copy the email address of the account owner.

Launch the Activity Tracker instance in Frankfurt. This is the instance where login security events are collected in the account. In the Views section, select the **Everything** view. Then, enter the following query in the search bar:

```
(action login) AND initiator.name:<email address>
```

Replace with the account owner's email address. The view now reports all the login actions that are reported for the account owner.

Next, you can define an alert on the view to get a notification when N number of events are received within a 24 hour period. The value of N depends on how you operate your cloud. You can start with a default value of 25 and increase or decrease depending on the tasks that the account administrator can perform in the account.

Default Value:

no default value.

References:

1. <https://cloud.ibm.com/docs/cloud-logs>

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	5.4 Restrict Administrator Privileges to Dedicated Administrator Accounts Restrict administrator privileges to dedicated administrator accounts on enterprise assets. Conduct general computing activities, such as internet browsing, email, and productivity suite use, from the user's primary, non-privileged account.			
v7	16.13 Alert on Account Login Behavior Deviation Alert when users deviate from normal login behavior, such as time-of-day, workstation location and duration.			

1.2 Ensure API keys unused for 180 days are detected and optionally disabled (Manual)

Profile Applicability:

- Level 1

Description:

Monitor API key usage in your account and search for API keys that are unused or used infrequently.

Rationale:

If an API key is unused for long period in your account, it must be suspended or disabled as a security best practice. All API keys, even those that are used infrequently, must be rotated periodically.

To reduce the likelihood of accidental exposure or leaking, monitoring for infrequently used API keys can indicate that an API key can be suspended and even deleted, if there is no anticipated future usage.

Audit:

Using Console:

1. Log in to IBM Cloud at <https://cloud.ibm.com>.
2. Click **Manage**, **Access (IAM)**, and select Inactive Identities
3. Click **Update report** to view the most recent report of inactive identities in your account
4. Select the **API keys** tab to review a list of unused API keys

Remediation:

On the **Inactive Identities** report under **API keys** tab, review and remove the API keys no longer in use.

To delete inactive identities that are no longer in use for over 180 days, click the **Actions** icon, **Remove**

References:

1. <https://cloud.ibm.com/docs/account?topic=account-id-inactive-identities>

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	5.3 <u>Disable Dormant Accounts</u> Delete or disable any dormant accounts after a period of 45 days of inactivity, where supported.			
v7	16.9 <u>Disable Dormant Accounts</u> Automatically disable dormant accounts after a set period of inactivity.			

1.3 Ensure API keys are rotated every 90 days (Manual)

Profile Applicability:

- Level 1

Description:

Replace production API keys with new API keys regularly, every 90 days for example, as a best practice to secure your account.

Rationale:

API key rotation can help reduce the impact to your organization if an API key becomes exposed or compromised. If you suspect that a key might have been leaked or compromised, the key must be rotated out of production and deleted.

Impact:

Any resource that is using an API key that has been rotated out of production will encounter errors until the API key has been updated.

Audit:

Using Console:

To find out when an API key was created, complete the following steps:

1. Log in to IBM Cloud at <https://cloud.ibm.com>.
2. From the Menu bar, click **Manage, Access(IAM), API keys**.
3. Identify an API key and from the **Actions** menu, select **Details**.
4. View the date the API key was created.

Remediation:

Using Console:

To create new API key, complete the following steps:

1. Log in to IBM Cloud at <https://cloud.ibm.com>.
2. From the Menu bar, click **Manage, Access (IAM), API keys**.
3. Click **Create an IBM Cloud API key**.

To rotate an API key, replace an old API key anywhere it is used with the newly created API key.

Delete an old API key:

1. Log in to IBM Cloud at <https://cloud.ibm.com>.
2. From the Menu bar, click **Manage, Access (IAM), API keys**.

3. Identify the API key you want to delete, and from the Actions menu, select **Delete**.

You can also opt to use IBM Cloud Secrets Manager to auto-rotate keys - <https://www.ibm.com/products/secrets-manager>

Default Value:

By default, an API key rotation mechanism is not enabled. API key rotation is a manual process.

References:

1. <https://cloud.ibm.com/docs/account?topic=account-userapikey>
2. <https://cloud.ibm.com/docs/secrets-manager?topic=secrets-manager-automatic-rotation&interface=ui>

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	0.0 <u>Explicitly Not Mapped</u> Explicitly Not Mapped			
v7	4.7 <u>Limit Access to Script Tools</u> Limit access to scripting tools (such as Microsoft PowerShell and Python) to only administrative or development users with the need to access those capabilities.			

1.4 Restrict user API key creation and service ID creation in the account via IAM roles (Manual)

Profile Applicability:

- Level 1

Description:

Use IAM settings to restrict user API key creation and service ID (and related API key) creation in the account. Enable both settings to restrict all users in the account from creating user API keys and service IDs except those with an IAM policy that explicitly allows it.

Rationale:

API keys authenticate IBM Cloud identities. Once an API key has been created, an identity can use it to authenticate and perform any action the identity has access to in any account where that identity is valid and has access, even a different account from the one where the API key was created. Service IDs can be granted a subset of access that a user has, and then used to authenticate and perform actions in the account. Service IDs are intended to be used by applications and other programmatic entities, and so they persist in an account even after users who created them or had access to them have been deleted.

Creating an unauthorized service ID or API key on an existing service ID could be a way for a user to gain unauthorized access to an account after they've been deleted, and so creation of service IDs and API keys should be limited to those users who have a legitimate need to do so.

Impact:

This process involves two IAM controls. Enabling the restriction of user API keys will prevent users in an account from creating user API keys, except those with an explicit IAM policy to do so. Enabling the restriction of service ID creation will prevent users in an account from creating service IDs, except those with an explicit IAM policy to do so.

Audit:

Using Console:

1. Log in to IBM Cloud at <https://cloud.ibm.com>.
2. Click **Manage, Access (IAM)**.
3. Click **Settings**.
4. In the Account section of the Settings page, ensure that Restrict API key creation and Restrict service ID creation are enabled.

Remediation:

Using Console:

1. Log in to IBM Cloud at <https://cloud.ibm.com>.
2. Click **Manage, Access (IAM)**.
3. Click **Settings**.
4. In the Account section of the Settings page, ensure that Restrict API key creation and Restrict service ID creation are enabled.
5. Once enabled, only users with the correct IAM policies will be able to create user API keys and service IDs.

Default Value:

By default, user API key creation and service ID creation are not restricted.

References:

1. <https://cloud.ibm.com/docs/cloud-logs>
2. <https://cloud.ibm.com/docs/account?topic=account-userapikey>

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	<u>5.4 Restrict Administrator Privileges to Dedicated Administrator Accounts</u> Restrict administrator privileges to dedicated administrator accounts on enterprise assets. Conduct general computing activities, such as internet browsing, email, and productivity suite use, from the user's primary, non-privileged account.			
v7	<u>4.3 Ensure the Use of Dedicated Administrative Accounts</u> Ensure that all users with administrative account access use a dedicated or secondary account for elevated activities. This account should only be used for administrative activities and not internet browsing, email, or similar activities.			

1.5 Ensure no owner account API key exists (Manual)

Profile Applicability:

- Level 1

Description:

API keys by definition allow access to your account and resources in your account. The API key authenticates the identity and allows all access assigned to the identity for which it was created, therefore an API key created by user with administrative privileges has administrative level access to resources in the account.

Rationale:

In accordance with the practice of granting least privilege, API keys should not be created by an account owner because of the level of privilege automatically granted to account-owner created API keys.

Impact:

The API key authenticates the identity and allows all access assigned to the identity for which it was created, therefore an API key created by an account owner has account-owner level access to resources in the account.

Audit:

To check for the existence of an API key created by an administrative user, complete the following steps.

1. Login as any administrative user at cloud.ibm.com
2. Click **Manage, Access (IAM)**
3. Click **API keys**
4. Check for any API keys that appear under the **My IBM Cloud API keys** view

Remediation:

To delete an API key, complete the following steps:

1. Login as the administrative user at cloud.ibm.com
2. In the console, go to **Manage, Access (IAM)**
3. Click on **API keys**
4. Identify the row of the API key that you want to delete and select **Delete** from the Actions List of actions icon menu (found on the right hand side of the row).
5. Then, confirm the deletion by clicking **Delete**.
6. If you have scenarios where you need a higher level of access, then you should setup a Trusted Profile with these privileges and use it with a less privileged identity

Default Value:

By default, there are no account-owner API keys created in an account.

References:

1. <https://cloud.ibm.com/docs/account?topic=account-userapikey>
2. <https://cloud.ibm.com/docs/account?topic=account-create-trusted-profile>

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	0.0 <u>Explicitly Not Mapped</u> Explicitly Not Mapped			
v7	4.7 <u>Limit Access to Script Tools</u> Limit access to scripting tools (such as Microsoft PowerShell and Python) to only administrative or development users with the need to access those capabilities.			

1.6 Ensure multi-factor authentication (MFA) is enabled for all users in account (Manual)

Profile Applicability:

- Level 1

Description:

Requires users to provide multiple factors of login credentials to authenticate their identity and gain access to IBM Cloud resources.

Rationale:

Multifactor authentication (MFA) adds an additional layer of security to an account by requiring users to provide an additional login credential. This requirement helps protect accounts from stolen, phished, or weak password exploits.

Impact:

Depending on the administrator's selection, users might be required to provide an additional authentication factor prior to gaining access to IBM Cloud resources. API keys for users and service IDs continue to work after MFA is enabled.

Audit:

Using Console:

1. Log in to IBM Cloud at <https://cloud.ibm.com>.
2. From the Menu bar, click **Manage, Access (IAM)**.
3. Click **Settings, Account login**.
4. Verify **Multifactor authentication** does not say **None**

Remediation:

Using Console:

1. Log in to IBM Cloud at <https://cloud.ibm.com>.
2. From the Menu bar, click **Manage, Access (IAM)**.
3. Click **Settings, Account login**.
4. Click **Edit** for the Account login setting.
5. Select **Non-federated users only**, or **All users** depending on which type of authentication you want to require.
6. Select the checkbox to confirm that you understand the impact of requiring MFA for users in your account, if you select the non-federated users only option.
7. Click **Update**.

Default Value:

By default, MFA is disabled.

References:

1. <https://cloud.ibm.com/docs/account?topic=account-enablemfa>

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	6.4 <u>Require MFA for Remote Network Access</u> Require MFA for remote network access.			
v7	16.3 <u>Require Multi-factor Authentication</u> Require multi-factor authentication for all user accounts, on all systems, whether managed onsite or by a third-party provider.			

1.7 Ensure multi-factor authentication (MFA) is enabled for the account owner and all administrative users (Manual)

Profile Applicability:

- Level 1

Description:

Requires account owner to provide multiple factors of login credentials to authenticate their identity and gain access to IBM Cloud resources.

Rationale:

Multifactor authentication (MFA) adds an additional layer of security to an account by requiring users to provide an additional login credential. This requirement helps protect accounts from stolen, phished, or weak password exploits.

Impact:

Depending on the administrator's selection, users might be required to provide an additional authentication factor prior to gaining access to IBM Cloud resources. API keys for users and service IDs continue to work after MFA is enabled.

Audit:

Using Console:

1. Log in to IBM Cloud at <https://cloud.ibm.com>.
2. From the Menu bar, click **Manage, Access (IAM)**.
3. Click **Settings, Account login**.
4. Verify **Multifactor authentication** does not say **None**.

Remediation:

Using Console:

1. Log in to IBM Cloud at <https://cloud.ibm.com>.
2. From the Menu bar, click **Manage, Access (IAM)**.
3. Click **Settings, Account login**.
4. Click **Edit** for the Account login setting.
5. Select **Non-federated users only**, or **All users** depending on which type of authentication you want to require.
6. Select the checkbox to confirm that you understand the impact of requiring MFA for users in your account, if you select the non-federated users only option.
7. Click **Update**.

Default Value:

By default, MFA is disabled.

References:

1. <https://cloud.ibm.com/docs/account?topic=account-enablemfa>

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	6.5 <u>Require MFA for Administrative Access</u> Require MFA for all administrative access accounts, where supported, on all enterprise assets, whether managed on-site or through a third-party provider.			
v7	4.5 <u>Use Multifactor Authentication For All Administrative Access</u> Use multi-factor authentication and encrypted channels for all administrative account access.			

1.8 Ensure multi-factor authentication (MFA) is enabled at the account level (Manual)

Profile Applicability:

- Level 1

Description:

Requires users to provide multiple factors of login credentials to authenticate their identity and gain access to IBM Cloud resources.

Rationale:

Multifactor authentication (MFA) adds an additional layer of security to an account by requiring users to provide an additional login credential. This requirement helps protect accounts from stolen, phished, or weak password exploits.

Impact:

Depending on the administrator's selection, users might be required to provide an additional authentication factor prior to gaining access to IBM Cloud resources. API keys for users and service IDs continue to work after MFA is enabled.

Audit:

Using Console:

1. Log in to IBM Cloud at <https://cloud.ibm.com>.
2. From the Menu bar, click **Manage, Access (IAM)**.
3. Click **Settings, Account login**.
4. Verify **Multifactor authentication** does not say **None**

Remediation:

Using Console:

1. Log in to IBM Cloud at <https://cloud.ibm.com>.
2. From the Menu bar, click **Manage, Access (IAM)**.
3. Click **Settings, Account login**.
4. Click **Edit** for the Account login setting.
5. Select **Non-federated users only**, or **All users** depending on which type of authentication you want to require.
6. Select the checkbox to confirm that you understand the impact of requiring MFA for users in your account, if you select the non-federated users only option.
7. Click **Update**.

Default Value:

By default, MFA is enabled but older accounts may not have this as a default.

References:

1. <https://cloud.ibm.com/docs/account?topic=account-enablemfa>

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	6.5 <u>Require MFA for Administrative Access</u> Require MFA for all administrative access accounts, where supported, on all enterprise assets, whether managed on-site or through a third-party provider.			
v7	4.5 <u>Use Multifactor Authentication For All Administrative Access</u> Use multi-factor authentication and encrypted channels for all administrative account access.			

1.9 Ensure contact email is valid (Manual)

Profile Applicability:

- Level 1

Description:

In order to receive emails and account alerts related to an IBM Cloud account, a valid email address should always be on record with IBM Cloud. If you lose access to an email address, you should update your email address on record to ensure continuity of correspondence.

Rationale:

Maintaining a valid email address on record is important to make sure you receive important account related information.

Impact:

Maintaining a valid email address on record allows you to receive correspondence from IBM Cloud about your account.

Audit:

Using Console:

1. Log in to IBM Cloud at <https://cloud.ibm.com>.
2. Click **Avatar icon**, **Profile**.
3. Verify the **Email** field in the **Contact information** section contains your correct email address.

Remediation:

Using Console:

1. Log in to IBM Cloud at <https://cloud.ibm.com>.
2. Click **Avatar icon**, **Profile**.
3. Click the **Edit** link in the **Contact information** section
4. Update your email to the correct email address.

Default Value:

By default, the email address on record is provided during account creation.

References:

1. <https://cloud.ibm.com/docs/account?topic=account-usersettings>

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	<u>17.2 Establish and Maintain Contact Information for Reporting Security Incidents</u> Establish and maintain contact information for parties that need to be informed of security incidents. Contacts may include internal staff, third-party vendors, law enforcement, cyber insurance providers, relevant government agencies, Information Sharing and Analysis Center (ISAC) partners, or other stakeholders. Verify contacts annually to ensure that information is up-to-date.			
v7	<u>19.5 Maintain Contact Information For Reporting Security Incidents</u> Assemble and maintain information on third-party contact information to be used to report a security incident, such as Law Enforcement, relevant government departments, vendors, and ISAC partners.			

1.10 Ensure contact phone number is valid (Manual)

Profile Applicability:

- Level 1

Description:

A valid phone number should be on record with IBM Cloud in the event that IBM needs to contact you regarding your IBM Cloud account.

Rationale:

Maintaining a valid phone number on record is important to make sure you receive important account related information from IBM Cloud when necessary.

Audit:

Using Console:

1. Log in to IBM Cloud at <https://cloud.ibm.com>.
2. Click **Avatar icon**, **Profile**.
3. Verify the **Primary phone number** and **Alternate phone number** fields in the **Contact information** section contain your correct phone numbers.

Remediation:

Using Console:

1. Log in to IBM Cloud at <https://cloud.ibm.com>.
2. Click **Avatar icon**, **Profile**.
3. Click the **Edit** link in the **Contact information** section
4. Update your Primary and Alternate phone numbers.

Default Value:

By default, there is no phone number on record.

References:

1. <https://cloud.ibm.com/docs/account?topic=account-usersettings>

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	<u>17.2 Establish and Maintain Contact Information for Reporting Security Incidents</u> Establish and maintain contact information for parties that need to be informed of security incidents. Contacts may include internal staff, third-party vendors, law enforcement, cyber insurance providers, relevant government agencies, Information Sharing and Analysis Center (ISAC) partners, or other stakeholders. Verify contacts annually to ensure that information is up-to-date.			
v7	<u>19.5 Maintain Contact Information For Reporting Security Incidents</u> Assemble and maintain information on third-party contact information to be used to report a security incident, such as Law Enforcement, relevant government departments, vendors, and ISAC partners.			

1.11 Ensure Trusted Profiles are used in place of ServiceIDs wherever feasible (Manual)

Profile Applicability:

- Level 1

Description:

IBM Cloud trusted profiles are used to securely manage identity and access for applications running on IBM Cloud without relying on static credentials like API keys.

Rationale:

One use of Trusted Profiles is to allow an application running on an IBM Cloud compute resource to assume the Trusted Profile and its access based on the identity of the compute resource where it is running, eliminating the need for the application to store and manage an API key.

Trusted Profiles are preferred over ServiceIDs because they offer a more secure, scalable, and maintainable approach to identity and access management. Unlike ServiceIDs, which are static and tied to specific credentials, Trusted Profiles leverage the built-in identities of compute resources to assign least privilege access to applications running on those compute resources. They reduce the risk of credential sprawl and simplify auditing and compliance. By using Trusted Profiles for application identities, organizations can reduce the need to store and rotate API keys, improving their security posture and streamlining management.

Impact:

When a Trusted Profile is created in IBM Cloud, you can assign compute resources a trust relationship, allowing them to assume the Trusted Profile, and configure access policies.

Audit:

To check if you have trusted profiles set up in your IBM Cloud account

1. Log in to the IBM Cloud Console
2. Navigate to **IAM, Trusted Profiles**.

This section displays all existing profiles, including those assigned to users, federated identities, or compute resources like Kubernetes clusters.

Remediation:

To create new trusted profile, complete the following steps:

1. Log in to the IBM Cloud Console
2. Navigate to **Manage, Access (IAM), Trusted profiles**
3. Click **Create** and define the profile's name, description, trusted entity type (such as federated users or compute resources), and access conditions.

Default Value:

By default, IBM Cloud accounts do not have trusted profile configured.

References:

1. <https://cloud.ibm.com/docs/account?topic=account-create-trusted-profile>

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	0.0 <u>Explicitly Not Mapped</u> Explicitly Not Mapped			

1.12 Ensure Context-Based Restrictions are implemented to enforce secure, conditional access to critical resources based on network location, IP range, or identity attributes (Manual)

Profile Applicability:

- Level 1

Description:

IBM Cloud Context-Based Restrictions are a security feature that allows administrators to control access to cloud resources based on the context of the request, such as the IP address the request is made from, not just the identity of the user or service.

Rationale:

IBM Cloud's Context-Based Restrictions (CBRs) provide an essential layer of defense by enforcing access conditions based on network location or type of endpoint, not just IAM roles. This means even if a user has the correct permissions, their request can be blocked if it originates from an untrusted context. By implementing CBRs, organizations can reduce the risk of unauthorized access, enforce compliance policies, and protect critical services like Cloud Object Storage, Key Protect, and Secrets Manager. In short, CBRs help turn identity-based access into context-aware security, which is vital in today's hybrid and distributed environments.

Impact:

Once a context-based restriction is enabled in IBM Cloud, you can enforce access controls that go beyond identity and role by evaluating the context of each request.

Audit:

To check if you have a Context-Based Restriction (CBR) set in IBM Cloud, follow these steps:

1. Log in to the IBM Cloud Console:
2. Navigate to **IAM, Context-based restrictions** in the left-hand menu
3. Under the Rules tab, you'll see a list of all active CBR rules in your account. Each rule will show:
 - The network zone it applies to (e.g., IP ranges, VPCs)
 - The target service or resource (e.g., Cloud Object Storage, Key Protect)
 - The action (allow or deny)
 - Any conditions or exceptions
4. You can click on each rule to view its details, including which users or services it affects and when it was last modified.
5. If no rules are listed, then no CBRs are currently enforced in your account.

Remediation:

To create new trusted profile, complete the following steps:

1. Log in to the IBM Cloud Console:
2. Navigate to **Manage, Context-based restrictions**, then select **Network zones** from the left navigation menu.
3. click **Create** and define the network zone(s) you want to allow access from, using allowed or denied IP addresses, subnets, or ranges, VPCs, and IBM Cloud services.
4. Select **Rules** from the left navigation menu
5. Click **Create** and select the service, APIs, and resources you want the rule to apply to, select the context including the zone you defined, and specify whether to enable or report on this rule.

Default Value:

By default, there are no context-based restriction (CBR) rules set and are an optional security feature that must be explicitly configured by an administrator.

References:

1. <https://cloud.ibm.com/docs/account?topic=account-cbr>
2. <https://cloud.ibm.com/docs/account?topic=account-context-restrictions-what-is#cbr-adopters>

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	0.0 <u>Explicitly Not Mapped</u> Explicitly Not Mapped			

1.13 Ensure limitations on External Identity Interactions are Enabled (Manual)

Profile Applicability:

- Level 1

Description:

Use IAM settings to restrict external identity interactions in your account. This will block all API calls if the calling userID is not authenticated to your account and has logged in using an API key in a different account.

Rationale:

When a user authenticates using an API key in one account, that user can use their token to do actions in any account they are a member of providing they have access policy.

Impact:

A user's exposed or unrotated API key in another account can't be used to access that user's resources in your account.

Audit:

To check if you have the External identities interactions limitation set in IBM Cloud, follow these steps:

1. Log in to the IBM Cloud Console
2. Go to **Manage, IAM**
3. Select **Settings** in the left-hand menu
4. Select the Resources tab
5. In the External identity interactions box, select **Edit**
6. Ensure the **Limited** option is selected

Remediation:

1. Log in to the IBM Cloud Console
2. Go to **Manage, IAM**
3. Select **Settings** in the left-hand menu
4. Select the Resources tab
5. In the External identity interactions box, select **Edit**
6. When turning the setting on for the first time in an existing account, it is recommended to enable the setting in **Report-only** mode for 30 days, then monitor ICL logs for any calls made from other accounts. If valid cross-account flows are found, they can be explicitly allowed by creating a trusted profile with

the appropriate access and allowing the identity in a different account to assume the trusted profile in your account.

7. After remediating any desired cross-account interactions, set the value of the setting to **Limited**.

Default Value:

By default, there are no restrictions on interactions when a user in your account has authenticated in a different account they are also a member of.

References:

1. <https://cloud.ibm.com/docs/account?topic=account-cross-acct>

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	0.0 <u>Explicitly Not Mapped</u> Explicitly Not Mapped			

1.14 Ensure IAM users with the same level of access are members of access groups and IAM policies are assigned only to access groups or Trusted Profiles (Manual)

Profile Applicability:

- Level 1

Description:

Simplify and secure the access management process by using access groups or Trusted Profiles when you assign access to groups of users with identical access needs.

Rationale:

You can create an access group or a Trusted Profile so that you can organize a set of users and service IDs into a single entity that makes it easy for you to assign access. You can assign a single policy to the group instead of assigning the same access multiple times for each individual user or service ID.

Using access groups or Trusted Profiles reduces the number of policies that must be created and managed in the account and simplifies the process of adding new users or service IDs or modifying user and service IDs access.

Audit:

Using Console:

Audit user access policies:

1. Log in to IBM Cloud at <https://cloud.ibm.com>.
2. From the Menu bar, click **Manage, Access (IAM)**.
3. Click **Users** and select a user by clicking on the username.
4. Click **Access Policies**.

***If the user has individual access policies and you wish to remove them, complete the appropriate remediation steps.

Remediation:

Using Console:

Assign an access policy to an Access Group:

1. Log in to IBM Cloud at <https://cloud.ibm.com>.
2. From the Menu bar, click **Manage, Access(IAM)**.
3. Click **Access Groups** or **Trusted Profiles**
4. Click an Access Group or Trusted Profile name, then click the **Access tab**

5. Click **Assign access**.

Add members to an Access Group or Trusted Profile:

1. Log in to IBM Cloud at <https://cloud.ibm.com>.
2. From the Menu bar, click **Manage, Access(IAM)**.
3. Click **Access Groups** or **Trusted Profiles**.
4. Click an Access Group or Trusted Profile name.
5. Click **Add**.

Delete an access policy for a user:

1. Log in to IBM Cloud at <https://cloud.ibm.com>.
2. From the Menu bar, click **Manage, Access(IAM)**.
3. Click **Users**.
4. Click on a user name.
5. Click the **Access tab**
6. Locate the row containing the access policy you wish to remove. Click the

actions icon corresponding to that row and click **Remove**.

Default Value:

By default, only the Public Access Group is enabled in IBM Cloud accounts.

References:

1. <https://cloud.ibm.com/docs/account?topic=account-groups>
2. <https://cloud.ibm.com/docs/account?topic=account-create-trusted-profile>

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	5.4 Restrict Administrator Privileges to Dedicated Administrator Accounts Restrict administrator privileges to dedicated administrator accounts on enterprise assets. Conduct general computing activities, such as internet browsing, email, and productivity suite use, from the user's primary, non-privileged account.			
v7	4.3 Ensure the Use of Dedicated Administrative Accounts Ensure that all users with administrative account access use a dedicated or secondary account for elevated activities. This account should only be used for administrative activities and not internet browsing, email, or similar activities.			

1.15 Ensure a support access group has been created to manage incidents with IBM Support (Manual)

Profile Applicability:

- Level 1

Description:

If you experience problems with IBM Cloud®, you can use support cases to get help with technical, access (IAM), billing & usage, and invoice or sales inquiry issues. You can create and manage a support case by using the Support Center. Access to Support Center is governed via IAM roles. In order to access Support Center, a user must have viewer or higher on the Support Center service. To create or edit service cases, a user must have editor or higher on the Support Center service. After you submit a support case, the support team investigates the issue based on your type of support plan.

The types of available support depends on the support level of the account. Your support plan also determines the severity level that you can assign to support cases. For more information, see Case severity and response time.

Rationale:

Support cases are used to raise issues to IBM Cloud. Access to IBM Cloud Support Center is managed via IAM roles. IAM roles can be used to efficiently control which users in an organization can view support cases, which can view, edit, and delete support cases, and which have no access at all. You can configure different levels of Support Center access using Access Groups.

Impact:

Users with access to IBM Cloud Support Center can create and/or manage support tickets based on their IAM role. Support Center access should be managed and assigned using Access Groups.

Audit:

Using Console:

1. In the IBM Cloud console, go to **Manage, Access (IAM)**, and then select **Access Groups**.
2. Look for an access group relating to Support Center. Access Group names are customizable and vary from customer to customer.
3. To verify the access policies for an Access Group, click on an Access Group name and then click **Access policies**.
4. Check for access policies on the Support Center service.

Remediation:

Using Console:

1. In the IBM Cloud console, go to **Manage, Access (IAM)**, and then select **Access Groups**.
2. Select **Create Access Group**.
3. Give the Access Group a descriptive name, for example, Support Center Viewers or Support Center Admins.
4. Optionally, provide a brief description.
5. Click **Create**.
6. Once the Access Group is created, click on the **Access Policies** tab.
7. Click **Assign Access**.
8. Click on **Account Management** and select **Support Center** from the drop down menu.
9. Select the Support Center role(s) that meet your use case. Descriptions are provided for each role in the IAM UI.
10. Click **add**.
11. Click **Assign**.
12. Click on the **Users** tab.
13. Click **Add users**
14. Select users from the list and click **Add to group**.

Default Value:

By default, users do not have access to IBM Cloud Support Center.

References:

1. <https://cloud.ibm.com/docs/account?topic=account-using-avatar>

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	17.1 Designate Personnel to Manage Incident Handling Designate one key person, and at least one backup, who will manage the enterprise's incident handling process. Management personnel are responsible for the coordination and documentation of incident response and recovery efforts and can consist of employees internal to the enterprise, third-party vendors, or a hybrid approach. If using a third-party vendor, designate at least one person internal to the enterprise to oversee any third-party work. Review annually, or when significant enterprise changes occur that could impact this Safeguard.			
v7	19.3 Designate Management Personnel to Support Incident Handling Designate management personnel, as well as backups, who will support the incident handling process by acting in key decision-making roles.			

1.16 Ensure Minimal Number of Users are Granted Administrative Privileges (Manual)

Profile Applicability:

- Level 1

Description:

Comply with the principle of granting least privilege by using Access Groups or Trusted Profiles to manage admin privileges and by avoiding the use of broadly scoped access policies.

Rationale:

The principle of granting least privilege mandates that a user must only be given access to the resources that are required to complete their task. This task can be hard to maintain when managing large numbers of users. Instead of assigning administrative privileges to individual users, create Access Groups with administrative privileges and add or remove users from these Access Groups as needed. Additionally, instead of using the Platform Administrator role for all Platform Services or all IAM-enabled services, IBM Cloud users can grant access to specific resources and account management services to better comply with the principle of granting least privilege.

Impact:

Managing administrative access via Access Groups or Trusted Profiles simplifies the process of adding/removing admin privileges from users in the account. Having too many users with Administrative privileges goes against the principle of granting least privileges and mean many possible holes for any security attack.

Audit:

Using Console:

1. Log in to IBM Cloud at <https://cloud.ibm.com>.
2. From the Menu bar, click **Manage, Access(IAM)**.
3. Click **Users** and select a User by clicking on the User name.
4. Click on the **Access Policies** tab.

View the access policies assigned to the User to verify if that User has Administrator Role assigned.

5. Review Access Groups and Trusted Profiles to determine which grant Administrator privileges.
6. For Access Groups and Trusted Profiles that grant Administrator.

privileges, review which users are members of the Access Groups or allowed to assume the Trusted Profiles.

7. Verify that all users who have Administrator privileges have a legitimate need for those privileges.

Remediation:

Using Console:

To remove excessive number of Users with Administrative privileges, follow the following steps.

1. Log in to IBM Cloud at <https://cloud.ibm.com>.
2. From the Menu bar, click **Manage, Access(IAM)**.
3. Click **Users** and select an User by clicking on the User name.
4. Click on the **Access Policies** tab.
5. View the access policies assigned to the User to verify if that User has Administrator Role. assigned on all Platform Services or all IAM-enabled services.
6. Review Access Groups and Trusted Profiles to determine which grant Administrator privileges.
7. For Access Groups and Trusted Profiles that grant Administrator privileges, review which users are members of the Access Groups or allowed to assume the Trusted Profiles.
8. If there are users who have Administrator privileges but do not have a legitimate need for them, remove the user's access policy or remove the user from the Access Group or Trusted. Profile. Alternatively you may remove the user from the account.

Default Value:

By default, there are no administrator Access Groups in the account.

References:

1. <https://cloud.ibm.com/docs/account?topic=account-userroles>

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	5.1 <u>Establish and Maintain an Inventory of Accounts</u> Establish and maintain an inventory of all accounts managed in the enterprise. The inventory must include both user and administrator accounts. The inventory, at a minimum, should contain the person's name, username, start/stop dates, and department. Validate that all active accounts are authorized, on a recurring schedule at a minimum quarterly, or more frequently.			
v7	4.1 <u>Maintain Inventory of Administrative Accounts</u> Use automated tools to inventory all administrative accounts, including domain and local accounts, to ensure that only authorized individuals have elevated privileges.			

1.17 Ensure Minimal Number of Service IDs are Granted Administrative Privileges (Manual)

Profile Applicability:

- Level 1

Description:

Comply with the principle of granting least privilege by using Access Groups to manage admin privileges and by avoiding the use of many Service IDs with Administrative Privileges.

Rationale:

The principle of granting least privilege mandates that a Service ID must only be given access to the resources that are required to complete their task. This task can be hard to maintain when managing large numbers of users. Instead of assigning administrative privileges to an individual Service ID, create Access Groups with administrative privileges and add or remove Service IDs from these Access Groups as needed. Additionally, instead of using the Platform Administrator role for all Platform Services or IAM-enabled services, IBM Cloud users can grant access to specific resources and account management services to better comply with the principle of granting least privilege.

Impact:

Managing administrative access via Access Groups simplifies the process of adding/removing admin privileges from users in the account. Having too many Service IDs with Administrative privileges goes against the principle of granting least privileges and mean many possible holes for any security attack.

Audit:

Using Console:

1. Log in to IBM Cloud at <https://cloud.ibm.com>.
2. From the Menu bar, click **Manage, Access(IAM)**.
3. Click **Service IDs** and select a Service ID by clicking on the Service ID name.
4. Click on the **Access Policies** tab.
5. View the access policies assigned to the Service ID to verify if that Service ID has Administrator Role assigned on all Platform Services or all IAM-enabled services
6. Verify that all service IDs that have Administrator privileges are in use and have a legitimate need for those privileges.

Remediation:

Using Console:

To remove excessive number of Users with Administrative privileges, follow the following steps.

1. Log in to IBM Cloud at <https://cloud.ibm.com>.
2. From the Menu bar, click **Manage, Access(IAM)**.
3. Click **Service IDs** and select a Service ID by clicking on the Service ID name.
4. Click on the **Access Policies** tab.
5. View the access policies assigned to the Service **IDUser** to verify if that Service ID has Administrator Role assigned on all IAM-Enabled services or all Platform Service
6. Review Access Groups and Trusted Profiles to determine which grant Administrator privileges.
7. For Access Groups and Trusted Profiles that grant Administrator privileges, review which Service IDs are members of the Access Groups or allowed to assume the Trusted Profiles.
8. If there are Service IDs that have Administrator privileges but do not have a legitimate need for them, remove the Service ID's access policy or remove the Service ID from the Access Group or Trusted Profile. Alternatively you may remove the Service ID from the account.

Default Value:

By default, there are no administrator Access Groups in the account.

References:

1. <https://cloud.ibm.com/docs/account?topic=account-userroles>

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	5.4 Restrict Administrator Privileges to Dedicated Administrator Accounts Restrict administrator privileges to dedicated administrator accounts on enterprise assets. Conduct general computing activities, such as internet browsing, email, and productivity suite use, from the user's primary, non-privileged account.			
v8	5.5 Establish and Maintain an Inventory of Service Accounts Establish and maintain an inventory of service accounts. The inventory, at a minimum, must contain department owner, review date, and purpose. Perform service account reviews to validate that all active accounts are authorized, on a recurring schedule at a minimum quarterly, or more frequently.			

Controls Version	Control	IG 1	IG 2	IG 3
v7	4.3 <u>Ensure the Use of Dedicated Administrative Accounts</u> Ensure that all users with administrative account access use a dedicated or secondary account for elevated activities. This account should only be used for administrative activities and not internet browsing, email, or similar activities.			

1.18 Ensure IAM Does Not Allow Public Access to Cloud Services (Manual)

Profile Applicability:

- Level 1

Description:

IBM Cloud features the capability for users with specific access roles to create access policies that allow all users (authenticated and non-authenticated) to access resources in the account. This “all users” access in turn ends up in public (including non-authenticated) access to resources. Determine if this capability is required by your organization and disable if not required.

Rationale:

Some customer use cases require that certain files or data are made available for all users to access, both authenticated and non-authenticated. Even if the public access setting is enabled, resources in your account are not publicly accessible unless an administrator level user has explicitly created a policy to create public access for a resource. As a best practice, if this capability is not required by your organization, it must be disabled to prevent unintentional misuse.

Impact:

If the public access setting is enabled in the account, an administrator level user can create access policies to make resources publicly accessible. Resources are not publicly accessible unless an administrator creates an access policy, regardless of setting.

Audit:

Using Console:

1. Log in to IBM Cloud at <https://cloud.ibm.com>.
2. From the Menu bar, click **Manage, Access (IAM)**.
3. Click **Settings**.
4. In the public access section of IAM Settings, observe the Public access group setting.
5. If the Public access group setting is disabled, IAM is not providing public access.
6. If the Public access group setting is enabled, proceed to the Access groups page by clicking Access Groups.
7. From the list of Access Groups, select Public Access by clicking on the Access Group name.
8. Ensure that there are no access policies present for services in the list of access policies.

Remediation:

Using Console:

To disable the Public Access Group:

1. Log in to IBM Cloud at <https://cloud.ibm.com>.
2. From the Menu bar, click **Manage, Access (IAM)**.
3. Click **Settings, Public Access**.
4. Disable Public Access to disable the Public Access Group.

To keep the Public Access Group enabled and verify that no access policies exist:

1. Log in to IBM Cloud at <https://cloud.ibm.com>.
2. From the Menu bar, click **Manage, Access (IAM)**.
3. Click **Settings**.
4. In the public access section of IAM Settings, observe the Public access group setting.
5. If the Public access group setting is disabled, IAM is not providing public access.
6. If the Public access group setting is enabled, proceed to the Access groups page by clicking Access Groups.
7. From the list of Access Groups, select Public Access by clicking on the Access Group name.
8. Ensure that there are no access policies present in the list of access policies.
9. To delete an access policy, click on the action menu icon for the access policy and click **Remove**.

Default Value:

By default, the public access group is enabled and there is no public access allowed.

References:

1. <https://cloud.ibm.com/docs/account?topic=account-public>
2. <https://cloud.ibm.com/docs/account?topic=account-public&interface=ui#disable-public-api>

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	6.8 Define and Maintain Role-Based Access Control Define and maintain role-based access control, through determining and documenting the access rights necessary for each role within the enterprise to successfully carry out its assigned duties. Perform access control reviews of enterprise assets to validate that all privileges are authorized, on a recurring schedule at a minimum annually, or more frequently.			●

Controls Version	Control	IG 1	IG 2	IG 3
v7	14.6 <u>Protect Information through Access Control Lists</u> Protect all information stored on systems with file system, network share, claims, application, or database specific access control lists. These controls will enforce the principle that only authorized individuals should have access to the information based on their need to access the information as a part of their responsibilities.			

1.19 Ensure Inactive User Accounts are Suspend (Manual)

Profile Applicability:

- Level 1

Description:

Revoke access privileges for users in an IBM Cloud account that are inactive, typically defined as user accounts with no logins in a given time frame.

Rationale:

Users and other identities can become inactive for a number of reasons, for example, vacation, parental leave, new roles within the company, or sick leave for user identities. If an identity's access needs to be temporarily revoked, you can suspend the user in the account to prevent access.

Impact:

After a user's status is updated to **Suspended**, the user is unable to gain access to any IBM Cloud resources.

Audit:

Using Console:

1. Log in to IBM Cloud at <https://cloud.ibm.com>.
2. From the Menu bar, click **Manage**, Access (IAM).
3. To view a list of inactive identities in the account, click **Gain Insight**, **Inactive Identities**
4. Click **Update report** to view the most recent report of inactive identities in your account
5. The list will also show the status for each user in the account.
6. To change a users' status, click on the **Actions** menu and select **Remove name**.
7. Under **User details**, select the desired status in the User status drop down.
8. Click **Apply**.

To check the last time a user logged in, follow the steps to enable Activity Tracker with IBM Cloud Logs in recommendation Enable audit logging for IBM Cloud Identity and Access Management.

Remediation:

Using Console:

1. Log in to IBM Cloud at <https://cloud.ibm.com>.
2. From the Menu bar, click **Manage**, **Access (IAM)**.
3. To view a list of users in the account, click **Users**.

4. The user list will also show the status for each user in the account.
5. To suspend a user, click on a user name.
6. Under **User details**, select **Suspended** in the User status drop down.
7. Click **Apply**.

Default Value:

By default, if an IBMid is associated with the user, user accounts are *Active*; if no IBMid is associated with the user, user accounts are *Pending*. When a new user completes the IBM Cloud onboarding agreement, the *Pending* status changes to *Active*.

References:

1. <https://cloud.ibm.com/status>
2. <https://cloud.ibm.com/apidocs/user-management#get-user-profile>

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	5.3 <u>Disable Dormant Accounts</u> Delete or disable any dormant accounts after a period of 45 days of inactivity, where supported.			
v7	16.9 <u>Disable Dormant Accounts</u> Automatically disable dormant accounts after a set period of inactivity.			

1.20 Enable audit logging for IBM Cloud Identity and Access Management (Manual)

Profile Applicability:

- Level 1

Description:

Use the IBM Cloud Activity Tracker with IBM Cloud Logs service to monitor certain IAM events.

Rationale:

As a security officer, auditor, or manager, you can use the IBM Cloud Activity Tracker with IBM Cloud Logs service to track how users and applications interact with IBM Cloud Identity and Access Management (IAM). You can use this service to investigate abnormal activity and critical actions and comply with regulatory audit requirements.

Impact:

Activity Tracker with IBM Cloud Logs allows you to track the following IAM events:

- Managing access groups by creating and deleting groups or adding and removing users
- Creating, updating, or deleting service IDs
- Creating, updating, or deleting API keys
- Creating, updating, or deleting access policies
- Logging in to IBM Cloud by using an API key, authorization code, passcode, password, or an API key that is associated with a service ID

Audit:

Using Console:

1. Log in to IBM Cloud at <https://cloud.ibm.com>.
2. Go to the Menu icon. Then, select **Observability** to access the Observability dashboard.
3. Select **Activity Tracker** from the page navigation menu
4. Check that you can see an IBM Cloud Activity Tracker with IBM Cloud Logs

instance in Frankfurt and one instance for each location where you operate in the IBM Cloud.

Remediation:

You must create an instance of the IBM Cloud Activity Tracker with IBM Cloud Logs service in the Frankfurt region to start tracking IAM events. Use a minimum of a 7-day event search.

Using Console:

1. Log in to IBM Cloud at <https://cloud.ibm.com>.
2. Go to the Menu icon. Then, select **Observability** to access the Observability dashboard.
3. Select Activity Tracker from the page navigation menu
4. Click Create instance to create an instance of IBM Cloud **Activity Tracker** with IBM Cloud Logs.
5. In the Select a region drop down, choose Frankfurt.
6. Select a pricing plan, service name, resource group, and provide optional tags. Choose a plan that offers a minimum of 7-day event search.
7. Click **Create**

Default Value:

By default, audit logging with Activity Tracker with IBM Cloud Logs is not enabled.

References:

1. <https://cloud.ibm.com/docs/account>
2. https://cloud.ibm.com/docs/atracker?topic=atracker-route_v2&interface=cli#route_behaviour
3. <https://cloud.ibm.com/docs/atracker?topic=atracker-getting-started>
4. <https://cloud.ibm.com/docs/cloud-logs>

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	8.2 Collect Audit Logs Collect audit logs. Ensure that logging, per the enterprise's audit log management process, has been enabled across enterprise assets.			
v7	6.3 Enable Detailed Logging Enable system logging to include detailed information such as an event source, date, user, timestamp, source addresses, destination addresses, and other useful elements.			

2 Storage

2.1 Cloud Object Storage

IBM® Cloud Object Storage stores encrypted and dispersed data across multiple geographic locations. Information stored with IBM® Cloud Object Storage is encrypted and dispersed across multiple geographic locations, and accessed over popular protocols like HTTPS using a modern RESTful API.

2.1.1 Cloud Object Storage Encryption

Objects stored in IBM Cloud Object Storage need to be encrypted at all times for client data security. By default all objects stored in IBM Cloud Object Storage are encrypted at-rest using provider-managed keys and no user action is needed. Optionally, you can also leverage IBM Cloud Object Storage integration with IBM Cloud Key Management Services to further add another layer of encryption to the Data Encryption Keys (DEKs) associated with the data (objects) stored in Cloud Object Storage buckets.

2.1.1.1 Ensure Cloud Object Storage encryption is done with customer managed keys (Manual)

Profile Applicability:

- Level 2

Description:

Users can store objects in IBM Cloud Object Storage buckets by providing their own encryption keys which get applied at a per object level.

Rationale:

Users can have added security and granular control over the encryption keys at a per object level.

Impact:

Users can configure Cloud Object Storage and use their own root keys when uploading objects. For any key rotation (or new key usage) users will have to issue a [GET operation](#) with the old key and a [PUT operation](#) with the new key.

Audit:

Using API/CLI:

Use of Server-Side Encryption with Customer-Provided Keys (SSE-C) can be validated by the following steps:

Note: Ensure that you have completed the configuration setup to use the CLI by following the guidelines on the [Using the AWS CLI](#) page

1. Review the metadata of the object that is encrypted using the customer-provided key. The operation can be performed using an API call or via a command-line interface. Here is an example call to get the object metadata:

```
aws --endpoint https://s3.private.au-syd.cloud-object-storage.appdomain.cloud
s3api head-object --bucket <bucket-name> --key <object-name> --sse-customer-
algorithm=AES256 --sse-customer-key=<customer-key-used-to encrypt-the-object>
```

1. The presence of the object headers **SSECustomerKeyMD5** and **SSECustomerAlgorithm** from the API/CLI response should confirm that the object is encrypted using the key.

Remediation:

Using API/CLI:

Objects can be uploaded with your own key by using a [PUT](#) object request with key specific headers.

Please refer to [Server-Side Encryption with Customer-Provided Keys](#) for additional information.

Default Value:

By default, all objects stored in IBM Cloud Object Storage are encrypted by using randomly generated keys and an all-or-nothing-transform (AONT) also known as provider managed keys. Clients can provide their own encryption keys for a per-object level encryption by using the IBM Cloud Object Storage Server-Side Encryption with Customer-Provided Keys (SSE-C) option.

References:

1. <https://cloud.ibm.com/docs/cloud-object-storage?topic=cloud-object-storage-encryption>
2. <https://cloud.ibm.com/docs/cloud-object-storage?topic=cloud-object-storage-sse-c>

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.11 Encrypt Sensitive Data at Rest Encrypt sensitive data at rest on servers, applications, and databases containing sensitive data. Storage-layer encryption, also known as server-side encryption, meets the minimum requirement of this Safeguard. Additional encryption methods may include application-layer encryption, also known as client-side encryption, where access to the data storage device(s) does not permit access to the plain-text data.			
v7	14.8 Encrypt Sensitive Information at Rest Encrypt all sensitive information at rest using a tool that requires a secondary authentication mechanism not integrated into the operating system, in order to access the information.			

2.1.1.2 Ensure Cloud Object Storage Encryption is set to On with BYOK (Manual)

Profile Applicability:

- Level 2

Description:

You can use IBM Cloud encryption key management service, for example Key Protect, to bring your own root key (BYOK) to IBM Cloud and use it to add envelope encryption for data that is stored in IBM Cloud Object Storage buckets.

Rationale:

When it comes to encryption of data at rest in IBM Cloud, the best practice is to allow customers to manage customer root keys (CRK) that are used to protect customer data stored in data and storage services in IBM Cloud. Bring your Own Key (BYOK) allows customers to ensure no one outside of their organization has access to the root key and with the support of BYOK, customers can manage the lifecycle of their customer root keys where they can create, rotate, delete those keys. This provides a significant level of control where those CRKs are managed by the customer, which in turn increases both security control as well as meet relevant compliance requirements. These CRKs can be used in turn to protect the data encryption keys used to encrypt the data.

Impact:

For Bring your Own Key (BYOK) encryption with Cloud Object Storage integration and Key Protect key management service you will need to review and understand how you can leverage the integration to handle key lifecycle events (for example key rotation, deletion, restore). Refer to the Cloud Object Storage integration with Key Protect section to learn about [key lifecycle management](#) and Key Protect [product page](#) to find out more about the key lifecycle events.

Audit:

You can use the IBM Cloud Object Storage bucket configuration properties to verify whether a Cloud Object Storage bucket is enabled to use Key Protect.

Using Console:

Navigate to your Cloud Object Storage instance:

1. Log in to IBM Cloud at <https://cloud.ibm.com>
2. Click the Menu icon and select **Resource List**
3. On the **Resource List** page under **Storage**, select the Cloud Object Storage instance that you have provisioned.
4. Click on the appropriate bucket that you would like to check

5. Click on **Configuration** and scroll down to **Associated key management service** to check/confirm if a Key Protect key management service is associated

Remediation:

You will not be able to add Key Protect as the key management service once data is already written to a Cloud Object Storage bucket. In order to ensure that objects are encrypted using Key Protect root keys you will need to create a new Cloud Object Storage bucket, set it to use Key Protect key management service and then upload/copy the existing objects to this new bucket.

Default Value:

By default, use of Key Protect encryption key management service with IBM Cloud Object Storage buckets is not enabled.

References:

1. • Data encryption with IBM Cloud Object Storage:
<https://cloud.ibm.com/docs/cloud-object-storage?topic=cloud-object-storage-encryption>
2. • Integrated service availability page: <https://cloud.ibm.com/docs/services/cloud-object-storage/basics?topic=cloud-object-storage-service-availability>
3. • <https://cloud.ibm.com/docs/services/cloud-object-storage/basics?topic=cloud-object-storage-compatibility-api-bucket-operations#compatibility-api-key-protect>

Additional Information:

Creating a Cloud Object Storage bucket with Key Protect (Bring Your Own Key):

1. From your Cloud Object Storage instance page, create a new Cloud Object Storage bucket by clicking **Create bucket**.
2. To create the bucket, in the **Create bucket** section, select **Custom bucket**.
3. In the bucket configuration section, you can select the option to use **Key Protect** under **Key management services**

Note: In order to configure a Cloud Object Storage bucket to use Key Protect key management service you will need an instance of Key Protect along with appropriate access authorization to your Cloud Object Storage instance.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.11 <u>Encrypt Sensitive Data at Rest</u> Encrypt sensitive data at rest on servers, applications, and databases containing sensitive data. Storage-layer encryption, also known as server-side encryption, meets the minimum requirement of this Safeguard. Additional encryption methods may include application-layer encryption, also known as client-side encryption, where access to the data storage device(s) does not permit access to the plain-text data.			
v7	14.8 <u>Encrypt Sensitive Information at Rest</u> Encrypt all sensitive information at rest using a tool that requires a secondary authentication mechanism not integrated into the operating system, in order to access the information.			

2.1.1.3 Ensure Cloud Object Storage Encryption is set to On with KYOK (Manual)

Profile Applicability:

- Level 2

Description:

You can use IBM Cloud encryption key management services, for example, Hyper Protect Crypto Services to keep and manage exclusive control over the root keys used to add envelop encryption for data that is stored in IBM Cloud Object Storage buckets.

Rationale:

When it comes to encryption of data at rest in IBM Cloud, the best practice is to allow customers use encryption capabilities offered by Hardware Security Module crypto service. IBM Cloud Hyper Protect Crypto Services offers Keep your Own Key (KYOK) capabilities that allow customers to have exclusive key control over encryption keys. This provides a significant level of control over encryption keys where only authorized users have access (no privileged users included IBM Cloud Admins) to encryption keys, in turn increases both security control as well as meet relevant compliance requirements.

Impact:

For Keep your Own Key (KYOK) encryption using IBM Cloud Hyper Protect Crypto Services key management service you will need to review and understand how key lifecycle events (for example key rotation) need to be handled. Refer to the Hyper Protect Crypto Services [product page](#) for details around the key lifecycle events supported.

Audit:

You can use the IBM Cloud Object Storage bucket configuration properties to verify whether a Cloud Object Storage bucket is configured to use Hyper Protect Crypto Services key management service.

Using Console:

Navigate to your Cloud Object Storage instance:

1. Log in to IBM Cloud at <https://cloud.ibm.com>
2. Click the Menu icon and select **Resource List**
3. On the **Resource List** page under **Storage**, select the Cloud Object Storage instance that you have provisioned.
4. Click on the appropriate bucket that you would like to check

5. Click on **Configuration** and scroll down to **Associated key management service** to check/confirm if Hyper Protect Crypto Services key is configured with the bucket

Remediation:

You will not be able to add Hyper Protect Crypto Services as the key management service once data is already written to a Cloud Object Storage bucket. In order to ensure that objects are encrypted using Hyper Protect Crypto Services root keys you will need to create a new Cloud Object Storage bucket, set it to use Hyper Protect Crypto Services key management service and then upload/copy the existing objects to this new bucket.

Default Value:

By default, use of Hyper Protect Crypto Services key management service with IBM Cloud Object Storage buckets is not enabled.

References:

1. • Data encryption with IBM Cloud Object Storage:
<https://cloud.ibm.com/docs/cloud-object-storage?topic=cloud-object-storage-encryption>
2. • Integrated service availability page: <https://cloud.ibm.com/docs/services/cloud-object-storage/basics?topic=cloud-object-storage-service-availability>

Additional Information:

Create a Cloud Object Storage bucket with Hyper Protect Crypto Services (Keep Your Own Key):

1. From your Cloud Object Storage instance page, create a new Cloud Object Storage bucket by clicking **Create bucket**.
2. To create the bucket, in the **Create bucket** section, select **Custom bucket**.
3. In the bucket configuration section, you can select the option to use **Hyper Protect Crypto Services** under **Key management services**

Note: In order to configure a Cloud Object Storage bucket to use Hyper Protect Crypto Services you will need an instance of Hyper Protect Crypto Services along with appropriate access authorization to your Cloud Object Storage instance.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.11 <u>Encrypt Sensitive Data at Rest</u> Encrypt sensitive data at rest on servers, applications, and databases containing sensitive data. Storage-layer encryption, also known as server-side encryption, meets the minimum requirement of this Safeguard. Additional encryption methods may include application-layer encryption, also known as client-side encryption, where access to the data storage device(s) does not permit access to the plain-text data.			
v7	14.8 <u>Encrypt Sensitive Information at Rest</u> Encrypt all sensitive information at rest using a tool that requires a secondary authentication mechanism not integrated into the operating system, in order to access the information.			

2.1.2 Ensure network access for Cloud Object Storage is restricted to specific IP range (Manual)

Profile Applicability:

- Level 2

Description:

IBM Cloud Object Storage bucket level context-based restriction rules allow users to restricts all access to data unless the request originates from a list of allowed IP addresses. Context-based restrictions are recommended over legacy bucket Firewalls for restricting IP addresses that can be used to access buckets.

Rationale:

Restrict access to the data stored in Cloud Object Storage buckets and enhance security controls by creating a context-based restriction that will only allow data to be accessed from specific IP addresses.

Impact:

For any application(s) that depends upon or accesses data stored in Cloud Object Storage buckets to conduct its operation(s), administrators should ensure that the network used to access Cloud Object Storage buckets is trusted. This can be achieved through Cloud Object Storage context-based restriction rules. Allowing all network addresses to access Cloud Object Storage buckets could result unnecessary data exposure.

Audit:

To verify that an IBM Cloud Object Storage bucket is accessible only from authorized IP addresses, administrators can navigate to **Permissions** tab available under your bucket information and check the **Context-base restrictions** rule set.

Using Console

1. Navigate to IBM Cloud Console: <https://cloud.ibm.com/resources>.
2. Under **Storage** click on the Cloud Object Storage instance to verify (*users will be directed to a default bucket listing page*)
3. Click on the Cloud Object Storage bucket name to review the bucket information.
4. At the bucket information screen, click on the **Permissions** tab in bucket description on the right navigation pane.
5. Within **Bucket access policies** you will see a list of policies that can be used to control access to the bucket, choose **Context-based restrictions**
6. If no **Context-based restriction** exists, one can be created using the **Create rule** button following directions in the public documentation here:

<https://cloud.ibm.com/docs/account?topic=account-context-restrictions-create&interface=ui>.

7. If Context-based restrictions exist, users can view the rules by following the **Manage context-based restrictions** link in the interface.
8. Review the rules to ensure they includes the IPs you want authorized.

Remediation:

Follow the steps outlined to add an IP to the list of Authorized IPs in context restriction rules.

Using Console

From the IBM Cloud [console dashboard](#), you can restrict access to your content by setting a context-based restriction.

Set a list of authorized IP addresses

1. Start by selecting **Storage** to view your resource list.
2. Next, select the service instance with the target bucket from within the **Storage** menu. The Object Storage Console will be displayed.
3. Select the bucket to navigate to the bucket details interface.
4. Select **Permissions** from the navigation menu.
5. Select the **Context-based restrictions** tab.
6. Click on **Create rule** and follow the instructions here:
<https://cloud.ibm.com/docs/account?topic=account-context-restrictions-create&interface=ui>

Note that all objects in this bucket are only accessible from those IP addresses.

Default Value:

By default Cloud Object Storage buckets can only be accessed by authenticated users.

References:

1. <https://cloud.ibm.com/docs/cloud-object-storage?topic=cloud-object-storage-setting-a-firewall>
2. <https://cloud.ibm.com/docs/cloud-object-storage?topic=cloud-object-storage-setting-a-firewall#firewall-api>

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.10 <u>Encrypt Sensitive Data in Transit</u> Encrypt sensitive data in transit. Example implementations can include: Transport Layer Security (TLS) and Open Secure Shell (OpenSSH).			
v7	14.4 <u>Encrypt All Sensitive Information in Transit</u> Encrypt all sensitive information in transit.			

2.1.3 Ensure network access for Cloud Object Storage is set to be exposed only on Private end-points (Manual)

Profile Applicability:

- Level 1

Description:

IBM Cloud Object Storage bucket context-based restrictions allows administrators to restricts all access to data unless the request originates from a list of allowed IP addresses that are part of the private subnets only.

Rationale:

Restrict access to data stored in Cloud Object Storage buckets and enhance security controls by creating a context-based restriction rule that will only allow data access to the list of IP addresses that are part of your private subnet.

Impact:

Ensuring network access is accessible via private subnets requires that you update the settings in Cloud Object Storage bucket configuration by following additional steps outlined in the remediation section.

Audit:

To check or confirm that an IBM Cloud Object Storage bucket is accessible only from a list of authorized IP addresses from private subnets, you can navigate to **Access policies** section available under your bucket information and check **Authorized IPs** list.

Using Console:

1. Go to IBM Cloud Console: <https://cloud.ibm.com/resources>
2. Under **Storage** click on the Cloud Object Storage instance you want to check.
(you will be directed to a default bucket listing page)
3. Click on the Cloud Object Storage bucket for which you want to review the bucket policy/context-based restriction information
4. At the bucket information screen, click on the **Permissions** section on the right navigation in the bucket description.
5. Within Bucket access policies one can view the tab **Context-based restrictions**
6. Review the list of rules to ensure one includes the IPs/subnets you want authorized, for example, **10.0.0.0/8** would authorize all the private IP addresses that are part of the IBM Cloud Infrastructure to access the bucket.

Remediation:

Follow the steps outlined to add an IP/subnet to the list of Authorized IPs in bucket context-based restriction policies.

Using Console:

From the IBM Cloud [console dashboard](#), you can restrict access to your content by setting a Context-based Restriction.

Set a list of authorized IP addresses

1. Start by selecting **Storage** to view your resource list.
2. Next, select the service instance with the target bucket from within the **Storage** menu. The Object Storage Console will be displayed.
3. Select the bucket to navigate to the bucket details interface.
4. Select **Permissions** from the navigation menu.
5. Select the **Context-based restrictions** tab.
6. Click on **Create rule** and follow the instructions here:
<https://cloud.ibm.com/docs/account?topic=account-context-restrictions-create&interface=ui>

Note that all objects in this bucket are only accessible from those IP addresses.

Default Value:

By default, Cloud Object Storage buckets can only be accessed by authenticated users.

References:

1. <https://cloud.ibm.com/docs/cloud-object-storage?topic=cloud-object-storage-setting-a-firewall>
2. <https://cloud.ibm.com/docs/cloud-object-storage?topic=cloud-object-storage-setting-a-firewall#firewall-api>

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.3 <u>Configure Data Access Control Lists</u> Configure data access control lists based on a user's need to know. Apply data access control lists, also known as access permissions, to local and remote file systems, databases, and applications.			

Controls Version	Control	IG 1	IG 2	IG 3
v7	14.6 <u>Protect Information through Access Control Lists</u> Protect all information stored on systems with file system, network share, claims, application, or database specific access control lists. These controls will enforce the principle that only authorized individuals should have access to the information based on their need to access the information as a part of their responsibilities.			

2.1.4 Ensure Cloud Object Storage bucket access is restricted by using IAM and S3 access control (Manual)

Profile Applicability:

- Level 1

Description:

Access controls on the Cloud Object Storage buckets are governed via IBM Identity and Access Management (IAM). However, some permissions can also be granted (or restricted) via S3 access controls.

Rationale:

Assign IAM access roles for users and Service IDs against buckets, by using either the UI or the CLI to create policies. The S3 Access Control is performed using ACLs granted against buckets and objects.

Impact:

Organizations can use Cloud Object Storage to store sensitive data that may need to be restricted. Therefore, creation of a new Cloud Object Storage bucket requires careful review and planning around access controls provided by IBM Cloud environment to ensure data access can be restricted to only those having valid business need.

Audit:

Using Console:

Complete the following steps to review your assigned access in an account that you have been added to:

1. In the console, click **Manage, Access (IAM)**, and select **Users** or **Manage, Access (IAM)**, and select **Service IDs**, depending on which identity you want to review.
2. Select your name or the service ID.
3. Review the assigned access in the **Access policies** section.

Using CLI:

Reviewing S3 ACLs to buckets

View the S3 ACLs via API or CLI. A typical API call is shown:

```
curl -X "GET" "https://{endpoint}/{bucket-name}?acl" \  
-H "Authorization: Bearer {token}" \  

```

Remediation:

Granting Access to a COS Bucket using IAM

Using Console:

To create a new bucket-level policy:

1. Navigate to the **Access IAM** console from the Manage menu.
2. Select **Users** from the left navigation menu.
3. Select a user.
4. Select the **Access Policies** tab to view the user's existing policies, assign a new policy, or edit an existing policy.
5. Click **Assign access** to create a new policy.
6. Choose **Assign access to resources**.
7. First, select **Cloud Object Storage** from the services menu.
8. Then, select the appropriate service instance. Enter **bucket**

in the **Resource type** field and the bucket name in the **Resource ID** field.

9. Select the wanted service access role. Selecting the lozenge with the number of actions show the actions available to the role.
10. Click **Assign**

Using CLI:

From a terminal run the following command:

```
ibmcloud iam user-policy-create <user-name> \  
  --roles <role> \  
  --service-name cloud-object-storage \  
  --service-instance <resource-instance-id> \  
  --resource-type bucket \  
  --resource <bucket-name>
```

To list existing policies:

```
ibmcloud iam user-policies <user-name>
```

To edit an existing policy:

```
ibmcloud iam user-policy-update <user-name> <policy-id> \  
  --roles <role> \  
  --service-name cloud-object-storage \  
  --service-instance <resource-instance-id> \  
  --resource-type bucket \  
  --resource <bucket-name>
```

The same set of accesses can be assigned to a service id as well. Please follow the procedure documented in <https://cloud.ibm.com/docs/cloud-object-storage?topic=cloud-object-storage-iam-bucket-permissions#iam-service-id>

Granting S3 ACLs to buckets

Grant the S3 ACLs via API or CLI. A Typical API call is shown:

```
curl -X "PUT" "https://{endpoint}/{bucket-name}?acl" \
-H "Authorization: Bearer {token}" \
-H "x-amz-acl: <scope>"
```

Default Value:

By default, users or service ids which have Cloud Object Storage service role access to the Cloud Object Storage service instances will have access to the Cloud Object Storage buckets under them as well.

References:

1. <https://cloud.ibm.com/docs/cloud-object-storage?topic=cloud-object-storage-iam-bucket-permissions>
2. <https://cloud.ibm.com/docs/account?topic=account-assign-access-resources>
3. <https://cloud.ibm.com/docs/cloud-object-storage?topic=cloud-object-storage-iam-public-access#public-access-object>

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.3 <u>Configure Data Access Control Lists</u> Configure data access control lists based on a user's need to know. Apply data access control lists, also known as access permissions, to local and remote file systems, databases, and applications.			

2.1.5 Ensure Public (anonymous) Access to IBM Cloud Object Storage buckets is Disabled (Manual)

Profile Applicability:

- Level 1

Description:

You can disable public (anonymous) access to IBM Cloud Object Storage buckets.

Rationale:

Buckets might have to hold open data sets for academic, research, or image repositories that are used by web applications and content delivery networks. You can make these buckets publicly accessible by using the **Public Access** group. But when buckets contain non-public data (e.g., restricted, internal, confidential or sensitive data), it is important to have public access disabled. To disable the public access, a previously defined access policy must be removed.

By default, public access to Cloud Object Storage buckets is disabled. If an access policy is defined that allows public access, you can disable the policy by using the console.

Audit:

To check if an access policy exists for a Cloud Object Storage bucket, you can list the access policies for the **Public Access** group.

Using Console:

1. Log in to IBM Cloud at <https://cloud.ibm.com>.
2. From the Menu bar, click **Manage, Access (IAM)**.
3. Click **Access groups**.
4. Select **Public Access**
5. Check the list of access policies to see if one exists for the relevant Cloud Object Storage bucket.

Remediation:

To disable public access for buckets, complete the following steps:

Using Console:

1. Log in to IBM Cloud at <https://cloud.ibm.com>.
2. From the Menu bar, click **Manage, Access (IAM)**.
3. Click **Access groups**.
4. Click **Public Access** to see a list of all public access policies currently in use.

5. Find the policy that corresponds to the bucket that you want to return to enforced access control.
6. From the list of actions, select **Remove**.
7. Confirm that you want to remove the policy.

Default Value:

By default, public access to Cloud Object Storage buckets is disabled.

References:

1. Information around Enabling and Disabling Public access to the COS bucket is available from the product page: <https://cloud.ibm.com/docs/services/cloud-object-storage/basics?topic=cloud-object-storage-iam-public-access#iam-public-access-console>

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.3 <u>Configure Data Access Control Lists</u> Configure data access control lists based on a user's need to know. Apply data access control lists, also known as access permissions, to local and remote file systems, databases, and applications.			
v7	14.6 <u>Protect Information through Access Control Lists</u> Protect all information stored on systems with file system, network share, claims, application, or database specific access control lists. These controls will enforce the principle that only authorized individuals should have access to the information based on their need to access the information as a part of their responsibilities.			

2.2 Block and File Storage

IBM Cloud® Block Storage for Virtual Private Cloud is persistent, high-performance storage that is provisioned and managed independently of compute instances. Block Storage for VPC provides primary boot volumes and secondary data volumes. Boot volumes are automatically created and attached during instance provisioning. Data volumes can be created and attached during instance provisioning, or as stand-alone volumes that you can later attach to an instance. Block Storage brings best-in-class levels of durability and availability with an unmatched feature set. It is built by using industry standards and best practices. Block Storage is designed to protect the integrity of the data and maintain availability through maintenance events and unplanned failures, and provide a consistent performance baseline.

IBM Cloud® File Storage for VPC provides NFS-based file storage services within the VPC Infrastructure. With File Storage you can create zonal file shares in any availability zone within a region. Although File shares are created within a specific availability zone they are mountable from any zone within the region. File shares are shared resources and can be mounted by multiple clients at the same time across one or more VPCs. You can view and manage your regional file shares in the console, from the CLI, and with the API. You can increase the file share size from its original capacity in GB increments up to 32,000 GB capacity. You can also adjust your file share bandwidth to meet your performance needs.

2.2.1 Cloud Block Storage Encryption

Data stored in IBM® Cloud Block Storage for Virtual Private Cloud needs to be encrypted at all times for client data security. By default all data stored within the Block Storage service is encrypted at-rest. Below are the options available for customers to encrypt data at rest:

1. Use provider-managed keys for Encryption
2. Use IBM Cloud KeyProtect Service for managing encryption keys or
3. Use IBM Cloud hardware HSM supported Hyper Protect Service for managing encryption keys

2.2.1.1 Ensure IBM Cloud® Block Storage for Virtual Private Cloud is encrypted with BYOK (Manual)

Profile Applicability:

- Level 2

Description:

By default, IBM Cloud® Block Storage for Virtual Private Cloud provides provider-managed encryption for all data. For enhanced security, customers can bring their own encryption keys and manage them through IBM Key Management Service – Key Protect. The customer can choose to use BYOK instead of provider-managed keys for enhanced security.

Rationale:

When it comes to encryption of data at rest in IBM Cloud, the best practice is to allow customers to manage customer root keys(CRK) that are used to protect customer data stored in data and storage services in IBM Cloud. Bring your Own Key(BYOK) allows customers to ensure no one outside of their organization has access to the root key and with the support of BYOK, customers can manage the lifecycle of their customer root keys where they can create, rotate, delete those keys. This provides a significant level of control where those CRKs are managed by the customer, which in turn increases both security control as well as meet relevant compliance requirements. These CRKs can be used in turn to protect the data encryption keys used to encrypt the data.

Impact:

With BYOK managed encryption, the customer manages their own encryption keys through IBM Key Management Service – Key Protect. This may create additional administrative overhead.

Audit:

You can use the IBM® Cloud Block Storage for Virtual Private Cloud configuration properties to verify whether a block volume is enabled to use Key Protect. From Console, Navigate to your block volume resource:

1. In the IBM Cloud console, go to the Menu icon, **VPC Infrastructure, Storage, Block storage volumes**. A list of all block storage volumes displays.
2. For each of the volumes listed, ensure the encryption field specifies **Key Protect**.

Remediation:

You will not be able to add Key Protect as the key management service once data is already written to a Cloud Block Storage Volume. In order to ensure that the data is encrypted using Key Protect keys you will need to create a new Cloud Block Storage volume, set it to use Key Protect key management service and then upload/copy the existing data to this new volume.

Default Value:

Provider Managed

References:

1. <https://cloud.ibm.com/docs/vpc?topic=vpc-block-storage-vpc-encryption&interface=ui>

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.11 <u>Encrypt Sensitive Data at Rest</u> Encrypt sensitive data at rest on servers, applications, and databases containing sensitive data. Storage-layer encryption, also known as server-side encryption, meets the minimum requirement of this Safeguard. Additional encryption methods may include application-layer encryption, also known as client-side encryption, where access to the data storage device(s) does not permit access to the plain-text data.			
v7	14.8 <u>Encrypt Sensitive Information at Rest</u> Encrypt all sensitive information at rest using a tool that requires a secondary authentication mechanism not integrated into the operating system, in order to access the information.			

2.2.1.2 Ensure IBM Cloud® Block Storage for Virtual Private Cloud is encrypted with KYOK (Manual)

Profile Applicability:

- Level 2

Description:

By default, IBM Cloud® Block Storage for Virtual Private Cloud provides provider-managed encryption for all data. For enhanced security, customers can bring their own encryption keys and manage them through IBM Key Management Service – Hyper Protect Crypto Services (HPCS). The customer can choose to use KYOK instead of provider-managed keys for enhanced security.

Rationale:

When it comes to encryption of data at rest in IBM Cloud, the best practice is to allow customers use encryption capabilities offered by Hardware Security Module crypto service. IBM Cloud Hyper protect Crypto Service (HPCS) offers Keep your Own Key (KYOK) capabilities that allow customers to have exclusive key control over encryption keys. This provides a significant level of control over encryption keys where only authorized users have access (no privileged users included IBM Cloud Admins) to encryption keys, in turn increases both security control as well as meet relevant compliance requirements.

Impact:

With KYOK managed encryption, the customer manages their own encryption keys through IBM Key Management Service - HPCS.

Audit:

You can use the IBM® Cloud Block Storage for Virtual Private Cloud configuration properties to verify whether a block volume is enabled to use Hyper Protect Crypto Service. From Console, Navigate to your block volume resource:

1. In the IBM Cloud console, go to the Menu icon, **VPC Infrastructure, Storage, Block storage volumes**. A list of all block storage volumes displays.
2. For each of the volumes listed, ensure the encryption field specifies **Hyper Protect**.

Remediation:

You will not be able to add Hyper Protect Crypto Services as the key management service once data is already written to a Cloud Block Storage Volumes. In order to ensure that data is encrypted using Hyper Protect Crypto Services you will need to create a new Cloud Block Storage volume, set it to use Hyper Protect Crypto Services key management service and then upload/copy the existing data to this new volume.

Default Value:

Provider managed

References:

1. <https://cloud.ibm.com/docs/vpc?topic=vpc-block-storage-vpc-encryption&interface=ui>

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.11 <u>Encrypt Sensitive Data at Rest</u> Encrypt sensitive data at rest on servers, applications, and databases containing sensitive data. Storage-layer encryption, also known as server-side encryption, meets the minimum requirement of this Safeguard. Additional encryption methods may include application-layer encryption, also known as client-side encryption, where access to the data storage device(s) does not permit access to the plain-text data.			
v7	14.8 <u>Encrypt Sensitive Information at Rest</u> Encrypt all sensitive information at rest using a tool that requires a secondary authentication mechanism not integrated into the operating system, in order to access the information.			

2.2.2 Cloud File Storage Encryption

Data stored in IBM® Cloud File Storage for Virtual Private Cloud needs to be encrypted at all times for client data security. Data on a regional file share is encrypted at rest with IBM-managed encryption by default. For added security, you can use your own root keys to protect your file shares with customer-managed keys. Below are the options available for customers to encrypt data at rest:

Use IBM provider-managed keys for Encryption Use IBM Cloud KeyProtect Service for managing encryption keys or Use IBM Cloud hardware HSM supported Hyper Protect Service for managing encryption keys

2.2.2.1 Ensure IBM Cloud® File Storage for Virtual Private Cloud is encrypted with provider managed keys (Manual)

Profile Applicability:

- Level 1

Description:

By default, IBM Cloud® File Storage for Virtual Private Cloud provides provider-managed encryption for all data. For enhanced security, customers can bring their own encryption keys and manage them through IBM Key Management Services – Key Protect or Hyper Protect Crypto Services (HPCS).

Rationale:

With provider-managed keys, the file service manages encryption at rest by default with no additional configuration needed by the customer.

With provider managed encryption, the service manages the root encryption keys on behalf of the customer.

Audit:

You can use the IBM® Cloud File Storage for Virtual Private Cloud configuration properties to verify whether a file share is enabled with provider managed encryption. From the IBM Cloud Console, Navigate to your file share resource:

1. In the IBM Cloud console, go to Menu icon, **VPC Infrastructure, Storage, File Storage Shares**. A list of all file shares is displays.
2. For each of the shares listed, ensure the encryption field specifies **Provider Managed**.

Remediation:

You will not be able to change the encryption option once data is already written to a File Share. In order to change your encryption setting you will need to create a new File Share, set it to use your desired encryption setting and then upload/copy the existing data to this new share.

Default Value:

Provider managed

References:

1. <https://cloud.ibm.com/docs/vpc?topic=vpc-block-storage-about&interface=ui>

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.11 <u>Encrypt Sensitive Data at Rest</u> Encrypt sensitive data at rest on servers, applications, and databases containing sensitive data. Storage-layer encryption, also known as server-side encryption, meets the minimum requirement of this Safeguard. Additional encryption methods may include application-layer encryption, also known as client-side encryption, where access to the data storage device(s) does not permit access to the plain-text data.			
v7	14.8 <u>Encrypt Sensitive Information at Rest</u> Encrypt all sensitive information at rest using a tool that requires a secondary authentication mechanism not integrated into the operating system, in order to access the information.			

2.2.2.2 Ensure IBM Cloud® File Storage for Virtual Private Cloud is encrypted with BYOK (Manual)

Profile Applicability:

- Level 2

Description:

By default, IBM® Cloud File Storage for Virtual Private Cloud provides provider-managed encryption for all data. For enhanced security, customers can bring their own encryption keys and manage them through IBM Key Management Service – Key Protect. The customer can choose to use BYOK instead of provider-managed keys for enhanced security.

Rationale:

When it comes to encryption of data at rest in IBM Cloud, the best practice is to allow customers to manage customer root keys(CRK) that are used to protect customer data stored in data and storage services in IBM Cloud. Bring your Own Key(BYOK) allows customers to ensure no one outside of their organization has access to the root key and with the support of BYOK, customers can manage the lifecycle of their customer root keys where they can create, rotate, delete those keys. This provides a significant level of control where those CRKs are managed by the customer, which in turn increases both security control as well as meet relevant compliance requirements. These CRKs can be used in turn to protect the data encryption keys used to encrypt the data.

Impact:

With BYOK managed encryption, the customer manages their own encryption keys through IBM Key Management Service – Key Protect. This may create additional administrative overhead.

Audit:

You can use the IBM® Cloud File Storage for Virtual Private Cloud configuration properties to verify whether a file share is enabled to use Key Protect.

From Console, Navigate to your file share resource:

1. In the IBM Cloud console, go to Menu icon, **VPC Infrastructure, Storage, File storage shares**. A list of all file shares displays.
2. For each of the shares listed, ensure the encryption field specifies **Key Protect**.

Remediation:

You will not be able to add Key Protect as the key management service once data is already written to a File Share. In order to ensure that the data is encrypted using Key Protect keys you will need to create a new File Share, set it to use Key Protect key management service and then upload/copy the existing data to this new volume.

Default Value:

Provider managed

References:

1. <https://cloud.ibm.com/docs/vpc?topic=vpc-block-storage-about&interface=ui>

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.11 <u>Encrypt Sensitive Data at Rest</u> Encrypt sensitive data at rest on servers, applications, and databases containing sensitive data. Storage-layer encryption, also known as server-side encryption, meets the minimum requirement of this Safeguard. Additional encryption methods may include application-layer encryption, also known as client-side encryption, where access to the data storage device(s) does not permit access to the plain-text data.			
v7	14.8 <u>Encrypt Sensitive Information at Rest</u> Encrypt all sensitive information at rest using a tool that requires a secondary authentication mechanism not integrated into the operating system, in order to access the information.			

2.2.2.3 Ensure IBM Cloud® File Storage for Virtual Private Cloud is encrypted with KYOK (Manual)

Profile Applicability:

- Level 2

Description:

By default, IBM Cloud® File Storage for Virtual Private Cloud provides provider-managed encryption for all data. For enhanced security, customers can bring their own encryption keys and manage them through IBM Key Management Service – Hyper Protect Crypto Services (HPCS). The customer can choose to use KYOK instead of provider-managed keys for enhanced security.

Rationale:

When it comes to encryption of data at rest in IBM Cloud, the best practice is to use encryption capabilities offered by Hardware Security Module crypto service. IBM Cloud Hyper protect Crypto Service (HPCS) offers Keep your Own Key (KYOK) capabilities that allow customers to have exclusive key control over encryption keys. This provides a significant level of control over encryption keys where only authorized users have access (no privileged users included IBM Cloud Admins) to encryption keys, in turn increases both security control as well as meet relevant compliance requirements.

Impact:

With KYOK managed encryption, the customer manages their own encryption keys through IBM Key Management Service - HPCS. This may create additional administrative overhead.

Audit:

You can use the IBM® Cloud File Storage for Virtual Private Cloud configuration properties to verify whether a file share is enabled to use Hyper Protect Crypto Service.

From Console, Navigate to your file share resource:

1. In the IBM Cloud console, go to Menu icon, **VPC Infrastructure, Storage, file storage shares**. A list of all file shares is displays.
2. For each of the share listed, ensure the encryption field specifies **Hyper Protect**.

Remediation:

You will not be able to add Hyper Protect Crypto Services as the key management service once data is already written to a file share. In order to ensure that data is encrypted using Hyper Protect Crypto Services you will need to create a new file share, set it to use Hyper Protect Crypto Services key management service and then upload/copy the existing data to this new volume.

Default Value:

Provider managed

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.11 <u>Encrypt Sensitive Data at Rest</u> Encrypt sensitive data at rest on servers, applications, and databases containing sensitive data. Storage-layer encryption, also known as server-side encryption, meets the minimum requirement of this Safeguard. Additional encryption methods may include application-layer encryption, also known as client-side encryption, where access to the data storage device(s) does not permit access to the plain-text data.			
v7	14.8 <u>Encrypt Sensitive Information at Rest</u> Encrypt all sensitive information at rest using a tool that requires a secondary authentication mechanism not integrated into the operating system, in order to access the information.			

2.2.3 Ensure boot volumes are encrypted with Customer managed keys (Manual)

Profile Applicability:

- Level 2

Description:

By default, IBM Cloud® Block Storage for Virtual Private Cloud provides provider-managed encryption for all data. For enhanced security, customers can bring their own encryption keys and manage them through IBM Key Management Services – Key Protect or Hyper Protect Crypto Services (HPCS).

Rationale:

With customer-managed keys, only customers can access and manage their master root keys, giving them full control over their data security.

Impact:

With BYOK or KYOK managed encryption, the customer manages their own encryption keys through either Key Protect or Hyper Protect Crypto Services.

Audit:

You can use the IBM® Cloud Block Storage for Virtual Private Cloud configuration properties to verify whether a block volume is enabled to use Key Protect or Hyper Protect key management services.

From Console, Navigate to your block volume resource:

1. In the IBM Cloud console, go to Menu icon, **VPC Infrastructure, Storage, Block storage volumes**. A list of all block storage volumes displays.
2. For each volumes listed with Attachment Type column value **Boot**, ensure the encryption field is **Not** pointing to **Provider Managed**.

Remediation:

You will not be able to change encryption option once data is already written to a Cloud Block Storage Volume. In order to ensure that data is encrypted using customer managed keys you will need to create a new Cloud Block Storage volume, set it to use either Key Protect or Hyper Protect key management service and then upload/copy the existing objects to this new volume.

Default Value:

Provider Managed

References:

1. <https://cloud.ibm.com/docs/vpc?topic=vpc-block-storage-vpc-encryption&interface=ui>

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.11 <u>Encrypt Sensitive Data at Rest</u> Encrypt sensitive data at rest on servers, applications, and databases containing sensitive data. Storage-layer encryption, also known as server-side encryption, meets the minimum requirement of this Safeguard. Additional encryption methods may include application-layer encryption, also known as client-side encryption, where access to the data storage device(s) does not permit access to the plain-text data.			
v7	14.8 <u>Encrypt Sensitive Information at Rest</u> Encrypt all sensitive information at rest using a tool that requires a secondary authentication mechanism not integrated into the operating system, in order to access the information.			

2.2.4 Ensure secondary volumes are encrypted with customer managed keys (Manual)

Profile Applicability:

- Level 2

Description:

By default, IBM Cloud® Block Storage for Virtual Private Cloud provides provider-managed encryption for all data. For enhanced security, customers can bring their own encryption keys and manage them through IBM Key Management Services – Key Protect or Hyper Protect Crypto Services (HPCS).

Rationale:

With customer-managed keys, only customers can access and manage their master root keys, giving them full control over their data security.

Impact:

With BYOK or KYOK managed encryption, the customer manages their own encryption keys through either Key Protect or Hyper Protect Crypto Services.

Audit:

You can use the IBM® Cloud Block Storage for Virtual Private Cloud configuration properties to verify whether a block volume is enabled to use Key Protect or Hyper Protect key management services.

From Console, Navigate to your block volume resource:

1. In the IBM Cloud console, go to Menu icon, **VPC Infrastructure, Storage, Block storage volumes**. A list of all block storage volumes will be displayed.
2. For each volumes listed with Attachment Type column value "Data", ensure the encryption field is **Not** pointing to "Provider Managed".

Remediation:

You will not be able to change encryption option once data is already written to a Cloud Block Storage Volume. In order to ensure that data is encrypted using customer managed keys you will need to create a new Cloud Block Storage volume, set it to use either Key Protect or Hyper Protect key management service and then upload/copy the existing data to this new volume.

Default Value:

Provider managed

References:

1. <https://cloud.ibm.com/docs/vpc?topic=vpc-block-storage-vpc-encryption&interface=ui>

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.11 <u>Encrypt Sensitive Data at Rest</u> Encrypt sensitive data at rest on servers, applications, and databases containing sensitive data. Storage-layer encryption, also known as server-side encryption, meets the minimum requirement of this Safeguard. Additional encryption methods may include application-layer encryption, also known as client-side encryption, where access to the data storage device(s) does not permit access to the plain-text data.			
v7	14.8 <u>Encrypt Sensitive Information at Rest</u> Encrypt all sensitive information at rest using a tool that requires a secondary authentication mechanism not integrated into the operating system, in order to access the information.			

2.2.5 Ensure unattached volumes are encrypted with customer managed keys (Manual)

Profile Applicability:

- Level 2

Description:

By default, IBM Cloud® Block Storage provides provider-managed encryption for all data. For enhanced security, customers can bring their own encryption keys and manage them through IBM Key Management Services – Key Protect or Hyper Protect Crypto Services (HPCS).

Rationale:

With customer-managed keys, only customers can access and manage their master root keys, giving them full control over their data security.

Impact:

With BYOK or KYOK managed encryption, the customer manages their own encryption keys through either Key Protect or Hyper Protect Crypto Services.

Audit:

You can use the IBM® Cloud Block Storage for Virtual Private Cloud configuration properties to verify whether a block volume is enabled to use Key Protect or Hyper Protect key management services.

From Console, Navigate to your Cloud Object Storage instance:

1. In the IBM Cloud console, go to Menu icon, **VPC Infrastructure, Storage, Block storage volumes**. A list of all block storage volumes will be displayed.
2. For each volumes listed without any value in the "Attachment Type" column, ensure the encryption field is **Not** pointing to "Provider Managed".

Remediation:

You will not be able to change encryption option once data is already written to a Cloud Block Storage Volume. In order to ensure that data is encrypted using customer managed keys you will need to create a new Cloud Block Storage volume, set it to use either Key Protect or Hyper Protect key management service and then upload/copy the existing data to this new volume.

Default Value:

Provider managed

References:

1. <https://cloud.ibm.com/docs/vpc?topic=vpc-block-storage-vpc-encryption&interface=ui>

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.11 <u>Encrypt Sensitive Data at Rest</u> Encrypt sensitive data at rest on servers, applications, and databases containing sensitive data. Storage-layer encryption, also known as server-side encryption, meets the minimum requirement of this Safeguard. Additional encryption methods may include application-layer encryption, also known as client-side encryption, where access to the data storage device(s) does not permit access to the plain-text data.			
v7	14.8 <u>Encrypt Sensitive Information at Rest</u> Encrypt all sensitive information at rest using a tool that requires a secondary authentication mechanism not integrated into the operating system, in order to access the information.			

3 Maintenance, Monitoring and Analysis of Audit Logs

Collect, manage, and analyze audit logs of events that could help detect, understand, or recover from an attack.

3.1 Ensure auditing is configured in the IBM Cloud account (Manual)

Profile Applicability:

- Level 1

Description:

Collect audit events from IBM Cloud resources so that you can monitor activity in your IBM Cloud account.

Rationale:

Use IBM Cloud® Activity Tracker Event Routing to configure how to route auditing events, both global and location-based event data, in your IBM Cloud. Auditing events are critical data for security operations and a key element for meeting compliance requirements. Control of the storage location is critical to building enterprise-grade solutions on the IBM Cloud.

You can use Activity Tracker Event Routing, a platform service, to manage auditing events at the account-level by configuring targets and routes that define where auditing data is routed. Activity Tracker Event Routing can route events that are generated in supported regions.

For example, you can use these audit events to investigate abnormal activity and critical actions, and comply with regulatory audit requirements. The audit events that are collected comply with the Cloud Auditing Data Federation (CADF) standard. Each audit event includes information about the initiator of the action, the action that is run, the target resource on which the action is requested, the observer, and the outcome of the action. For more information about the format, see Event fields.

Activity Tracker events are collected as two types of events for audit-enabled services in the IBM Cloud:

- Management events
- Data events

Data events access or modify customer data. Management events report on operational actions on IBM Cloud resources. Both types of events generate events for create, read, update, and delete (CRUD) actions.

For the highest set of log analysis and monitoring capabilities, use IBM Cloud® Activity Tracker Event Routing to route all audit events to IBM Cloud Logs.

Impact:

Failure to meet this recommendation limits your ability to monitor activity in your IBM Cloud account. It also restricts your ability to identify the initiator of actions in your account, the resources affected, and details about the request.

Audit:

To check that you are collecting audit events from IBM Cloud resources so that you can monitor activity in your IBM Cloud account, you can use the following check list to ensure that auditing is configured in an IBM Cloud account:

1. Ensure that routes and/or targets are defined for audit events in IBM Cloud® Activity Tracker Event Routing. Be sure to include Global events, as well as for each region that you operate within.
2. Use the **validate** function within IBM Cloud® Activity Tracker Event Routing, which ensures the configured route or target are working and are able to authenticate to the specified destination.

To check if routes and/or targets are defined for audit events in IBM Cloud® Activity Tracker Event Routing, complete the following steps:

Note: To complete these steps, your IBM Cloud user ID (IBMid) must have the following roles:

- A platform role with viewer role for the IBM Cloud® Activity Tracker Event Routing service for the account
- A service role with reader role for the IBM Cloud® Activity Tracker Event Routing service for the account
- Identity and Access Management (IAM) permissions to read and list targets and routes in the account, including the following IAM actions: `atracker.target.read`, `atracker.target.list`, `atracker.route.read`, `atracker.route.list`.

Using Console:

1. Log in to IBM Cloud at <https://cloud.ibm.com>.
2. Go to the Menu icon. Then, select **Observability** to access the **Observability** dashboard.
3. Select **Activity Tracker** from the page navigation menu
4. Select **Routing** from the page navigation menu
5. Select **Routes** from the page navigation menu
6. All configured Routes will be listed. Review to ensure the routes cover all locations, including global.
7. Select **Targets** from the page navigation menu
8. All configured Targets will be listed. Ensure the Target Status is **Active** for all targets. If the target status is **Error**, the target is misconfigured and events will not be routed to the destination.

Using CLI:

1. Log in to IBM Cloud. Run the following command:

```
ibmcloud login -a cloud.ibm.com
```

For a federated account, run the following command:

```
ibmcloud login -a cloud.ibm.com --sso
```

2. List all routes that are configured in your account. Run the following command:

```
ibmcloud atracker route ls
```

3. Get the details of each configured route found in the list from the previous command:

```
ibmcloud atracker route get --route ROUTE
```

where ROUTE is the name or ID of the route.

4. List all targets that are configured in your account. Run the following command:

```
ibmcloud atracker target ls
```

5. Get the details of each configured target found in the list from the previous command:

```
ibmcloud atracker target get --target TARGET
```

where TARGET is the name or ID of the route.

6. Validate each target to ensure it is operating successfully Ensure the write status is "Success". Run the following command:

```
ibmcloud atracker target validate --target TARGET
```

where TARGET is the name or ID of the route.

Using API:

To make API calls to manage routes and targets, complete the following steps:

- Get an IAM access token. For more information, see [Retrieving IAM access tokens](#).
- Identify the API endpoint in the region where you plan to configure or manage a route. For more information, see [Endpoints](#).

In this set of instructions, cURL will be used to execute the API calls.

1. List all routes that are configured in your account. Run the following command:

```
curl -X GET <ENDPOINT>/api/v2/routes -H "Authorization: $ACCESS_TOKEN" -H "content-type: application/json"
```

where <ENDPOINT> is the API endpoint in the region where you plan to configure or manage a route.

2. Get the details of each configured route found in the list from the previous command:

```
curl -X GET <ENDPOINT>/api/v2/routes/<ROUTE_ID> -H "Authorization: $ACCESS_TOKEN" -H "content-type: application/json"
```

where <ENDPOINT> is the API endpoint in the region where you plan to configure or manage a route and <ROUTE_ID> is the ID of the route.

3. List all targets that are configured in your account. Run the following command:

```
curl -X GET <ENDPOINT>/api/v2/targets -H "Authorization: $ACCESS_TOKEN" -H "content-type: application/json"
```

where <ENDPOINT> is the API endpoint in the region where you plan to configure or manage a route.

4. Get the details of each configured target found in the list from the previous command:

```
curl -X GET <ENDPOINT>/api/v2/targets/<TARGET_ID> -H "Authorization: $ACCESS_TOKEN" -H "content-type: application/json"
```

where <ENDPOINT> is the API endpoint in the region where you plan to configure or manage a route and <TARGET_ID> is the ID of the target.

5. Validate each target to ensure it is operating successfully Ensure the write_status has a status of "success". Run the following command:

```
curl -X POST <ENDPOINT>/api/v2/targets/<TARGET_ID>/validate -H "Authorization: $ACCESS_TOKEN" -H "content-type: application/json"
```

where <ENDPOINT> is the API endpoint in the region where you plan to configure or manage a route and <TARGET_ID> is the ID of the target.

Remediation:

1. If a route is not configured within IBM Cloud® Activity Tracker Event Routing for each of the locations where you operate in IBM Cloud (including global), you must create or update a route.

To create a route, choose any of the following options:

- [Creating a route using the CONSOLE.](#)
 - [Creating a route using the CLI.](#)
 - [Creating a route using the API.](#)
2. If a target is not configured within IBM Cloud® Activity Tracker Event Routing for each of the locations where you wish to receive your audit events, you must create or update a target.

To create a target, choose any of the following options:

- [Creating a IBM Cloud Logs target using the CONSOLE.](#)
 - [Creating a IBM Cloud Logs target using the CLI.](#)
 - [Creating a IBM Cloud Logs target using the API.](#)
3. If any of the targets have a status or write status of ERROR, you must update the configured target to resolve the authentication issue with the destination.

To update a target, choose any of the following options:

- [Updating a IBM Cloud Logs target using the CONSOLE.](#)
- [Updating a IBM Cloud Logs target using the CLI.](#)
- [Updating a IBM Cloud Logs target using the API.](#)

Default Value:

By default, management audit events are generated and collected automatically. However, you must configure routes and targets to receive those audit events using the IBM Cloud® Activity Tracker Event Routing platform service in your account, as no routes and targets are created by default.

For most of the services in IBM Cloud, data events are generated and collected automatically. However, there are some exceptions where you must opt-in to collect them, such as IBM Cloud Object Storage.

References:

1. <https://cloud.ibm.com/docs/atracker?topic=atracker-getting-started>
2. https://cloud.ibm.com/docs/atracker?topic=atracker-route_v2
3. https://cloud.ibm.com/docs/atracker?topic=atracker-target_v2

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	8.2 Collect Audit Logs Collect audit logs. Ensure that logging, per the enterprise's audit log management process, has been enabled across enterprise assets.			

Controls Version	Control	IG 1	IG 2	IG 3
v8	8.5 <u>Collect Detailed Audit Logs</u> Configure detailed audit logging for enterprise assets containing sensitive data. Include event source, date, username, timestamp, source addresses, destination addresses, and other useful elements that could assist in a forensic investigation.			
v7	6.2 <u>Activate audit logging</u> Ensure that local logging has been enabled on all systems and networking devices.			
v7	6.3 <u>Enable Detailed Logging</u> Enable system logging to include detailed information such as an event source, date, user, timestamp, source addresses, destination addresses, and other useful elements.			

3.2 Ensure data retention for audit events (Manual)

Profile Applicability:

- Level 2

Description:

Create Cloud Object Storage buckets for long-term storage of all audit log events so that you have access to data for a longer period of time, you can comply with highly regulated environments, you can recover quickly in the eventuality of a disaster scenario, and you can adhere to internal data storage policies.

Rationale:

When you provision an instance of IBM Cloud Logs, you must have an IBM Cloud Object Storage (COS) instance in the same account where your IBM Cloud Logs instance is provisioned. Cloud Logs supports having all logs go to the COS bucket, and also has Priority Insights, which provides enhanced interaction with the logs. However, Priority Insights does not provide long-term storage. As such, it is important to ensure that a Cloud Object Storage bucket has been created and that all data is stored there, in addition to any optional use of Priority Insights.

The maximum number of days that data can be available for search within Priority Insights (90 days) is not sufficient and requires a long-term data storage solution. For example, highly regulated environments impose strict storage policies where they define the minimum number of days that log data must be saved for. Internal corporate regulations can also impose data storage policies. You might be affected by a natural disaster and you must recover fast. In any of these sample scenarios, you must implement a storage solution that allows you to keep data for long-term retention.

Data that is managed by the IBM Cloud Logs service is encrypted at rest. Data that is stored in a bucket that is hosted in IBM Cloud Object Storage is encrypted by default using randomly generated keys and an all-or-nothing-transform.

While this IBM Cloud Object Storage default encryption model provides at-rest security, some workloads need to be in possession of the encryption keys used. You can manage your keys manually by providing your own encryption keys - referred to as Server-Side Encryption with Customer-Provided Keys (SSE-C). With IBM Cloud Object Storage, you also have a choice to use IBM's integration capabilities with IBM Cloud Key Management Services like IBM Key Protect and Hyper Protect Crypto Services. Depending on the security requirements, you can decide whether to use IBM Key Protect or IBM Hyper Protect Crypto Services for your IBM Cloud Object Storage buckets.

- IBM Key Protect for IBM Cloud helps you provision encrypted keys for apps across IBM Cloud services. As you manage the lifecycle of your keys, you can benefit from knowing that your keys are secured by FIPS 140-2 Level 3 certified

cloud-based hardware security modules (HSMs) that protect against the theft of information.

- Hyper Protect Crypto Services is a single-tenant, dedicated HSM that is controlled by you. The service is built on FIPS 140-2 Level 4-certified hardware, the highest offered by any cloud provider in the industry.

If you use IBM Cloud Logs, you can store data that is available through an audit instance in an IBM Cloud Object Storage bucket. You can configure the bucket to meet all your internal and external regulations.

There are two types of data that you must consider retaining: events, and service instance metadata, such as views, templates, screens, and alerts.

As guidance, events must be kept for as long as internal compliance requires. If no requirements exist, consider a minimum of 365 days.

Impact:

If you have regulatory or organizational requirements that determine the number of days that data must be available, failure to meet this control can result in breaching compliance.

In addition, if data is corrupted or not archived, and you do not export it within the number of days that are available for Priority Insights, you can lose data.

If you have requirements that define the bucket specification, policies, and encrypting requirements, you might be in breach of infrastructure compliance.

Audit:

Use the following check list to ensure that long-term retention is configured for each of your Cloud Logs instances:

1. Ensure that IBM Cloud Logs instances are provisioned in a region that also contains one or more Cloud Object Storage buckets to configure long-term storage to an external storage service.
2. Ensure that each IBM Cloud Logs has a COS bucket enabled and configured.
 - a. Log in to IBM Cloud at <https://cloud.ibm.com>.
 - b. From the Menu bar, select **Observability**.
 - c. Select **Logging, Instances**. You might need to click the **Cloud Logs** tab to see your IBM Cloud Logs instances.
 - d. Select the instance to which you want to verify a data bucket.
 - e. In the Storage section, confirm the Bucket CRN, and the Bucket endpoint.
3. Ensure that you have access to storage, for example, check that you have an instance of the IBM Cloud Object Storage service provisioned in your account.

You must define a service to service (S2S) authorization between IBM Cloud Logs and IBM Cloud Object Storage to allow IBM Cloud Logs to read and write data into the data bucket. For more information, see [Creating a S2S authorization to grant access to a bucket](#).

4. Ensure that you have COS buckets available to retain your data. Separate buckets for the Data Bucket and Metrics bucket may be required, such as when you wish to apply separate data retention settings to each type of data. Check the bucket configuration to verify that it meets your corporate and external market regulations.

Consider using a bucket for each Cloud Logs instance so that you can customize the bucket to meet security requirements. These requirements might be related to the type of data that is archived and to external regulations like EU-managed requirements, for example.

5. Ensure that the bucket has the following features enabled:
 - A key management service is configured. For example, check IBM Cloud Key Protect is configured so that you can use your own key to encrypt data.
 - Auditing to IBM Cloud Object Storage is enabled and that the options read and data events are included for write and read operations.
 - Monitoring with IBM Cloud Monitoring with Sysdig is enabled.
 - Expiration rules are configured that define when audit logs are automatically deleted. As guidance, events must be kept for as long as internal compliance requires. If no requirements exist, consider a rule that keeps files for a minimum of 365 days.
 - [Optional] An archive policy is configured so that objects that are rarely accessed are moved from their default bucket storage class to the archive storage class after a certain period. Note that Cloud Logs cannot read or search objects which are archived within the Cloud Object Storage bucket, however the archived data can be restored within COS to re-enable Cloud Logs to read and search that data.

Remediation:

1. If the Cloud Logs instance cannot connect to the Cloud Object Storage bucket, you must define a service to service (S2S) authorization between IBM Cloud Logs and IBM Cloud Object Storage to allow IBM Cloud Logs to read and write data into the data bucket. For more information, see [Creating a S2S authorization to grant access to a bucket](#).
2. If no Data Bucket is defined, you must define the Data Bucket within Cloud Logs as follows:
 - a. Log in to IBM Cloud at <https://cloud.ibm.com>.
 - b. From the Menu bar, select **Observability**.

- c. Select **Logging, Instances**. You might need to click the **Cloud Logs** tab to see your IBM Cloud Logs instances.
 - d. Select the instance to which you want to configure a data bucket.
 - e. In the Storage section, click **edit**.
 - f. In the **Logs data** section, configure the Bucket CRN, and the Bucket endpoint.
 - Select **Insert CRN from search** to get the list of buckets in your account. You can choose a CRN from the list.
 - Select **View endpoints in docs** to find the endpoints per location. Choose the endpoint based on your bucket configuration.
 - g. Click Save to save the configuration.
3. If no Metrics Bucket is defined, you must define the Data Bucket within Cloud Logs as follows:
 - a. Log in to IBM Cloud at <https://cloud.ibm.com>.
 - b. From the Menu bar, select **Observability**.
 - c. Select **Logging, Instances**. You might need to click the **Cloud Logs** tab to see your IBM Cloud Logs instances.
 - d. Select the instance to which you want to configure a metrics bucket.
 - e. In the Storage section, click edit.
 - f. In the **Events to metrics data** section, configure the Bucket CRN, and the Bucket endpoint.
 - Select **Insert CRN from search** to get the list of buckets in your account. You can choose a CRN from the list.
 - Select **View endpoints in docs** to find the endpoints per location. Choose the endpoint based on your bucket configuration.
 - g. Click Save to save the configuration.
4. If you cannot find an instance of IBM Cloud Object Storage (COS) in your account, [provision one](#).
5. If you have a bucket that does not have full control over the data encryption keys, configure one of the supported options. [IBM® Cloud Object Storage provides several options to encrypt your data](#).
6. If you have a bucket that does not have an expiration rule to automatically delete objects, configure one for the bucket based on your compliance and organizational requirements. The minimum expiration must be 365 days. For more information, see [Delete stale data with expiration rules](#).

7. If you have a bucket that does not have an archive policy to store long-term data that is rarely accessed, configure one for the bucket based on your compliance and organizational requirements. For more information, see [Archive cold data with transition rules](#).
8. If you have a bucket that does not have Activity Tracker events enabled so that you can monitor any interaction of users and services with the bucket, [enable Activity Tracker events](#) for the bucket.
9. If you have a bucket that does not enable monitoring with IBM Cloud Monitoring with Sysdig, [configure the bucket](#).
10. If you want to create a bucket, see [create and configure a bucket](#).
 - Configure one of the supported options to add additional encryption capabilities. For more information, see [IBM® Cloud Object Storage provides several options to encrypt your data](#).
 - Configure an expiration rule to automatically delete objects. Configure a rule for the bucket based on your compliance and organizational requirements. The minimum expiration must be 365 days. For more information, see [Delete stale data with expiration rules](#).
 - Configure an archive policy to store long-term data that is rarely accessed. Configure a policy for the bucket based on your compliance and organizational requirements. For more information, see [Archive cold data with transition rules](#).
 - Enable Activity Tracker events on the bucket so that you can monitor any interaction of users and services with the bucket. For more information, see [enable Activity Tracker events for the bucket](#).
 - [Enable monitoring for the bucket](#).
 - Define a service to service (S2S) authorization between IBM Cloud Logs and IBM Cloud Object Storage to allow IBM Cloud Logs to read and write data into the data bucket. For more information, see [Creating a S2S authorization to grant access to a bucket](#).

Default Value:

By default, Cloud Logs uses a Cloud Object Storage bucket for storage of events and metadata. However, some settings and options, such as Priority Insights, may change this behavior. Additionally, the default Cloud Object Storage bucket does not have all data protection settings in place that are required to properly secure audit logs and ensure long-term storage.

IBM Cloud Logs does not backup your data. You are responsible for retaining your events. When you enable Cloud Object Storage for your data, you are responsible for checking that your retained files are protected, and the maintenance of your retained files.

References:

1. IBM Cloud Logs: Managing COS Buckets: <https://cloud.ibm.com/docs/cloud-logs?group=managing-cos-buckets>

2. IBM Cloud Logs: TCO Data Pipelines: <https://cloud.ibm.com/docs/cloud-logs?topic=cloud-logs-tco-data-pipelines>
3. IBM Cloud Object Storage: <https://cloud.ibm.com/docs/cloud-object-storage?topic=cloud-object-storage-getting-started-cloud-object-storage>
4. IBM Cloud Object Storage managing encryption: <https://cloud.ibm.com/docs/cloud-object-storage?topic=cloud-object-storage-encryption>

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	8.3 <u>Ensure Adequate Audit Log Storage</u> Ensure that logging destinations maintain adequate storage to comply with the enterprise's audit log management process.			
v7	6.4 <u>Ensure adequate storage for logs</u> Ensure that all systems that store logs have adequate storage space for the logs generated.			

3.3 Ensure that events are collected and processed to identify anomalies or abnormal events (Manual)

Profile Applicability:

- Level 1

Description:

Events that you collect and centralize in the IBM Cloud Logs service provide information about actions that take place on your account. You can analyze this data to resolve problems, identify anomalies, and be notified of abnormal situations.

Rationale:

IBM Cloud Logs and IBM Cloud Activity Tracker Event Routing add audit capabilities to your IBM Cloud architecture.

Each event reports information about who requested an action on your account (initiator details), what action was requested, the resource on which the action was requested (target details), and outcome of the request. Each event is based on the Cloud Auditing Data Federation (CADF) standard. For more information about the IBM event definition, see [Event types](#) and [Event fields](#).

In IBM Cloud Activity Tracker Event Routing, events from core IBM Cloud platform services are collected automatically and can be routed to a destination for analysis such as the IBM Cloud Logs service instances in your account. Events are also collected automatically for [enabled-AT services](#). However, some [services might require an upgrade of the service plan, a configuration setting, or both](#), for you to be able to collect and analyze them.

Core platform Activity Tracker events are available for all IBM Cloud services. These events include provisioning and deletion of service instances, tagging, and IAM management.

Through an audit instance, you can troubleshoot events in real time to diagnose issues and identify problems.

By using the live tail feature, you can diagnose issues, analyze stack traces and exceptions, identify the source of errors, and monitor different event sources through a single view. See [Using Livetail](#) for more information.

IBM® Cloud Logs [custom views](#) feature helps organize specific, relevant log information, as well as create views that help other users work and retrieve important data more efficiently. You can define private and shared views.

Impact:

The recommended custom views allow you to monitor actions that take place in your account, the level of threat of those actions in your account, and abnormal situations. Missing any of these views and the ability to check that events are available through them, exposes a potential security risk by hiding a possible gap of events that are critical to control what happens in the account. In addition, views can have alerts attached to them so that you are notified quickly of abnormal situations. If you do not have the right views, you lose the ability to configure alerts and pre-empt situations that might require your attention.

Audit:

Use the following checklist to ensure that events are collected and processed to identify anomalies or abnormal events:

This checklist assumes that you have a different IBM Cloud account for development, staging, Q&A, and production. When you separate accounts by domain (for example, production versus development), you isolate events for each domain and location. You use IAM to define permissions to view and manage events in an instance.

Note: When a user gets read permissions to see events in an IBM Cloud Logs instance, the user gets visibility of all events in the region. Therefore, separate domains by account to avoid exposing production logs to non-authorized users.

Checklist

The checklist must be applied to each environment independently.

1. Ensure that events from core IBM Cloud core platform services, such as IAM are collected and available in the Cloud Logs instance where 'global' events have been routed to. Check that each core service has one or more custom views to analyze the data.
 - Check that you see provisioning events
 - Check that you see IAM identity login events
 - Check that you see IAM access group and policy events.
2. Ensure that events from enabled IBM Cloud services are collected in each region where you operate. Check that events are available in the audit instance that is available in the same region as your service instances.
 - [Check for additional configuration steps that a service might require](#).
 - Check that you have a custom view for each service.
 - Check that events for a specific service are available for analysis through the custom view.
3. Views can be classified in categories. For example, a category might be aligned with a line of business.
 - Ensure that views are grouped in categories.
 - Check that each view belongs to the correct category.
4. Check that custom views are defined for each service to monitor events that have an outcome of failure.

5. Check that custom views are defined for each service to monitor events that report high level threat actions in your account. These events report deletion actions in the account.
6. Check that custom views are defined for each service to monitor events that report changes to resources in the account. For example, these events report actions that modify the state of a resource in your account.
7. Check that custom views are defined for each service to monitor events that report unauthorized or forbidden access to run actions in the account.
8. Check that custom views are defined for each service to monitor events that report user management actions in the account.
9. Check that custom views are defined for each service to monitor events that report actions on user management and related IAM actions.

UI Instructions

UI instructions that you can use to check that you have custom views to monitor activity in your account:

1. Log in to your IBM Cloud account at <https://cloud.ibm.com>.
2. Go to the Menu icon. Then, select **Observability** to access the **Observability** dashboard.
3. Click **Logging**. By default Instances are displayed.
4. Click the **Cloud Logs** tab.
5. The list of instances that are available on IBM Cloud is displayed.

If the instances are not displayed, click **Instances**, **Cloud Logs** to display the list of logging instances.

6. Click Open dashboard for your selected instance.
7. Look for views that report events from core IBM Cloud core platform services, such as IAM. Check that the search criteria of the views match the query indicated in the search criteria provided.
 - Check that each view displays events with actions listed in the Events that are generated section.
 - Check the description of each view and ensure that it is clear and reflects the type of events that are available through the view.
 - Name your view according to your organization's naming convention.

Service to check: *IAM Identity*

```
Query: *_platform:iam-identity*
```

```
Events that are generated: [Events that are generated when a user or  
app logs in to the IBM  
Cloud] (https://cloud.ibm.com/docs/account?topic=account-  
at\_events\_iam#at\_events\_iam\_login)
```

Service to check: *IAM Access Management (IAM AM)*

```
Query: *_platform:iam-am*
```

Events that are generated: [Events that are generated when you manage IAM policies] (https://cloud.ibm.com/docs/account?topic=account-at_events_iam#at_events_iam_policies)

Service to check: *IAM Groups*

```
Query: *_platform:iam-groups*
```

Events that are generated: [Events that are generated when you manage access groups] (https://cloud.ibm.com/docs/account?topic=account-at_events_iam#at_events_iam_access)

8. Look for views that report events from enabled IBM Cloud services.
 - Check that the search query to filter data in the custom view is in the following format:

```
_platform:<Service Name>
```

- Check the description for each view.
- Check that the name of each view follows your organization's naming convention.

To see the list of available services, see [Cloud services](#).

9. Check that views are organized and grouped by category.
 - a. In the Cloud Logs web UI, select **All Views**
 - b. Check the views that are within each folder.

10. Look for views that report events that fail from enabled IBM Cloud services.
 - Check that the search query to filter data in the custom view is in the following format:

```
_platform:<Service Name> AND outcome:failure
```

- Check the description for each view.
- Check that the name of each view follows your organization's naming convention.

To see the list of available services, see [Cloud services](#).

11. Look for views that report high level of threat actions in your account.
 - Check that the search query to filter data in the custom view is in the following format:

```
_platform:<Service Name> AND severity:critical
```

- Check the description for each view.
- Check that the name of each view follows your organization's naming convention.

To see the list of available services, see [Cloud services](#).

12. Look for views that report actions that modify the state of resources in your account.

- Check that the search query to filter data in the custom view is in the following format:

```
_platform:<Service Name> AND severity:warning
```

- Check the description for each view.
- Check the name of each view follows your organizations naming convention.

To see the list of available services, see [Cloud services](#).

13. Look for views that report unauthorized or forbidden permissions on in your account.

- Use the following search query to check that the custom view reports unauthorized access to run the action due to lack of permissions (RC 401):

```
reason.reasonCode:401
```

- Use the following search query to check that the custom view reports forbidden access to run the action due to missing credentials (RC 403):

```
reason.reasonCode:403
```

- Check the description for each view.
- Check that the name of each view follows your organization's naming convention.

14. Look for views that report user management actions in your account.

- Use the following search query to check that the custom view reports user management actions in the account:

```
(_platform:BSS AND action:user-management)
```

- Use the following search query to check user management and related IAM actions in your account:

```
-( _platform:iam-identity AND (action login)) AND ( _platform:iam  
OR ( _platform:BSS AND action:user-management))
```

- Check the description for each view.
 - Check that the name of each view follows your organization's naming convention.
15. Look for views that report successful logins in your account.
- Use the following search query to check the custom view:

```
_platform:iam-identity AND (action login)
```

- Check the description for each view.
 - Check that the name of each view follows your organization's naming convention.
16. Look for views that report Security Advisor findings, that is, security incidents that are monitored by IBM Cloud Security Advisor in your account.
- Check the description for each view.
 - Check that the name of each view follows your organization's naming convention.

Remediation:

UI instructions that you can use to create custom views when one or more are missing in the account:

1. Log in to your IBM Cloud account at <https://cloud.ibm.com>.
2. Go to the Menu icon. Then, select **Observability** to access the **Observability** dashboard.
3. Click **Logging**. By default Instances are displayed.
4. Click the **Cloud Logs** tab.
5. The list of instances that are available on IBM Cloud is displayed.

If the instances are not displayed, click **Instances**, **Cloud Logs** to display the list of logging instances.

6. Click Open dashboard for your selected instance.
7. In the left navigation, click the **Explore logs icon**, **Logs**.
8. The last view you had opened will be displayed. If no view was previously open, all views will be displayed.
9. Select the fields to be included in the view. By default you can select Applications, Subsystems, and log Severities.
10. (Optional) Add additional filters click **+ Add Filter** and select and configure additional field and filter values.
11. Select if you want you view to only include Priority Logs (those in the Priority insights pipeline) or All Logs, that is, logs that are stored in IBM Cloud Object

Storage. Logs in IBM Cloud Object Storage includes logs collected through all the data pipelines.

12. (Optional) Add a Lucene or DataPrime query to further filter your data.

13. Specify the time interval for the view, for example Last 2 Days.

14. Save your view by clicking the three dots ...

a. Enter a name for your view.

b. If you want to save the query and filter values you configured, check **Save query and filters**.

c. If you want your view to be the default view, check **Set as default view**. This sets the view as the default for you as the user. It does not set the view as the default view for the entire account.

d. Set the privacy of your view. Private views can only be seen by you. You can set a view as Private or Shared.

15. If you are missing views to monitor events from core IBM Cloud core platform services, such as IAM, [create custom views](#) for each of the following services. Use the search criteria provided.

- Check that each view displays events with actions listed in the Events that are generated section.
- Check the description of each view and ensure that it is clear and reflects the type of events that are available through the view.
- Name your view according to your organization's naming convention.

Service to check: *IAM Identity*

```
Query: *_platform:iam-identity*
```

```
Events that are generated: [Events that are generated when a user or app logs in to the IBM Cloud] (https://cloud.ibm.com/docs/account?topic=account-at_events_iam#at_events_iam_login)
```

Service to check: *IAM Access Management (IAM AM)*

```
Query: *_platform:iam-am*
```

```
Events that are generated: [Events that are generated when you manage IAM policies] (https://cloud.ibm.com/docs/account?topic=account-at_events_iam#at_events_iam_policies)
```

Service to check: *IAM Groups*

```
Query: *_platform:iam-groups*
```

Events that are generated: [Events that are generated when you manage access groups] (https://cloud.ibm.com/docs/account?topic=account-at_events_iam#at_events_iam_access)

16. If you are missing views to monitor events from enabled IBM Cloud services, create custom views for each one of them.
- Use the following search query to filter data in the custom view:

```
_platform:<Service Name>
```

- Add a description to each view.
- Name your view according to your organization's naming convention.

To see the list of available services, see [Cloud services](#).

17. If views are not organized and grouped by folder, create as many folders as you want, and assign views.
1. In the Cloud Logs web UI, select **All Views**.
 2. To create a new folder, click the folder icon. Enter a folder name, and click **Create**.
 3. Move views to folders by dragging them to the folder.

18. If you are missing views to monitor events from enabled IBM Cloud services that report failures, create custom views for each one of them.

Use the following search query to filter data in the custom view:

```
_platform:<Service Name> AND outcome:failure
```

Add a description to each view.

Name your view according to your organization's naming convention.

To see the list of available services, see [Cloud services](#).

19. If you are missing views to monitor events that report high level of threat actions in your account, create custom views for each one of them.

Use the following search query to filter data in the custom view:

```
_platform:<Service Name> AND severity:critical
```

Add a description to each view.

Name your view according to your organization's naming convention.

To see the list of available services, see [Cloud services](#).

20. If you are missing views to monitor events that report actions that modify the state of resources in your account, create custom views for each one of them.

Use the following search query to filter data in the custom view:

```
_platform:<Service Name> AND severity:warning
```

Add a description to each view.

Name your view according to your organization's naming convention.

To see the list of available services, see [Cloud services](#).

21. If you are missing views to monitor events that report unauthorized or forbidden permissions in your account, create custom views for each one of them.

Use the following search query to filter data in the custom view that reports unauthorized access to run the action due to lack of permissions (RC 401):

```
reason.reasonCode:401
```

Use the following search query to filter data in the custom view that reports forbidden access to run the action due to missing credentials (RC 403):

```
reason.reasonCode:403
```

Add a description to each view.

Name your view according to your organization's naming convention.

22. If you are missing views to monitor events that report user management actions in your account, create custom views for each one of them.

Use the following search query to filter data in the custom view that report user management actions in the account:

```
(_platform:BSS AND action:user-management)
```

Use the following search query to filter data in the custom view to report user management and related IAM actions in your account:

```
-( _platform:iam-identity AND (action login)) AND ( _platform:iam OR  
( _platform:BSS AND action:user-management))
```

Add a description to each view.

Name your view according to your organization's naming convention.

23. If you are missing views to monitor events that report successful logins in your account, create a custom view.

Use the following search query to filter data in the custom view:

```
_platform:iam-identity AND (action login)
```

Add a description to the view.

Name your view according to your organization's naming convention.

Default Value:

IBM Cloud Logs does not include default templates for views or alerts.

You can define your own views, alerts, and notification channels. Default notification channels are configured by using presets.

References:

1. IBM Cloud Activity Tracker Event Routing: Available Services: https://cloud.ibm.com/docs/atracker?topic=atracker-cloud_services_atracker
2. IBM Cloud Activity Tracker Event Routing: Services Requiring Opt-In: <https://cloud.ibm.com/docs/atracker?topic=atracker-events-opt-in>
3. IBM Cloud Logs: Custom Views: https://cloud.ibm.com/docs/cloud-logs?topic=cloud-logs-custom_views
4. IBM Cloud Activity Tracker Event Types: https://cloud.ibm.com/docs/atracker?topic=atracker-event_types
5. IBM Cloud Activity Tracker Event Fields: <https://cloud.ibm.com/docs/atracker?topic=atracker-event>

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	8.11 <u>Conduct Audit Log Reviews</u> Conduct reviews of audit logs to detect anomalies or abnormal events that could indicate a potential threat. Conduct reviews on a weekly, or more frequent, basis.		●	●
v8	13.1 <u>Centralize Security Event Alerting</u> Centralize security event alerting across enterprise assets for log correlation and analysis. Best practice implementation requires the use of a SIEM, which includes vendor-defined event correlation alerts. A log analytics platform configured with security-relevant correlation alerts also satisfies this Safeguard.		●	●
v7	6.6 <u>Deploy SIEM or Log Analytic tool</u> Deploy Security Information and Event Management (SIEM) or log analytic tool for log correlation and analysis.		●	●
v7	6.7 <u>Regularly Review Logs</u> On a regular basis, review logs to identify anomalies or abnormal events.		●	●

3.4 Ensure alerts are defined on custom views to notify of unauthorized requests, critical account actions, and high-impact operations in your account (Manual)

Profile Applicability:

- Level 2

Description:

Events that you collect and centralize in the IBM Cloud Logs service provide information about actions that take place on your account. You can define alerts to notify promptly of problems, anomalies, and abnormal situations.

Rationale:

Each event reports information about who requested an action on your account (initiator details), what action was requested, the resource on which the action was requested (target details), and outcome of the request. Each event is based on the Cloud Auditing Data Federation (CADF) standard. For more information about the IBM event definition, see Event types and Event fields.

In IBM Cloud Activity Tracker Event Routing, events from core IBM Cloud platform services are collected automatically and can be routed to a destination for analysis such as the IBM Cloud Logs service instances in your account. Events are also collected automatically for enabled-AT services. However, some [services might require an upgrade of the service plan, a configuration setting, or both](#), for you to be able to collect and analyze them.

Core platform Activity Tracker events are available for all IBM Cloud services. These events include provisioning and deletion of service instances, tagging, and IAM management.

Through an audit instance, you can troubleshoot events in real time to diagnose issues and identify problems.

By using the live tail feature, you can diagnose issues, analyze stack traces and exceptions, identify the source of errors, and monitor different event sources through a single view. See Using Livetail for more information.

IBM® Cloud Logs custom views feature helps organize specific, relevant log information, as well as create views that help other users work and retrieve important data more efficiently. You can define private and shared views.

IBM Cloud Logs and IBM Cloud Activity Tracker Event Routing add audit capabilities to your IBM Cloud architecture.

Each event reports information about who requested an action on your account (initiator details), what action was requested, the resource on which the action was requested (target details), and outcome of the request. Each event is based on the Cloud Auditing Data Federation (CADF) standard. For more information about the IBM event definition, see [Event types](#) and [Event fields](#).

In IBM Cloud Activity Tracker Event Routing, events from core IBM Cloud platform services are collected automatically and can be routed to a destination for analysis such as the IBM Cloud Logs service instances in your account. Events are also collected automatically for enabled-AT services. However, some [services might require an upgrade of the service plan, a configuration setting, or both](#), for you to be able to collect and analyze them.

Core platform Activity Tracker events are available for all IBM Cloud services. These events include provisioning and deletion of service instances, tagging, and IAM management.

Through an audit instance, you can troubleshoot events in real time to diagnose issues and identify problems.

By using the live tail feature, you can diagnose issues, analyze stack traces and exceptions, identify the source of errors, and monitor different event sources through a single view. See [Using Livetail](#) for more information.

IBM Cloud Logs [custom views](#) feature helps organize specific, relevant log information, as well as create views that help other users work and retrieve important data more efficiently. You can define private and shared views.

IBM Cloud Logs alerts allow for timely detection of anomalies, proactive incident response, improved mean time to resolution (MTTR), reduced manual monitoring effort, customization, and flexibility. Powered by machine learning, alerting proactively notifies teams of potential problems, correlates incidents, and provides root cause analysis.

Impact:

The recommended alerts on custom views allow you to monitor actions that take place in your account, the level of threat of those actions in your account, and abnormal situations. If you are missing any of these views and the ability to check that events are available through them, exposes a potential security risk by hiding a possible gap of events that are critical to control what happens in the account. In addition, views can have alerts attached to them so that you are notified quickly about abnormal situations. If you do not have the right views, you lose the ability to configure alerts and pre-empt situations that might require your attention.

Audit:

Use the following checklist to ensure alerts are defined on custom views to notify of unauthorized requests, critical account actions, and high-impact operations in your account.

This checklist assumes that you have a different IBM Cloud account for development, staging, Q&A, and production. The checklist must be applied to each environment independently.

In IBM Cloud Logs, you configure alerts that define the triggering conditions on filtered data on which you want to be notified. In IBM Cloud Event Notifications, you configure the destinations where you want to be notified for an alert and the conditions that define to which destination an event is routed. You can route events to one or more destinations based on conditions that you configure. You can notify to a service destination such as a webhook or PagerDuty, or to a human destination such as email or slack.

To check and confirm that alerts are correctly configured, perform the following checks:

1. Verify the outbound connection from IBM Cloud Logs to the IBM Cloud Event Notifications service.

a. First, complete the following steps in the Event Notifications instance:

i. Verify the source with name **IBM Cloud Logs - <CLOUD_LOGS_INSTANCE_ID>**, that matches your integration name, is created in the IBM Cloud Event Notifications instance.

- Select **Sources**.
- Look for the source with name **IBM Cloud Logs - <CLOUD_LOGS_INSTANCE_ID>**.

ii. Create a topic that specifies this Cloud Logs instance as the source and **Event type** scoped to **Test Event**.

- Select **Topics**. Then, click **Create**.
- Enter a topic name, for example, **CloudLogsInstance-test**.
- Select the source **IBM Cloud Logs - <CLOUD_LOGS_INSTANCE_ID>** for the instance whose integration you want to test.
- Select the **Event type** **Test Event**.
- Select **Add a condition**, **Save source**.
- Click **Create**.

iii. Create a destination and verify the destination is configured. For example, you can configure a Slack destination or an email.

iv. Create a Subscription pairing the topic and the destination.

- Enter a name, for example, **Test integration**.
- Select the topic **CloudLogsInstance-test**.
- Select a destination.
- Click **Create**.

- b. Next, in the IBM Cloud Logs UI, complete the following steps:
- i. Edit the outbound integration.
 - ii. Click **Test**.
 - iii. Check your chosen destination and verify the test event has been sent.
2. Ensure all required alerts are defined in the IBM Cloud Logs instance. Normal use and behavior can vary depending on the workload that each client is running. Each client is encouraged to develop and maintain a list of critical alert. Review the configured alerts to ensure there is coverage for all rules required by your organization.
 3. Ensure the IBM Cloud Event Notifications instance is configured to route event notifications when an alert is triggered in IBM Cloud Logs to your target destinations.
- a. Ensure 1 or more topics are defined.
- A topic defines the alert conditions that you want to group together.
 - For example, if you have multiple alert definitions in your IBM Cloud Logs instance that notify through the same slack channel, you can configure these alerts within the same topic.
 - Another example, if you have multiple alert definitions in your IBM Cloud Logs instance that notify through different slack channels, you must configure as many topics as slack channels you use, and include in a topic the alerts that notify through the same slack channel.
- b. Define 1 or more destinations.
- A destination defines a notification channel that you can use to notify when an alert is triggered.
 - For more information on destinations, see [Supported destinations](#).
- c. Define 1 or more subscriptions.
- A subscription links 1 topic with 1 destination.
 - You must add subscriptions to define the alerts configured in a topic are the ones notified through the destination selected in the subscription configuration.
 - A subscription correlates one topic with a notification channel.
 - You can have multiple subscriptions with the same topic so you can alert through multiple destination channels.
4. For each custom view in Cloud Logs, check the purpose of the view and ensure suitable alerts have been created based on the insights gained from that view
 5. Check that alerts have been configured for each of the following custom views:

- Custom views that are defined for each service to monitor events that have an outcome of failure.
- Custom views that are defined for each service to monitor events that have a severity set to critical. These events report deletion actions in the account.
- Custom views that are defined for service to monitor events that have a severity set to warning. These events report actions that modify the state of a resource in your account.
- Custom views that are defined for each service to monitor events that have a reason code set to 403 or 409. These events report requests on a service that are not authorized.
- Custom views that are defined for each service to monitor events that report actions on access groups, changes of policies, user management, service IDs. These events report IAM actions in the account.
- Custom views that report Security Advisor findings, that is, security incidents that are monitored by IBM Cloud Security Advisor in your account.

UI instructions that you can use to check that alerts on custom views are defined and working.

This checklist assumes that you have a different IBM Cloud account for development, staging, Q&A, and production. The checklist must be applied to each environment independently.

1. Log in to IBM Cloud at <https://cloud.ibm.com>.
2. Go to the Menu icon. Then, select **Observability** to access the **Observability** dashboard.
3. Click **Logging**. By default Instances are displayed.
4. Click the **Cloud Logs** tab.
5. The list of instances that are available on IBM Cloud is displayed. If the instances are not displayed, click **Instances**, **Cloud Logs** to display the list of logging instances.
6. Click **Open dashboard** for your selected instance.
7. Look for views that report events from core IBM Cloud core platform services, such as IAM, as well as those related to the conditions described in the Benchmark section 3.3.
8. Check that alert definitions are defined. In the IBM Cloud Logs navigation, click the **Alerts icon**, **Alerts Management**.
9. For each custom view and alert notification channel, verify that you see an alert notification so that you can validate that the alert is being generated.

Remediation:

UI instructions that you can use to create alerts on custom views:

1. Log in to IBM Cloud at <https://cloud.ibm.com>.
2. Go to the Menu icon. Then, select **Observability** to access the **Observability** dashboard.

3. Click **Logging**. By default Instances are displayed.
4. Click the **Cloud Logs** tab.
5. The list of instances that are available on IBM Cloud is displayed. If the instances are not displayed, click **Instances**, **Cloud Logs** to display the list of logging instances.
6. Click **Open dashboard** for your selected instance.
7. [Configure alerts](#) for any missing alerts.

UI Instructions that you can use to create missing outbound integration to connect IBM Cloud Logs with IBM Cloud Event Notifications:

1. Log in to IBM Cloud at <https://cloud.ibm.com>.
2. In the console, click the **Navigation Menu icon**, **Resource list**.
3. Select your instance of IBM Cloud Logs.
4. In the IBM Cloud Logs navigation, click the **Integrations icon**, **Outbound integrations**.
5. In the outbound integrations section, find Event Notifications and click **Add**.
6. On the Integrations page, click **Add new**.
7. If an IAM authorization between IBM Cloud Logs and Event Notifications doesn't exist in your account, you must configure one by clicking **IAM Authorizations**. Follow the prompts to grant access between the services. For more information, see [Creating a S2S authorization to work with the IBM Cloud Event Notifications service](#).
8. Enter a name for the integration.
9. Select the Event Notifications service instance that you want to connect to your IBM Cloud Logs instance.
10. Select the **Endpoint Type** as **public** or **private**. For more information, see Service endpoints for Event Notifications
11. To confirm the connection, click **Save**.

Default Value:

IBM Cloud Logs does not include default templates for views, alerts, and notification channels.

You can define your own views, alerts, and notification channels.

References:

1. IBM Cloud Logs: Working with Alerts: <https://cloud.ibm.com/docs/cloud-logs?topic=cloud-logs-event-notifications-about>
2. Configuring an outbound integration to connect IBM Cloud Logs with IBM Cloud Event Notifications: <https://cloud.ibm.com/docs/cloud-logs?topic=cloud-logs-event-notifications-configure>
3. IBM Cloud Logs: Alerting: <https://cloud.ibm.com/docs/cloud-logs?topic=cloud-logs-alerts>

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	8.11 <u>Conduct Audit Log Reviews</u> Conduct reviews of audit logs to detect anomalies or abnormal events that could indicate a potential threat. Conduct reviews on a weekly, or more frequent, basis.		●	●
v8	13.1 <u>Centralize Security Event Alerting</u> Centralize security event alerting across enterprise assets for log correlation and analysis. Best practice implementation requires the use of a SIEM, which includes vendor-defined event correlation alerts. A log analytics platform configured with security-relevant correlation alerts also satisfies this Safeguard.		●	●
v8	13.11 <u>Tune Security Event Alerting Thresholds</u> Tune security event alerting thresholds monthly, or more frequently.			●
v7	6.6 <u>Deploy SIEM or Log Analytic tool</u> Deploy Security Information and Event Management (SIEM) or log analytic tool for log correlation and analysis.		●	●
v7	6.7 <u>Regularly Review Logs</u> On a regular basis, review logs to identify anomalies or abnormal events.		●	●
v7	6.8 <u>Regularly Tune SIEM</u> On a regular basis, tune your SIEM system to better identify actionable events and decrease event noise.			●

3.5 Ensure the account owner can login only from a list of authorized countries/IP ranges (Manual)

Profile Applicability:

- Level 1

Description:

Monitor the account owner's access to the IBM Cloud account is done from authorized locations that are restricted by IP addresses.

Rationale:

By default, a user can log in from any IP address.

In IBM Cloud, you can restrict a user to log in only from specific IP addresses. Therefore, you can define for the account owner the list of IP addresses that are allowed. Other IP addresses will be restricted.

This configuration feature per user allows you to restrict access from controlled locations and adds an additional level of security into your IBM Cloud account.

When a user such as the account owner logs in, information about its IP address is included in the Activity Tracker security event. You can monitor and be notified when this event is generated in the account. You can obtain in the security event information about unauthorized location.

Impact:

Failure to meet this recommendation limits your ability to control that the account manager can only access and operate in the account from locations that are authorized and allowed by your organization.

Audit:

Complete the following steps to check if you monitor the locations from which the account owner logs in to the account:

First, you need to identify the email of the account owner.

1. In the Cloud UI, go to **Manage, Access (IAM)**, then select **Users**.
2. Identify the user that has the tag **owner**.
3. Select the account owner. Then, click **Details**.
4. Copy the email address of the account owner.

Second, [launch the IBM Cloud Logs instance](#) in the region where Frankfurt and 'global' events are routed. This is the instance where login security events are collected in the account.

In the **All Views** section, look for a view that monitors the account owner login attempts. The search query should be set to: **(action login) AND initiator.name:<email address> AND -initiator.host.address:(<list of IP addresses>)**, where **<email address>** is the account owner email address, and **<list of IP addresses>** is the list of authorized IP addresses that are separated by **OR**, for example, **(xxx.xxx.xxx.xxx OR xxx.xxx.xxx.xxx)**.

Then, check that at least one alert has been configured for audit events that deviate from the expected source IPs.

Additionally, context-based restrictions protect your resources by denying access to identities that don't satisfy context requirements, such as making access requests from the network zones and endpoint types that you define. You can enable context-based restrictions upon creation, or choose to set the rule to report-only mode. Use IBM Cloud Logs to monitor enabled rules and report-only rules to view how the rule affects your users, applications, and workflows without enforcing the rule.

Complete the following steps to check if you monitor for context-based restrictions violations that occur in report-only mode:

1. In the IBM Cloud console, go to the **Navigation Menu icon, Observability, Logging, Instances, Cloud Logs**.
2. Click **Open dashboard** on the dashboard that you use to monitor context-based restrictions.
3. Use the search field to narrow the results to report-only context-based restrictions events.
 - To view potentially blocked access requests, search for **action:context-based-restrictions.policy.eval responseData.isEnforced:==false responseData.decision:Deny**.
 - **isEnforced:==false** indicates that the rule is in report-only mode.
 - **responseData.decision:Deny** indicates that, if you enable the rule, this access request is blocked.
4. Check that at least one alert has been configured for audit events that detect high volumes of context-based restriction violations that are not being enforced.
5. Check that an alert is configured to trigger on any/all context-based restriction violations that are not being enforced which occur for the email address of the Account Owner.

Remediation:

Complete the following steps to monitor the locations from which the account owner logs in to the account:

First, you need to identify the email of the account owner.

1. In the Cloud UI, go to **Manage, Access (IAM)**, then select **Users**.

2. Identify the user that has the tag **owner**.
3. Select the account owner. Then, click **Details**.
4. Copy the email address of the account owner and the list of authorized IP addresses.
5. [Launch the IBM Cloud Logs instance](#) in the region where Frankfurt and global events are routed. This is the instance where login security events are collected in the account.
6. [Create an alert](#) based on any deviations where the Account Owner logs in from an unauthorized IP address. For example, use the following query: **(action login) AND initiator.name:<email address> AND - initiator.host.address:(<list of IP addresses>)**. Replace with the account owner's email address. Replace <list of IP addresses> with the list of IP addresses that are separated by **OR**, for example, (xxx.xxx.xxx.xxx OR xxx.xxx.xxx.xxx) and configured for the account owner.

Complete the following steps to monitor for context-based restriction violations that are not being enforced:

First, you need to identify the email of the account owner.

1. In the Cloud UI, go to **Manage, Access (IAM)**, then select **Users**.
2. Identify the user that has the tag **owner**.
3. Select the account owner. Then, click **Details**.
4. Copy the email address of the account owner and the list of authorized IP addresses.
5. [Launch the IBM Cloud Logs instance](#) in the region where Frankfurt and global events are routed. This is the instance where login security events are collected in the account.
6. [Create an alert](#) that [monitors for any context-based restriction deviations](#) where the Account Owner's email is identified in an event for a context-based restriction that is not being enforced but would have resulted in a deny.
 - Use the query field to narrow the results to report-only context-based restrictions events. Search for **action:context-based-restrictions.policy.eval responseData.isEnforced:==false responseData.decision:Deny**.
 - **isEnforced:==false** indicates that the rule is in report-only mode.
 - **responseData.decision:Deny** indicates that, if you enable the rule, this access request is blocked.

Default Value:

By default, there are no restrictions of which IP Address or contexts the account owner can login from, and there are no alerts in place to monitor this.

References:

1. Monitoring context-based restrictions:
<https://cloud.ibm.com/docs/account?topic=account-cbr-monitor>
2. IBM Cloud Logs: Create an alert: <https://cloud.ibm.com/docs/cloud-logs?topic=cloud-logs-alerts-config>

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	13.5 Manage Access Control for Remote Assets Manage access control for assets remotely connecting to enterprise resources. Determine amount of access to enterprise resources based on: up-to-date anti-malware software installed, configuration compliance with the enterprise's secure configuration process, and ensuring the operating system and applications are up-to-date.			
v7	16.13 Alert on Account Login Behavior Deviation Alert when users deviate from normal login behavior, such as time-of-day, workstation location and duration.			

3.6 Ensure Activity Tracker data is encrypted at rest (Manual)

Profile Applicability:

- Level 1

Description:

Ensure Activity Tracker data is encrypted at rest.

Rationale:

IBM Cloud Logs uses encrypted storage for all its rest data.

IBM Cloud Logs stores the Activity Tracker data in an IBM Cloud Object Storage (COS) bucket for long-term storage. By default, all objects that are stored in COS are encrypted by using randomly generated keys and an all-or-nothing-transform (AONT). Cloud Object Storage further supports additional key management scenarios to encrypt your data. This encryption model is called customer-managed encryption:

1. You can manage your keys manually by providing your own encryption keys - referred to as Server-Side Encryption with Customer-Provided Keys (SSE-C).
2. You can choose to use the integration capabilities with IBM Cloud® Key Management Services like IBM® Key Protect and Hyper Protect Crypto Services.

Impact:

Failure to adopt a customer-managed encryption model for audit data that is retained for long-term storage can breach infrastructure compliance where you are required to use your keys for encrypting data that you manage.

Audit:

1. Ensure IBM Cloud Activity Tracker Event Routing is configured to route audit events to one or more IBM Cloud Logs instances as [documented](#).
2. For each IBM Cloud Logs instance, identify the IBM Cloud Object Storage buckets that are used for both the [data bucket](#) and the [metrics bucket](#). In some cases, these will both use the same bucket, but for some clients separate COS buckets will be used.
3. Verify the data encryption configuration of the COS buckets being used by IBM Cloud Logs to store your data. Check the bucket configuration to verify that it meets your corporate and external market regulations.
4. Ensure that the CIS control **3.2 Ensure data retention for audit events** is met, which outlines the encryptions settings in detail.

Remediation:

If you have Cloud Object Storage buckets in use that do not meet your enterprise or industry encryption compliance requirements, use one of these options to implement the necessary encryption settings:

- A. Implement [Server-Side Encryption with Customer-Provided Keys \(SSE-C\)](#)
- B. Implement [Server-Side Encryption with IBM Key Protect \(SSE-KP\)](#)
- C. Implement [Server-Side Encryption with Hyper Protect Crypto Services](#)

Default Value:

IBM Cloud Logs uses encrypted storage for all data at rest.

By default, all objects that are stored in Cloud Object Storage are encrypted by using randomly generated keys and an all-or-nothing-transform (AONT).

References:

- 1. IBM Cloud Object Storage: <https://cloud.ibm.com/docs/cloud-object-storage?topic=cloud-object-storage-getting-started-cloud-object-storage>
- 2. IBM Cloud Object Storage managing encryption: <https://cloud.ibm.com/docs/cloud-object-storage?topic=cloud-object-storage-encryption>

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.11 <u>Encrypt Sensitive Data at Rest</u> Encrypt sensitive data at rest on servers, applications, and databases containing sensitive data. Storage-layer encryption, also known as server-side encryption, meets the minimum requirement of this Safeguard. Additional encryption methods may include application-layer encryption, also known as client-side encryption, where access to the data storage device(s) does not permit access to the plain-text data.			
v7	14.8 <u>Encrypt Sensitive Information at Rest</u> Encrypt all sensitive information at rest using a tool that requires a secondary authentication mechanism not integrated into the operating system, in order to access the information.			

4 IBM Cloud Databases Family

The IBM Cloud Databases family is a selection of ubiquitous industry databases that run as a cloud-native service with a common consumption, security, and architectural model. These databases have a common control plane API and CLI for non-database engine operations like scaling, whitelisting, and reading available backups. This consistency enables uniform implementation and auditing of platform-level security controls across different database technologies—requiring only the resource name to be adjusted for the specific product.

IBM Cloud Databases are encrypted by default, and this encryption cannot be disabled. If customers choose to use Key Protect and Bring Your Own Key (BYOK), they are fully responsible for managing their encryption keys and configuring Key Protect access controls.

Databases that follow this paradigm include:

- Databases for PostgreSQL
- Databases for MySQL
- Databases for MongoDB
- Databases for Elasticsearch
- Databases for Redis
- Messages for RabbitMQ

4.1 Ensure IBM Cloud Databases disk encryption is enabled with customer managed keys (Manual)

Profile Applicability:

- Level 1

Description:

IBM Cloud Databases provides automatic encryption at rest when provisioning the service. It is not an option to deploy a database service without encryption at rest. However, using the service's integration with IBM Key Protect, customers can bring their own encryption key at the time of database provisioning. Furthermore, IBM Cloud Databases backups are also encrypted by default.

Before any UI or CLI commands. Follow the authorization instructions between the HSM and Database service.

1. Open your IBM Cloud dashboard.
2. From the menu bar, click **Manage, Access (IAM)**.
3. In the side navigation, click **Authorizations**.
4. Click **Create**.
5. In the **Source service** menu, select the service of the deployment. For example, *Databases for PostgreSQL* or *Messages for RabbitMQ*
6. In the **Source service instance** menu, select *All instances*.
7. In the **Target service menu**, select *Key Protect*.
8. Select or retain the default value *Account* as the resource group for the Target Service.
9. In the **Target service Instance ID** menu, select the service instances to authorize.
10. Under **Service access**, check the box to enable the *Reader* role.
11. Click **Authorize**.
12. Service Creation via UI or CLI with the appropriate encryption key from IBM Key Protect

Using Console:

1. Head to the respective catalog page of the service you want to provision with a customer-managed encryption key (e.g., <https://cloud.ibm.com/catalog/services/databases-for-postgresql>)
2. Fill out the form with the desired region, RAM, CPU, Disk, Database version, and Networking settings.
3. Click **Select a Key Protect instance**, your authorized Key Protect instances will appear in the dropdown. Select the one you want to use.

4. Directly to the right, click **Select a disk encryption key**. A list of available encryption keys from the previously selected Key Protect instance will be selectable for encrypting your database at rest.

Using CLI:

Run the following command after logging into IBM Cloud via the CLI

```
ibmcloud resource service-instance-create example-database <service-name>  
standard us-south \  
-p \ '{"disk_encryption_key_crn": "crn:v1:<...>:key:<id>"}'
```

Rationale:

When it comes to encryption of data at rest in IBM Cloud, we recommend for customers to manage customer root keys that are used to protect customer data stored in data and storage services in IBM Cloud. With the support of Bring Your Own Key (BYOK), customers can manage lifecycle of their customer root keys where they can create, rotate, delete those keys. This provides a significant level of control where those CRKs are managed by the customer, which in turn increases both security control as well as meet relevant compliance requirements. These CRKs are used in turn to protect the data encryption keys used to encrypt the data.

Impact:

If a customer does not bring their own encryption key at provision time, they are not able to cryptoshred the database or revoke the database's access to the encryption key rendering it unable to boot storage.

Audit:

Using Console:

1. Log on to your IBM Cloud account
2. Go to the **Menu icon**, **Resource List** to access your list of account resources
3. Click the Database service you are interested in to open the service dashboard.
4. Ensure you are on the **Manage** page in the left pane.
5. You should be on the **Overview** tab. Scroll down to the **security** section.
6. The **security** section will show an **Encryption Key** section under **Disks**. If the value shown is **Automatic Key** this means the deployment does not have a customer-managed encryption key through IBM Key Protect

Using CLI:

1. At a minimum, have the Viewer role for the IBM Cloud Databases deployment.
2. Run

```
ibmcloud cdb deployment-about <CRN> [--all] [--json]
```

This will return the Encryption Key Status, if the deployment is created with a customer-managed encryption key, the key CRN will display here.

Remediation:

There is no zero-downtime remediation procedure . Customer must restore a backup with a new encryption key or create a net new database instance with Bring Your Own Key enabled.

To restore a backup with a new encryption key:

1. Ensure you have the Viewer Privileges on the IBM Cloud Databases deployment to read a backup file and X privileges on IBM Cloud platform to create a resource
2. Ensure you have service to service authorization set up between IBM Cloud Databases and IBM Key Protect, directions for granting this access can be found [here](#)
3. Be sure to replace SERVICE_INSTANCE_NAME and KEY PROTECT KEY CRN with a new service instance name and your desired Key Protect key CRN respectively before running this command. For more information, [please view our documentation](#).

```
ibmcloud resource service-instance-create SERVICE_INSTANCE_NAME databases-  
for-postgresql standard us-south -p '{"backup_id":"xyz-initial-  
backup","disk_encryption_key_crn":"DISK_ENCRYPTION_KEY_CRN"}'
```

4. This will create a new database instance from backup with the requested customer managed encryption key.

Default Value:

The default value when creating a deployment is automatic disk and backup encryption key management by IBM Cloud Databases

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.11 <u>Encrypt Sensitive Data at Rest</u> Encrypt sensitive data at rest on servers, applications, and databases containing sensitive data. Storage-layer encryption, also known as server-side encryption, meets the minimum requirement of this Safeguard. Additional encryption methods may include application-layer encryption, also known as client-side encryption, where access to the data storage device(s) does not permit access to the plain-text data.			
v7	14.8 <u>Encrypt Sensitive Information at Rest</u> Encrypt all sensitive information at rest using a tool that requires a secondary authentication mechanism not integrated into the operating system, in order to access the information.			

4.2 Ensure network access to IBM Cloud Databases service is set to be exposed on “Private end points only” (Manual)

Profile Applicability:

- Level 1

Description:

All Cloud Databases deployments offer integration with IBM Cloud Service Endpoints. It gives you the ability to enable connections to your deployments from the public internet and over the IBM Cloud Private network.

Service Endpoints are available in all IBM Cloud Multi-Zone Regions and Single-Zone Regions. In other words, Deployments in all regions can utilize the available service endpoint options.

Public endpoints provide a connection to your deployment on the public network. However, at provision time, a private endpoint is the default option for all deployments. Your environment needs to have internet access to connect to a deployment.

A deployment with a service endpoint on the private network gets an endpoint that is not accessible from the public internet. All traffic is routed to hardware dedicated to Cloud Databases deployments and remains on the IBM Cloud Private network. All traffic to and from this endpoint is free and unmetered as long as the traffic remains in IBM Cloud. Once your environment has access to the IBM Cloud Private network, an internet connection is not required to connect to your deployment.

Rationale:

The use of public endpoints exposes data that is contained in the database to unnecessary risk from the outside internet.

Impact:

Some applications are not run in the IBM Cloud. Therefore, they cannot rely on the IBM Cloud network backbone to maintain communication from application to the database over the private network. In this case, the customer may choose to enable "Public" endpoints which allow access to the database from the internet. Customers that are required to do so should IP Whitelist the database before enabling "Public" endpoints.

Audit:

Using Console:

1. Log on to your IBM Cloud account
2. Go to the **Menu icon**, **Resource List** to access your list of account resources
3. Click the Database service you are interested in to open the service dashboard.
4. Ensure you are on the **Manage** page in the left pane.

5. Click the **Settings** tab in the middle of the page and scroll down to **Service endpoints**
6. Review the toggle that displays the status of Private endpoint and Public endpoint enablement. Ensure, Public is toggled **off** and Private is toggled **on**. (Private is the default setting)

Using API:

1. Access to the API uses token authentication, by using the header Authorization: Bearer . The token must be IAM-issued. You can send in an IAM API key directly as the token or use the API key to generate an [IAM Bearer Token](#).
2. Insert the region your deployment is in and the CRN of your deployment as indicated by {}

```
curl -X GET
https://api.{region}.databases.cloud.ibm.com/v4/ibm/deployments/{id} -H
'Authorization: Bearer <>' \
```

This will return something like:

```
{
  "deployment": {
    "id": "crn",
    "name": "crn",
    "type": "database",
    "platform_options": {
      "key_protect_key_id": ""
    },
    "version": "x.y",
    "admin_username": "admin",
    "enable_private_endpoints": true,
    "enable_public_endpoints": false
  }
}
```

Ensure that **enable_private_endpoints** is **true** and that **enable_public_endpoints** is **false**.

Remediation:

Using Console:

1. Log on to your IBM Cloud account
2. Go to the **Menu icon**, **Resource List** to access your list of account resources
3. Click the Database service you are interested in to open the service dashboard.
4. Ensure you are on the **Manage** page in the left pane.
5. Click the **Settings** tab in the middle of the page and scroll down to **Service endpoints**
6. Select **Private endpoint** toggle to be turned **on** and **Public endpoint** to be turned **off**.
7. Click **Update Endpoints**

Using CLI:

You can use the `ibmcloud resource service-instance-update` command in the CLI, specifying the endpoint with the `--service-endpoints` flag. This can be done online with no downtime

```
ibmcloud resource service-instance-update <service-name> --service-endpoints <endpoint-type>
```

Changing the type of endpoints available on your deployment does not cause any downtime from a database perspective. However, if you disable an endpoint that is being used by you or your applications, those connections are dropped.

From the API:

You can use the Resource Controller API, with a **PATCH** request to the `/resource_instances/{id}` endpoint.

Figure out more detail here, should be copy and paste for every service

Default Value:

Private

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.3 <u>Configure Data Access Control Lists</u> Configure data access control lists based on a user's need to know. Apply data access control lists, also known as access permissions, to local and remote file systems, databases, and applications.			
v7	14.6 <u>Protect Information through Access Control Lists</u> Protect all information stored on systems with file system, network share, claims, application, or database specific access control lists. These controls will enforce the principle that only authorized individuals should have access to the information based on their need to access the information as a part of their responsibilities.			

4.3 Ensure incoming connections are limited to allowed sources (Manual)

Profile Applicability:

- Level 1

Description:

Restrict incoming connections to database instances to approved sources, ensuring access is limited to authorized entities.

Rationale:

IBM Cloud Databases supports Context-Based Restrictions (CBR) for both public and private endpoints. Context-based restrictions give account owners and administrators the ability to define and enforce access restrictions for resources based on a rule's criteria. The criteria include the network location of access requests, the endpoint type from where the request is sent, the multifactor authentication level of an identity, and sometimes the API that the request tries to access.

Audit:

Using Console:

1. Log on to your IBM Cloud account
2. On the top bar, click on **Manage** and then on **Context-Based Restrictions**
3. On the left, click on **Network zones** and then on the **Create** button.
4. Give the rule a name and fill out the other details as appropriate. **Complete creation.**
5. On the left, click on **Network rules** and then on the **Create** button
6. Select the appropriate database resource, such as **Databases for PostgreSQL**. Click on **next**.
7. When asked for APIs to protect, deselect **All** and select **Data Plane** instead. Click on **next**.
8. Under **Resources**, select Specific resources, and then in the dropdown, select **instance**
9. Click on **Select a value**, and you can choose a database to match. Click on **review** and then on **continue**.

Using CLI:

1. Create a zone for IP 192.0.2.2

```
ibmcloud cbr zone-create --addresses=192.0.2.2 --name=my_zone
```

2. Note the ID of the zone from the response, or from the zones list

```
ibmcloud cbr zones
```

3. Create the rule that only allows the defined zone to connect to our PostgreSQL database

```
ibmcloud cbr rule-create --enforcement-mode enabled --context-attributes networkZoneId=ac31d7c9911cd0b98bb77490b2254258 --service-name databases-for-postgresql --service-instance 8e4ce809-5edd-47c0-b4cd-8737f030f29d --api-types crn:v1:bluemix:public:context-based-restrictions:::api-type:data-plane --description my_cbr_rule
```

4. Examine the list of rules.

```
ibmcloud cbr rules
```

Note that the direct “Using IP Allowlists on your Deployment” mechanism, as described in <https://cloud.ibm.com/docs/cloud-databases?topic=cloud-databases-allowlisting&interface=ui>, has been deprecated in favor of CBR.

Remediation:

Configure restrictions using the following procedure:

Using Console:

1. Log on to your IBM Cloud account
2. On the top bar, click on **Manage** and then on **Context-Based Restrictions**
3. On the left, click on **Network zones** and then on the **Create** button.
4. Give the rule a name and fill out the other details as appropriate. **Complete creation.**
5. On the left, click on **Network rules** and then on the **Create** button
6. Select the appropriate database resource, such as **Databases for PostgreSQL**. Click on **next**.
7. When asked for APIs to protect, deselect **All** and select **Data Plane** instead. Click on **next**.
8. Under **Resources**, select Specific resources, and then in the dropdown, select **instance**
9. Click on **Select a value**, and you can choose a database to match. Click on **review** and then on **continue**.

10. Select the check mark for the zone that you want to give access to (the one created at the start of the process), then click on the **Add** button. You will see it on the right side. Click on **continue**.
11. Give it a descriptive name, and then click on **Create**.

Using CLI:

1. Create a zone for IP 192.0.2.2

```
ibmcloud cbr zone-create --addresses=192.0.2.2 --name=my_zone
```

2. Note the ID of the zone from the response, or from the zones list

```
ibmcloud cbr zones
```

3. Create the rule that only allows the defined zone to connect to our PostgreSQL database

```
ibmcloud cbr rule-create --enforcement-mode enabled --context-attributes networkZoneId=ac31d7c9911cd0b98bb77490b2254258 --service-name databases-for-postgresql --service-instance 8e4ce809-5edd-47c0-b4cd-8737f030f29d --api-types crn:v1:bluemix:public:context-based-restrictions:::api-type:data-plane --description my_cbr_rule
```

4. Examine the list of rules.

```
ibmcloud cbr rules
```

Note that the direct “Using IP Allowlists on your Deployment” mechanism, as described in <https://cloud.ibm.com/docs/cloud-databases?topic=cloud-databases-allowlisting&interface=ui>, has been deprecated in favor of CBR.

Default Value:

All incoming connections allowed.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.3 <u>Configure Data Access Control Lists</u> Configure data access control lists based on a user's need to know. Apply data access control lists, also known as access permissions, to local and remote file systems, databases, and applications.			

Controls Version	Control	IG 1	IG 2	IG 3
v7	14.6 <u>Protect Information through Access Control Lists</u> Protect all information stored on systems with file system, network share, claims, application, or database specific access control lists. These controls will enforce the principle that only authorized individuals should have access to the information based on their need to access the information as a part of their responsibilities.			

5 Cloudant

Cloudant is a database, run as a service in the IBM Cloud. Its job is to store your application's data securely and allow you to retrieve it quickly and efficiently. The foundation of the IBM Cloudant managed database service is the Apache CouchDB database. IBM is active in the Apache CouchDB committee, employs members of the PMC, and commits most of its feature, functions, and enhancements back to the open source project. Over the last few years, IBM made significant effort to align the core feature set of IBM Cloudant and CouchDB. We contributed key features like IBM Cloudant Query/Mango query language, full-text search, and partition queries to CouchDB.

Apache CouchDB and IBM Cloudant are nearly fully API compatible, which means they can serve as drop-in replacements for each other in your application. They speak the same replication protocol so that you can seamlessly synchronize data between IBM Cloudant and CouchDB instances. However, some differences between the fully managed cloud service IBM Cloudant and self-managed open source Apache CouchDB still exist.

5.1 Ensure IBM Cloudant encryption is enabled with customer managed keys (Manual)

Profile Applicability:

- Level 2

Description:

IBM Cloudant encrypts all client data at-rest by default. For customers using a Dedicated Hardware plan instance, it is optional to use the service's integration with IBM Key Protect for customers to bring their own encryption key at provision time for the instance.

To provision a Cloudant Dedicated Hardware plan instance using Bring-Your-Own-Key with Key Protect, first ensure you are logged into your IBM Cloud account at <https://cloud.ibm.com/>. Note a paid account is required to provision a Cloudant Dedicated Hardware plan instance.

Before provisioning the Dedicated Hardware plan instance with BYOK with Key Protect, follow the authorization instructions between Key Protect and Cloudant:

1. Open your IBM Cloud dashboard.
2. From the menu bar, click **Manage, Access (IAM)**.
3. In the side navigation, click **Authorizations**.
4. Click **Create**.
5. In the Source service menu, select the **Cloudant** in **Account**.
6. In the Source service instance menu, select **All instances**.
7. In the Target service menu, select **Key Protect** in **Account**, and leave Instance ID of **string equals All instances**.
8. Enable the **Reader** role by checking the checkbox.
9. Click **Authorize**.

Ensure the necessary encryption key(s) in Key Protect have been created. (See IBM Key Protect documentation for those steps.)

Next provision a Cloudant Dedicated Hardware plan instance and choose the BYOK with Key Protect option during the provisioning process:

Using Console:

1. From the IBM Cloud Dashboard, click on **Create resource**.
2. Type **Cloudant** in the search bar and click the Cloudant tile to open it.
3. Select **Cloudant** offering.
4. Click the **Dedicated** tab.
5. Click **Create Host**.
6. Select the IBM Cloud region.

7. Configure the Cloudant instance by specifying the **Instance name** and **Resource group**.
8. Under Configure Host, choose the **Location for deployment** to specify the physical location of the Dedicated Hardware plan instance.
9. Choose **Yes** or **No** for **Will the data stored require HIPPA compliance?**.
10. To use a customer-managed (BYOK) encryption key, choose the KMS instance under **Key Management Service instance**.
11. Under Disk encryption key, choose the name of the encryption key to use from the KMS instance in the previous step.
12. Click **Create** to provision the Dedicated Hardware plan instance. Note that during provisioning, a spinning wheel appears next to the instance in your IBM Cloud Dashboard. A request is sent to provision a Dedicated Hardware plan instance on bare metal servers. Provisioning time is asynchronous and can take up to 5 days.

Using CLI:

1. Login to the IBM Cloud via the CLI.
2. Run the following command to provision a Cloudant Dedicated Hardware plan instance using a customer-managed encryption key stored in IBM Key Protect:

```
ibmcloud resource service-instance-create <name> cloudantnosqldb dedicated-hardware <region> -p '{"location":"<location>", "hipaa":"<hipaa>", "kms_instance_crn": "<kms_instance_crn>", "kms_key_crn": "<kms_key_crn>"}'
```

Where the customer parameters to enter are as follows:

- **name**: An arbitrary name of the Cloudant Dedicated Hardware instance.
- **region**: The major region where you want to deploy, for example us-south, us-east, etc.
- **location**: The actual physical location of the Dedicated Hardware plan instance, which might differ from the **region**. The location can be in any IBM Cloud location, including major regions and locations outside the major regions.
- **hipaa**: Either **true** or **false**.
- **kms_instance_crn**: An optional parameter that must be set to the CRN of the Key Protect instance housing the encryption key for BYOK. All IBM Cloudant environments are encrypted. If you would like to BYOK with Key Protect, supply the CRN of the Key Protect instance that holds the encryption key. Otherwise, don't supply this parameter in the CLI, which means the environment is encrypted with an IBM Cloudant-managed key.
- **kms_key_crn**: This parameter is required if you use the **kms_instance_crn** parameter. Otherwise, it must not be supplied in the CLI command. The **kms_key_crn** parameter is set to the CRN of the encryption key stored in the Key Protect instance defined by the **kms_instance_crn** parameter.

Below is an example CLI command with the parameters populated with sample values:

```
ibmcloud resource service-instance-create cloudant-dedicated-with-byok
cloudantnosqldb dedicated-hardware us-south -p '{"location":"dallas",
"hipaa":"false", "kms_instance_crn": "crn:v1:bluemix:public:kms:us-
south:a/abcdefg7df5907a4ae72ad28d9f493d6:888a5a41-543c-4ca7-af83-
74da3bb8f711::", "kms_key_crn": "crn:v1:bluemix:public:kms:us-
south:a/abcdefg7df5907a4ae72ad28d9f493d6:888a5a41-543c-4ca7-af83-
74da3bb8f711:key:0123c653-f904-4fe7-9fdb-5097e1ed85db"}'
```

Rationale:

When it comes to encryption of data at rest in IBM Cloud, we recommend for customers to manage customer root keys that are used to protect customer data stored in data and storage services in IBM Cloud. With the support of Bring Your Own Key (BYOK), customers can manage lifecycle of their customer root keys where they can create, rotate, delete those keys. This provides a significant level of control where those CRKs are managed by the customer, which in turn increases both security control as well as meet relevant compliance requirements. These CRKs are used in turn to protect the data encryption keys used to encrypt the data.

Impact:

Additional administrative time will be required for the creation, transport, storage, and management of keys when using customer managed keys. If a customer does not bring their own encryption key at provision time, they are not able to crypto-shred the data or revoke the database's access to the encryption key, which would render the database unable to read the data.

Audit:

Users can audit whether a Cloudant Dedicated Hardware environment is using a customer-managed key by viewing associations between root keys and associated cloud services in the IBM Key Protect UI or API. Use the steps below to see the associations and verify that the Cloudant Dedicated Hardware plan instance(s) have the appropriate associations listed to show the use of customer-managed encryption key in Key Protect.

Using Console:

1. Log in to the IBM Cloud console.
2. Go to **Menu, Resource List** to view a list of your resources.
3. From your IBM Cloud resource list, select your provisioned instance of Key Protect.
4. On the application details page, select the **Associated Resources** tab on the left side menu.
5. On the Associated resources page, use the **Associated Resources** table to browse the registrations in your service.
6. Click the ^ icon under the **Details** column to view a list of details for a specific registration.

7. Click **Filter** button to filter for resources by key ID, Cloud Resource Name (CRN), and retention policy.

Using API:

You can retrieve the registration details that are associated with a specific root key by making a GET call to the following endpoint:

```
https://<region>.kms.cloud.ibm.com/api/v2/keys/<key_ID>/registrations
```

View the registrations that are associated with a root key by running the following cURL command:

```
$ curl -X GET \
  "https://<region>.kms.cloud.ibm.com/api/v2/keys/<key_ID>/registrations" \
  -H "authorization: Bearer <IAM_token>" \
  -H "bluemix-instance: <instance_ID>"
```

where the variables are as follows:

- **region**: Required. The region abbreviation, such as **us-south** or **eu-gb**, that represents the geographic area where your Key Protect instance resides.
- **key_ID**: Required. The identifier for the root key that is associated with the cloud resources that you want to view.
- **IAM_token**: Required. Your IBM Cloud access token. Include the full contents of the IAM token, including the Bearer value, in the cURL request.
- **instance_ID**: Required. The unique identifier that is assigned to your Key Protect service instance.

Remediation:

The process to remediate a configuration where there is no use of a customer-managed encryption is as follows:

1. Provision a new Cloudant Dedicated Hardware plan instance using a customer-managed key as shown in details above.
2. Create new Cloudant instance(s) on the Dedicated Hardware plan instance that is using a customer-managed key as needed.
3. Replicate data over from the Cloudant instances not using a customer-managed key to the instances on the Dedicated Hardware environment using the customer-managed key. This process requires use of the Cloudant replication feature as shown in the Cloudant documentation.
4. Delete any Cloudant instances on environments that do not use customer-managed keys once the replication is complete.

Default Value:

The default value is **Automatic disk encryption key (default)**, which means the disk encryption will be done with an IBM-managed key and not a customer managed key. Customers must choose to use IBM Key Protect with a customer-managed key.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.11 <u>Encrypt Sensitive Data at Rest</u> Encrypt sensitive data at rest on servers, applications, and databases containing sensitive data. Storage-layer encryption, also known as server-side encryption, meets the minimum requirement of this Safeguard. Additional encryption methods may include application-layer encryption, also known as client-side encryption, where access to the data storage device(s) does not permit access to the plain-text data.			
v7	14.8 <u>Encrypt Sensitive Information at Rest</u> Encrypt all sensitive information at rest using a tool that requires a secondary authentication mechanism not integrated into the operating system, in order to access the information.			

6 Networking

6.1 IBM Cloud Internet Services

IBM Cloud™ Internet Services (CIS), powered by Cloudflare, offers three main capabilities to enhance your workflow: security, reliability, and performance.

6.1.1 Enable TLS 1.2 at minimum for all inbound traffic on IBM Cloud Internet Services Proxy (Manual)

Profile Applicability:

- Level 1

Description:

The Transport Layer Security (TLS) options let you control whether visitors can browse your website over a secure connection, and when they do, how IBM Cloud™ Internet Services connects to your origin server. Ensure minimum TLS level for TLS termination is set to TLS 1.2. Use the latest version of the TLS protocol (TLS 1.3) for improved security and performance by switching from **Disabled** to **Enabled** or **Enabled+ORTT** in the list.

TLS encryption modes

Set the TLS mode by selecting one of the following options from the Mode list.

These options are listed in the order from the least secure (Off) to the most secure (End-to-End CA signed).

- Off (not recommended)
- Client-to-Edge (edge to origin not encrypted, self-signed certificates are not supported)
- End-to-End flexible (edge to origin certificates can be self-signed)
- End-to-End CA signed (default and recommended)
- HTTPS only origin pull (Enterprise only)

Traffic encryption - Minimum TLS version

Set the minimum TLS version for traffic trying to connect to your site by selecting one of the versions from the list.

By default, this is set to 1.2. Higher TLS versions provide additional security, but might not be supported by all browsers. This could result in some customers being unable to connect to your site.

The minimum TLS version applies to whichever **TLS encryption mode** is selected.

Rationale:

Use the latest version of the TLS protocol for improved security and performance. TLS1.1 is now considered obsolete and has some vulnerabilities.

Impact:

Higher TLS versions provide additional security, but might not be supported by all browsers. This could result in some customers being unable to connect to your site.

Audit:

The Minimum TLS setting can be audited using the following mechanisms

IBM Cloud Console

1. Log in to IBM Cloud at <https://cloud.ibm.com>.
2. Click **Menu icon --> Resource list**
3. Select the Cloud Internet Service Instance
4. Select the domain that needs to be audited from the domains drop down
5. Choose the **Security** section from the left panel.
6. Click on the **TLS** tab in the Security panel.
7. Verify the **Traffic Encryption - Minimum TLS Version** is set to a value of *TLS 1.2(default)* or higher

IBM Cloud CLI

1. Verify `min_tls_version` must be set to **1.2** or higher

```
ibmcloud cis tls-settings e476aba943b5d7d29b96135c78aa55c9 --output json
{
  "min_tls_version": "1.2",
  "ssl": "strict",
  "tls_1_2_only": "off",
  "tls_1_3": "off",
  "universal": true
}
```

Remediation:

IBM Cloud Console

1. Log in to IBM Cloud at <https://cloud.ibm.com>.
2. Click **Menu icon -- Resource list**
3. Select the Cloud Internet Service Instance that needs to be remediated from the domains drop down.
4. Choose the **Security** section from the left panel.
5. Click on the **TLS** tab in the Security panel.
6. Change the TLS version on **Traffic Encryption - Minimum TLS Version** to *TLS 1.2(default)*

IBM Cloud CLI

1. Set `min_tls_version` to `1.2`

```
ibmcloud cis tls-settings-update <DOMAIN_ID> -i <Instance-Name> --min-tls-version 1.2
```

Default Value:

The default TLS mode is set to TLS1.2 for any TLS termination on Cloud Internet Services

References:

1. <https://cloud.ibm.com/docs/cis?topic=cis-cis-tls-options>
2. <https://cloud.ibm.com/docs/cis?topic=cis-manage-your-ibm-cis-for-optimal-security>
3. <https://cloud.ibm.com/docs/cis?topic=cis-cli-plugin-cis-cli#waf>
4. <https://cloud.ibm.com/docs/cis?topic=cis-cli-plugin-cis-cli#overview>
5. <https://cloud.ibm.com/docs/cis?topic=cis-getting-started>

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.10 <u>Encrypt Sensitive Data in Transit</u> Encrypt sensitive data in transit. Example implementations can include: Transport Layer Security (TLS) and Open Secure Shell (OpenSSH).			
v7	14.4 <u>Encrypt All Sensitive Information in Transit</u> Encrypt all sensitive information in transit.			

6.1.2 Ensure Web application firewall is **ENABLED** in IBM Cloud Internet Services (CIS) (Manual)

Profile Applicability:

- Level 1

Description:

A Web Application Firewall (WAF) is a security solution designed to protect web applications by monitoring, filtering, and blocking malicious HTTP/S (OSI Layer 7) traffic between a client (usually a browser) and a web server.

What is a Web Application Firewall?

A WAF sits between the internet and your web application, acting as a reverse proxy that inspects incoming and outgoing web traffic. It uses rule-based logic, machine learning, or behavioral analysis to detect and prevent common threats including the OWASP Top-10 attack techniques.

A WAF may use one or more of the following detection methods:

- Signature-based detection (matches known attack patterns)
- Anomaly-based detection (flags behavior outside the baseline)
- Policy-based rules (user-defined or vendor-supplied rules)

Key benefits of a CIS WAF

The IBM Cloud™ Internet Services WAF is an easy way to set up, manage, and customize security rules to protect your web applications from common web threats. See the following list for key features:

- **Easy setup:** The CIS WAF is part of our overall service, which takes just a few minutes to set up. After you redirect your DNS to us, you can switch on the WAF and set up the rules you need.
- **Always on protection:** Once CIS WAF is deployed and enabled it will protect against some of the common web application attack patterns like
 - Zero-day vulnerabilities -
 - Top-10 attack techniques
 - Use of stolen/leaked credentials
- **Detailed reporting:** See greater detail in the reporting, for example, threats blocked by rule/rule group.

Rationale:

A WAF or Web Application Firewall helps protect web applications by filtering and monitoring HTTP traffic between a web application and the client on the Internet.

Types of attacks WAF can prevent

A WAF typically protects web applications from attacks such as cross-site forgery, cross-site-scripting (XSS), file inclusion, and SQL injection, among others. A WAF usually is part of a suite of tools, which together can create a holistic defense against a range of attack vectors.

How a WAF works

WAF is a type of reverse-proxy that protects the server from exposure by having the client requests pass through the WAF before reaching the server. It acts as shield placed between the web application and the internet.

A WAF operates through a set of rules often called policies. These policies aim to protect against vulnerabilities in the application by filtering out malicious traffic.

The value of a WAF comes from the speed and ease with which its policy modifications can be implemented, thereby allowing a faster response to varying attack vectors. For example, for a zero-day vulnerability the WAF vendor can deploy a patch on that will prevent the exploitation of the vulnerability.

Impact:

A WAF is an OSI protocol Layer-7 defense in the OSI model, and it is not designed to defend against all types of attacks. When a WAF is enabled on Cloud Internet Services the TLS traffic is terminated at the proxy, unencrypted, inspected for any attacks, and then re-encrypted and forwarded on to the application. Another thing to consider with WAF is that there may be false positives based on the application patterns and clients may get blocked or challenged. This can be mitigated by tuning the WAF or creating custom policies that would let traffic pass under certain conditions.

Audit:

The Web Application Firewall setting can be audited using the following mechanisms

Using Console:

1. Login to the IBM Cloud at <https://cloud.ibm.com>
2. Click **Menu icon**, **Resource list**
3. Select the Cloud Internet Service Instance
4. Select the domain that needs to be audited from the domains drop down
5. Choose the **Security** section from the left panel.
6. Click on the **WAF** tab in the **Security** panel.
7. Make sure the **CIS Managed Ruleset** and **CIS OWASP Core Ruleset** are both deployed and enabled

Using API:

1. Run the curl command below. The value for \$iam_token will be the IBM Cloud iam token retrieved by running the command

```
ibmcloud iam oauth-tokens
Request:
curl -s
https://api.cis.cloud.ibm.com/v1/{crn}/zones/{zoneid}/rulesets/phases/http_request_firewall_managed/entrypoint \
-H 'content-type: application/json' \
-H 'accept: application/json' \
-H "x-auth-user-token: Bearer $iam_token" | jq '.result.rules[] | {ruleid: .action_parameters.id, enabled: .enabled}'

Response:
{
  "ruleid": "efb7b8c949ac4650a09736fc376e9aee",
  "enabled": true
}
{
  "ruleid": "4814384a9e5d4991b9815dcfc25d2f1f",
  "enabled": true
}
```

In the above response rules map to the deployed ruleset ids as shown below

```
CIS Managed Ruleset: efb7b8c949ac4650a09736fc376e9aee
CIS OWASP Core Ruleset: 4814384a9e5d4991b9815dcfc25d2f1f
```

Remediation:

The Web Application Firewall can be enabled in Cloud Internet Services using the following procedure

Using Console

1. Login to the IBM Cloud at <https://cloud.ibm.com>
2. Click **Menu icon**, **Resource list**
3. Select the Cloud Internet Service Instance
4. Select the domain that needs to be audited from the **domains** drop down
5. Choose the **Security** section from the left panel.
6. Click on the **WAF** tab in the **Security** panel.
7. Deploy the following WAF managed rulesets by clicking the **Deploy** button next to them
 - o CIS Managed Ruleset
 - o CIS OWASP Core Ruleset
8. After rulesets are deployed or if they are already deployed, make sure they are enabled by clicking on the toggle under the **Status** column.

Note: For WAF to be inline of the request flow, the DNS records or global load balancers need to have proxies enabled. Only when the records are proxied, the traffic will flow through the Cloud Internet Services reverse proxy and will get inspected.

Default Value:

By default the Managed rulesets for WAF will not be deployed in Cloud Internet Services.

References:

1. <https://cloud.ibm.com/docs/cis?topic=cis-manage-your-ibm-cis-for-optimal-security#best-practice-activate-waf-safely>
2. <https://cloud.ibm.com/docs/cis?topic=cis-waf-q-and-a>
3. <https://cloud.ibm.com/docs/cis?topic=cis-using-the-cis-security-events-capability>
4. <https://cloud.ibm.com/docs/cis?topic=cis-getting-started>

Additional Information:

The proxy mode for the dns record or the global load balancer must be enabled for the traffic to pass through the Web Application Firewall.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	13.10 Perform Application Layer Filtering Perform application layer filtering. Example implementations include a filtering proxy, application layer firewall, or gateway.			●
v7	9.5 Implement Application Firewalls Place application firewalls in front of any critical servers to verify and validate the traffic going to the server. Any unauthorized traffic should be blocked and logged.			●

6.1.3 Ensure DDoS protection is Active on IBM Cloud Internet Services (Manual)

Profile Applicability:

- Level 1

Description:

IBM Cloud Internet services provides automatic DDoS protection for any proxied DNS records or a Range Application. For an application to be protected against DDoS attacks the DNS records for the application should be proxied. If the application is accessed via a Cloud Internet Services global load balancer, the global load balancer should be proxied. In addition, it is required to allowlist only IPs from the Cloud Internet Services on your application ingress points. The list of ips to be allow listed is found [here](#).

Rationale:

A distributed denial of service (DDoS) attack is a malicious attempt to disrupt normal traffic of a server, service, or network by overwhelming the target or its surrounding infrastructure with a flood of internet traffic. DDoS attacks achieve effectiveness by utilizing many compromised computer systems as sources of attack traffic. Exploited machines can include computers and other networked resources such as IoT devices. From a high level, a DDoS attack is like a traffic jam clogging up a highway, preventing regular traffic from arriving at its destination.

DDoS attack vectors target varying components of a network connection. While nearly all DDoS attacks involve overwhelming a target device or network with traffic, attacks can be divided into three categories. An attacker can use one or multiple attack vectors, and might even cycle through these attack vectors based on countermeasures taken by the target.

Common types are:

- Application layer attacks (Layer 7)
- Protocol attacks (Layer 3 and Layer 4)
- Volumetric attacks (amplification attacks)

Application layer attacks An application layer attack is sometimes referred to as a Layer-7 DDoS attack (in reference to the 7th layer of the OSI model). The goal of these attacks is to exhaust the resources of the victim, by targeting the layer where web pages are generated on the server and delivered to the visitors in response to HTTP requests (that is, the application layer). Layer-7 attacks are challenging, because the traffic can be difficult to identify as malicious.

Protocol attacks Protocol attacks utilize weaknesses in Layer 3 and Layer 4 of the ISO protocol stack to render the target inaccessible. These attacks, also known as a state-exhaustion attacks, cause a service disruption by consuming all the available state table capacity of web application servers, or of intermediate resources such as firewalls and load balancers.

Volumetric attacks This category of attacks attempts to create congestion by consuming all available bandwidth between the target and the wider internet. Large amounts of data are sent to a target using a form of amplification, or by other means of creating massive traffic, such as requests from a botnet.

Impact:

Allowing proxy will route your data through the Cloud Internet Services proxy and will be decrypted and inspected for layer7 DDoS attacks.

Audit:

The different types of mechanisms to audit if DDoS is enabled are as follows:

Using Console:

1. Log in to IBM Cloud at <https://cloud.ibm.com>.
2. Click **Menu icon, Resource list**
3. Select the Cloud Internet Service Instance
4. Click on **Reliability** on the Left Navigation panel.
5. Click on the **Global Load Balancers** tab.
6. Verify each GLB indicates that proxy is enabled by the green toggle.
7. Click on the **DNS** tab.
8. Verify each DNS record indicates that proxy is enabled by the green toggle.

Using CLI:

Run the following ibmcloud cli command and review the value of the **proxied** property to verify it is set to **true** for any global load balancers. This ensures that the traffic is inspected by the proxy and detect and layer 7 DDoS attacks.

```
ic cis glbs <DOMAIN_ID> --output JSON | jq '.[ ] | {Name: .name, Proxied: .proxied}'
{
  "Name": "tt.advanced-cert-test.batflare.com",
  "Proxied": true
}
```

Run the following ibmcloud cli command and review the value of the **proxied** property to verify it is set to **true** for any DNS records that are proxiable (that can be proxied). This ensures that the traffic is inspected by the proxy and detect and layer 7 DDoS attacks.

```
ic cis dns-records <DOMAIN_ID> --output JSON | jq '.[ ] | {Name: .name, Type:
.type, Content: .content, Proxiable: .proxiable, Proxied: .proxied}'
{
  "Name": "advanced-cert-test.batflare.com",
  "Type": "A",
  "Content": "1.2.3.4",
  "Proxiable": true,
  "Proxied": true
}
{
  "Name": "tanya.advanced-cert-test.batflare.com",
  "Type": "A",
  "Content": "20.43.161.105",
  "Proxiable": true,
  "Proxied": true
}
{
  "Name": "test.advanced-cert-test.batflare.com",
  "Type": "AAAA",
  "Content": "2001:db8::2:1",
  "Proxiable": true,
  "Proxied": true
}
{
  "Name": "www.advanced-cert-test.batflare.com",
  "Type": "CNAME",
  "Content": "www.google.com",
  "Proxiable": true,
  "Proxied": true
}
}
```

Remediation:

The different types of mechanisms to set if DDoS is enabled are as follows:

Using Console:

1. Log in to IBM Cloud at <https://cloud.ibm.com>.
2. Click **Menu icon**, **Resource list**
3. Select the Cloud Internet Service Instance
4. Click on **Reliability** on the Left Navigation panel.
5. Click on the **Global Load Balancers** tab.
6. Change the toggle for the **Proxied** column to green.
7. Click on the **DNS** tab.
8. Change the toggle for **Proxy** column for the relevant DNS records to green.

Using CLI:

1. Run the following ibmcloud cli commands to set the value of the **proxied** property to **true**
 - Global Load Balancer

```
ibmcloud cis glb-update <DNS Domain Id> <DNS GLB ID> --json '{
    "name": "tt.advanced-cert-test.batflare.com",
    "fallback_pool": "9f3fa92d0c7c59d96b179450aff0fc8e",
    "default_pools": ["9f3fa92d0c7c59d96b179450aff0fc8e"],
    "proxied": true
}'
Updating GLB '8d9b09da038741ca319fa3ec0262bb19' in domain
'681c5cf97f44e5da2f66924f5a4db5b2' for service instance 'WAF Epoch June 12th'
...
OK
```

ID	8d9b09da038741ca319fa3ec0262bb19
Name	tt.advanced-cert-test.batflare.com
Created On	0001-01-01 00:00:00 +0000 UTC
Modified On	2025-08-19 18:58:47.038104 +0000 UTC
Description	
Proxied	true
TTL	30
Fallback Pool	9f3fa92d0c7c59d96b179450aff0fc8e
Default Pools	9f3fa92d0c7c59d96b179450aff0fc8e
Region Pools	
Session Affinity	none
Session Affinity TTL	0
Session Affinity Attributes	
Samesite	Auto
Secure	Auto
Drain Duration	0
Steering Policy	off
Available Pools	0/1

- **DNS Records**

```
ibmcloud cis dns-record-update <DOMAIN_ID> <DNS_RECORD_ID> --proxied true
Updating DNS Record '98d434c268fd613ac28937176a8b86b5' in domain
'681c5cf97f44e5da2f66924f5a4db5b2' for service instance 'WAF Epoch June 12th'
...
OK
```

ID	98d434c268fd613ac28937176a8b86b5
Created On	2024-12-13 23:37:25.43331 +0000 UTC
Modified On	2024-12-13 23:37:35.834688 +0000 UTC
Name	advanced-cert-test.batflare.com
Type	A
Content	1.2.3.4
Domain ID	
Domain Name	
Proxied	true
TTL	1

Default Value:

Default value for Proxy for all DNS records and GLBs are set to disabled.

References:

1. <https://cloud.ibm.com/docs/cis?topic=cis-distributed-denial-of-service-ddos-attack-concepts>
2. <https://cloud.ibm.com/docs/cis?topic=cis-manage-your-ibm-cis-for-optimal-security#best-practice-activate-waf-safely>
3. <https://cloud.ibm.com/docs/cis?topic=cis-cis-allowlisted-ip-addresses>

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	0.0 <u>Explicitly Not Mapped</u> Explicitly Not Mapped			
v7	9.2 <u>Ensure Only Approved Ports, Protocols and Services Are Running</u> Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.		●	●

6.2 IBM Virtual Private Cloud (VPC)

With IBM Cloud™ Virtual Private Cloud (VPC), you can use the UI, CLI, and API to quickly provision generation 2 virtual server instances for VPC with high network performance. VPC infrastructure contains a number of Infrastructure-as-a-Service (IaaS) offerings, including Virtual Servers for VPC. Use the following information to understand a simple use case for planning, creating, and configuring resources for your VPC, and learn about additional VPC overviews and VPC tutorials.

6.2.1 Ensure no VPC access control lists allow ingress from 0.0.0.0/0 to port 22 (Manual)

Profile Applicability:

- Level 1

Description:

VPC access control lists filter all incoming and outgoing traffic in IBM Cloud VPC. An ACL is a built-in, virtual firewall where ACL rules control traffic to and from the subnets, rather than to and from the virtual servers. It is recommended that no ACL allows unrestricted ingress access to port 22.

Rationale:

Removing uncontrolled connectivity to remote console services, such as SSH, reduces a server's exposure to risk.

Impact:

For updating an existing environment, care should be taken to ensure that administrators currently relying on an ingress from 0.0.0.0/0 have access to ports 22 through another, more restrictive, access control list.

Audit:

Using Console:

1. Log in to the IBM Cloud Portal at <https://cloud.ibm.com>
2. Navigate to the Infrastructure section by clicking on the Menu icon and selecting **Infrastructure, Network, Access Control Lists**
3. For each access control list, follow these steps:
 - a. Click on the access control list name to view its details.
 - b. In the **Inbound Rules** tab, examine each rule to ensure it does not contain a port range that includes port **22** and has a Source of **ANY IP OR 0.0.0.0/0**. A port range value of **ALL** or a range that includes port **22**, such as **0-1024** are inclusive of port **22**.

Remediation:

Using Console:

1. Login to the IBM Cloud Portal at <https://cloud.ibm.com>.
2. Select the **Navigation** Menu, then click **Infrastructure, Network, Access control lists**.
3. For the ACL that need to be remediated, perform the following:

- a. Select the access control list name.
- b. Identify the Inbound rule to be removed.
- c. Using the **Options** icon, select **Delete**.

Default Value:

Unless modified, the *allow-all-network-acl* access control list has *Access* set to *Allow*, *protocol* set to *Any*, a *port range* of *Any* and a *Source* of **0.0.0.0/0**.

References:

1. <https://cloud.ibm.com/docs/vpc?topic=vpc-using-acls>

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	4.4 <u>Implement and Manage a Firewall on Servers</u> Implement and manage a firewall on servers, where supported. Example implementations include a virtual firewall, operating system firewall, or a third-party firewall agent.			
v8	4.5 <u>Implement and Manage a Firewall on End-User Devices</u> Implement and manage a host-based firewall or port-filtering tool on end-user devices, with a default-deny rule that drops all traffic except those services and ports that are explicitly allowed.			
v7	9.2 <u>Ensure Only Approved Ports, Protocols and Services Are Running</u> Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.			

6.2.2 Ensure the default security group of every VPC restricts all traffic (Manual)

Profile Applicability:

- Level 1

Description:

VPC security groups provide stateful filtering of ingress/egress network traffic to Virtual Server. It is recommended that no security group allows unrestricted ingress access to a Virtual Server. Unless modified, the default security group allows inbound traffic from all members of the group that is, all other virtual servers that are attached to this security group.

Rationale:

Removing uncontrolled connectivity to a Virtual Server, reduces a server's exposure to risk.

Impact:

For updating an existing environment, care should be taken to ensure that Virtual Servers currently relying on ingress have the required access.

Audit:

Perform the following tasks to determine if the account is configured as prescribed:

Using Console:

1. Login to the IBM Cloud Portal at <https://cloud.ibm.com>.
2. At the Menu icon, select **VPC Infrastructure**, **VPC Layout**, **Security Groups**.
3. For the default security group, perform the following:
 - a. Ensure no Inbound Rule exists that allows unrequited traffic to the Virtual Servers.

Remediation:

Using Console:

1. Login to the IBM Cloud Portal at <https://cloud.ibm.com>.
2. At the Menu icon, select **VPC Infrastructure**, **VPC Layout**, **Security Groups**.
3. For the default security group, perform the following:
 - a. Identify the Inbound rule.
 - b. Update the rule to only allow the required traffic flow.

Default Value:

Unless modified, the default security group allows inbound traffic from all members of the group that is, all other virtual servers that are attached to this security group.

References:

1. <https://cloud.ibm.com/docs/vpc?topic=vpc-updating-the-default-security-group>

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	4.4 <u>Implement and Manage a Firewall on Servers</u> Implement and manage a firewall on servers, where supported. Example implementations include a virtual firewall, operating system firewall, or a third-party firewall agent.			
v8	4.5 <u>Implement and Manage a Firewall on End-User Devices</u> Implement and manage a host-based firewall or port-filtering tool on end-user devices, with a default-deny rule that drops all traffic except those services and ports that are explicitly allowed.			
v7	9.2 <u>Ensure Only Approved Ports, Protocols and Services Are Running</u> Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.			

6.2.3 Ensure no VPC security groups allow ingress from 0.0.0.0/0 to port 3389 (Manual)

Profile Applicability:

- Level 1

Description:

VPC security groups provide stateful filtering of ingress/egress network traffic to Virtual Server Instances. It is recommended that no security group allows unrestricted ingress access to port 3389.

Rationale:

Removing uncontrolled connectivity to remote console services, such as RDP, reduces a server's exposure to risk.

Impact:

For updating an existing environment, care should be taken to ensure that administrators currently relying on an ingress from 0.0.0.0/0 have access to port 3389 through another, more restrictive, access control list.

Audit:

Perform the following tasks to determine if the account is configured as prescribed:

Using Console:

1. Login to the IBM Cloud Portal at <https://cloud.ibm.com>.
2. At the Menu icon, select **Infrastructure, Network, Security Groups**.
3. For each security group, perform the following:
 - a. Select the security group name.
 - b. Ensure no Inbound Rule exists that has a port range that includes port 3389 and has a **Source** of 0.0.0.0/0. Note that a **port range** value of **ANY** or a **port range** that includes port 3389, e.g. 3300-3400, are inclusive of port 3389.

Remediation:

Using Console:

1. Login to the IBM Cloud Portal at <https://cloud.ibm.com>.
2. At the Menu icon, select **Infrastructure, Network, Security Groups**.
3. For each security group, perform the following:
 - a. Select the access control list name.
 - b. Identify the Inbound rule to be removed.
 - c. Using the **Options** icon, select **Delete**.

Default Value:

There are no default rules in the default security group with a value of 3389.

References:

1. <https://cloud.ibm.com/docs/vpc?topic=vpc-using-acls>
2. <https://cloud.ibm.com/docs/vpc?topic=vpc-configuring-the-security-group&interface=ui>

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	4.4 Implement and Manage a Firewall on Servers Implement and manage a firewall on servers, where supported. Example implementations include a virtual firewall, operating system firewall, or a third-party firewall agent.			
v8	4.5 Implement and Manage a Firewall on End-User Devices Implement and manage a host-based firewall or port-filtering tool on end-user devices, with a default-deny rule that drops all traffic except those services and ports that are explicitly allowed.			
v7	9.2 Ensure Only Approved Ports, Protocols and Services Are Running Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.			

6.2.4 Ensure no VPC security groups allow ingress from 0.0.0.0/0 to port 22 (Manual)

Profile Applicability:

- Level 1

Description:

VPC security groups provide stateful filtering of ingress/egress network traffic to Virtual Servers. It is recommended that no security group allows unrestricted ingress access to port 22.

Rationale:

Removing uncontrolled connectivity to remote console services, such as SSH, reduces a server's exposure to risk.

Impact:

For updating an existing environment, care should be taken to ensure that administrators currently relying on an ingress from 0.0.0.0/0 have access to port 22 through another, more restrictive, security group.

Audit:

Perform the following tasks to determine if the account is configured as prescribed:

Using Console:

1. Login to the IBM Cloud Portal at <https://cloud.ibm.com>.
2. At the Menu icon, select **Infrastructure, Network, Security Groups**.
3. For each security group, perform the following:
 - a. Select the security group name.
 - b. Ensure no Inbound Rule exists that has a value that includes port 22 and has a **Source** of 0.0.0.0/0. Note that a **port range** value of **ANY** or a **port range** that includes port 22, e.g. 0-1024, are inclusive of port 22.

Remediation:

Using Console:

1. Login to the IBM Cloud Portal at <https://cloud.ibm.com>.
2. At the Menu icon, select **Infrastructure**, **Network**, **Security Groups**.
3. For each security group, perform the following:
 - a. Select the security group name.
 - b. Identify the Inbound rule to be removed.
 - c. Using the **Options** icon, select **Delete**.

Default Value:

Unless modified, the default security group includes a rule with **protocol** set to **TCP**, a value of **22** and a **Source** of **0.0.0.0/0**.

References:

1. <https://cloud.ibm.com/docs/vpc?topic=vpc-using-acls>

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	4.4 Implement and Manage a Firewall on Servers Implement and manage a firewall on servers, where supported. Example implementations include a virtual firewall, operating system firewall, or a third-party firewall agent.			
v8	4.5 Implement and Manage a Firewall on End-User Devices Implement and manage a host-based firewall or port-filtering tool on end-user devices, with a default-deny rule that drops all traffic except those services and ports that are explicitly allowed.			
v7	9.2 Ensure Only Approved Ports, Protocols and Services Are Running Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.			

6.2.5 Ensure no VPC access control lists allow ingress from 0.0.0.0/0 to port 3389 (Manual)

Profile Applicability:

- Level 1

Description:

VPC access control lists filter all incoming and outgoing traffic in IBM Cloud VPC. An ACL is a built-in, virtual firewall where ACL rules control traffic to and from the subnets, rather than to and from the virtual servers. It is recommended that no ACL allows unrestricted ingress access to port 3389.

Rationale:

Removing uncontrolled connectivity to remote console services, such as RDP, reduces a server's exposure to risk.

Impact:

For updating an existing environment, care should be taken to ensure that administrators currently relying on an ingress from 0.0.0.0/0 have access to port 3389 through another, more restrictive, access control list.

Audit:

Perform the following tasks to determine if the account is configured as prescribed:

Using Console:

1. Login to the IBM Cloud Portal at <https://cloud.ibm.com>.
2. At the Menu icon, select **Infrastructure, Network, Access Control Lists**.
3. For each access control list, perform the following:
 - a. Select the access control list name.
 - b. Ensure no Inbound Rule exists that has a **port range** that includes port 3389 and has a Source of 0.0.0.0/0. Note that a **port range** value of **ANY** or a **port range** that includes port 3389, e.g. 3300-3400, are inclusive of port 3389.

Remediation:

1. Login to the IBM Cloud Portal at <https://cloud.ibm.com>.
2. At the Menu icon, select **Infrastructure, Network, Access Control Lists**.
3. For the ACL that need to be remediated, perform the following:
 - a. Select the access control list name.

- b. Identify the Inbound rule to be removed.
- c. Using the **Options** icon, select **Delete**.

Default Value:

Unless modified, the **allow-all-network-acl** access control list has **Access** set to **Allow**, **protocol** set to **Any**, a **port range** of **Any** and a **Source** of **0.0.0.0/0**.

References:

1. <https://cloud.ibm.com/docs/vpc?topic=vpc-using-acls>

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	4.4 <u>Implement and Manage a Firewall on Servers</u> Implement and manage a firewall on servers, where supported. Example implementations include a virtual firewall, operating system firewall, or a third-party firewall agent.			
v8	4.5 <u>Implement and Manage a Firewall on End-User Devices</u> Implement and manage a host-based firewall or port-filtering tool on end-user devices, with a default-deny rule that drops all traffic except those services and ports that are explicitly allowed.			
v7	9.2 <u>Ensure Only Approved Ports, Protocols and Services Are Running</u> Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.			

7 Containers

7.1 IBM Cloud Kubernetes Service

Deploy highly available containerized apps in Kubernetes clusters and use the powerful tools of IBM Cloud™ Kubernetes Service to automate, isolate, secure, manage, and monitor your workloads across zones or regions.

First, create a cluster with a few clicks in the IBM Cloud console. Then, deploy your first containerized app to your cluster through the Kubernetes dashboard.

7.1.1 Ensure data in Kubernetes secrets is encrypted using a Key Management Service (KMS) provider (Manual)

Profile Applicability:

- Level 2

Description:

Protect sensitive information in your IBM Cloud Kubernetes Service cluster to ensure data integrity and to prevent your data from being exposed to unauthorized users.

Understanding Key Management Service (KMS) providers When you enable a key management service (KMS) provider for your cluster, you bring your own root key. The root key is used to encrypt the data encryption keys (DEKs) which are then used to encrypt the secrets in your cluster. The root key is stored in the KMS provider instance that you control. The encrypted DEKs are stored in etcd and can only be unencrypted using the root key from the KMS provider.

Supported KMS providers IBM Cloud Kubernetes Service supports the following KMS providers:

- IBM Key Protect for IBM Cloud.
- Hyper Protect Crypto Services.

Key Protect leverages FIPS 140-2 Level 3 certified cloud-based hardware security modules. Hyper Protect Crypto Services is built on FIPS 140-2 Level 4 certified hardware.

As adding a different KMS provider requires updating the managed master default configuration, you can have only one KMS provider and key enabled in the cluster at a time.

Rationale:

Kubernetes secrets are base64 encoded by default. You can further protect Kubernetes secrets and any credentials stored in your secrets by enabling a key management service (KMS) provider to encrypt secrets with encryption keys that you control.

When it comes to encryption of data at rest, IBM Cloud recommend for customers to manage customer root keys (CRK) that are used to protect customer data stored in data and storage services in IBM Cloud. With the support of Bring Your Own Key (BYOK), customers can create, store, and manage the lifecycle of their root keys to achieve full control of other DEKs stored in the cloud.

Impact:

Review the following notes about cluster secret encryption.

- Standard pricing for Key Protect and Hyper Protect Crypto Services applies.
- Cluster secrets are encrypted by using your KMS.
- Cluster secrets are automatically updated after rotating root keys.
- Clusters that use the root key are viewable from the KMS provider interface.
- Clusters automatically respond if you disable, enable, rotate, or restore root keys.
- Disabling a root key restricts cluster functionality until you reenables the key.
- If a deleted root key cannot be restored, the cluster becomes unusable and unrecoverable.
 - Both Key Protect and Hyper Protect Crypto Services provide features that allow deleted keys to be restored for a period of time after deletion.
- Deleting the KMS instance will delete the keys as well, making the cluster unstable and unrecoverable.
- You can have only one KMS provider and key enabled in the cluster at a time.
- You can switch the KMS provider and key.
- You can't disable KMS provider encryption.

Audit:

1. To check that KMS encryption is enabled, verify that the **Key Management Service** status is set to enabled in the output of the following command.

```
ibmcloud ks cluster get -c <cluster_name_or_ID>
```

2. [Log in to your account. If applicable, target the appropriate resource group. Set the context for your cluster.](#)
3. Verify that you can list the secrets in your cluster

```
kubectl get secrets --all-namespaces
```

4. In your KMS instance, [disable the root key](#) that is used to encrypt your cluster. Note: the CRK can only be disabled from the account where it is located.
5. Wait for the cluster to detect the change to your root key.
6. Try to list your secrets. You will get a timeout error because you can no longer connect to your cluster. If you try to set the context for your cluster by running **ibmcloud ks cluster config**, the command fails.

```
kubectl get secrets --all-namespaces
```

7. Check that your cluster is in a warning state. Your cluster remains in this state and is unusable until you enable your root key again.

```
ibmcloud ks cluster get -c <cluster_name_or_ID>
```

8. In your KMS instance, enable the root key so that your cluster returns to a **normal** state and becomes usable again.

Remediation:

Using Console:

The following remediation steps assume you are not using cross account KMS encryption.

1. [Create a KMS instance and root key.](#)
2. Log in to the IBM Cloud console.
3. To view a list of your resources, go to **Menu**, **Containers**, **Clusters**.
4. From the Clusters page, select your cluster.
5. In the **Cluster details** section, under Cluster encryption click **Enable**. If you already enabled the KMS provider, click **Update**.
6. Select the **Root key** that you want to use for the encryption, by KMS instance or Root key CRN.
7. Click **Enable** (or **Update**).
8. Verify that the KMS enablement process is finished. The process is finished when that the **Master Status** is **Ready** and **Key management service** is **enabled**.
9. After the KMS provider is enabled in the cluster, all cluster secrets are automatically encrypted.

Using Command Line:

The following remediation steps assume you are not using cross account KMS encryption.

1. [Create a KMS instance and root key.](#)
2. Obtain the ID of the KMS instance that you previously created.

```
ibmcloud ks kms instance ls
```

3. Get the ID of the root key that you previously created.

```
ibmcloud ks kms crk ls --instance-id <KMS_instance_ID>
```

4. Enable the KMS provider to encrypt secrets in your cluster. Complete the options with the information that you previously retrieved. The KMS provider's private cloud service endpoint is used by default to download the encryption keys. To use the public cloud service endpoint instead, include the **--public-endpoint** option. The enablement process can take some time to complete.

```
ibmcloud ks kms enable -c <cluster_name_or_ID> --instance-id  
<kms_instance_ID> --crk <root_key_ID> [--public-endpoint]
```

5. Verify that the KMS enablement process is finished. The process is finished when that the **Master Status** is **Ready** and **Key management service** is **enabled**.
6. After the KMS provider is enabled in the cluster, all cluster secrets are automatically encrypted.

Default Value:

Kubernetes secrets are base64 encoded but not encrypted.

References:

1. <https://cloud.ibm.com/docs/containers?topic=containers-encryption-secrets>
2. <https://cloud.ibm.com/docs/containers?topic=containers-encryption#cluster-secret-encryption>
3. <https://cloud.ibm.com/docs/key-protect>
4. <https://cloud.ibm.com/catalog/services/key-protect>
5. <https://cloud.ibm.com/docs/hs-crypto>
6. <https://cloud.ibm.com/catalog/services/hyper-protect-crypto-services>

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.11 <u>Encrypt Sensitive Data at Rest</u> Encrypt sensitive data at rest on servers, applications, and databases containing sensitive data. Storage-layer encryption, also known as server-side encryption, meets the minimum requirement of this Safeguard. Additional encryption methods may include application-layer encryption, also known as client-side encryption, where access to the data storage device(s) does not permit access to the plain-text data.			
v7	14.8 <u>Encrypt Sensitive Information at Rest</u> Encrypt all sensitive information at rest using a tool that requires a secondary authentication mechanism not integrated into the operating system, in order to access the information.			

7.1.2 Ensure TLS 1.2+ for all inbound traffic at IBM Cloud Kubernetes Service Ingress (Automated)

Profile Applicability:

- Level 1

Description:

Ensure that all insecure (HTTP) client requests to applications and services hosted on IBM Cloud Kubernetes Service are redirected to secure TLS connections (HTTPS) and ensure that only TLS versions 1.2+ are supported.

You set up Ingress application load balancers (ALBs) in your cluster to secure your domain with the IBM-provided TLS certificate or your custom TLS certificate. Some users might try to access your apps by using an insecure http request to your ALB domain, for example <http://www.myingress.com>, instead of using https.

Rationale:

Hypertext transfer protocol secure (HTTPS) is the secure version of HTTP and uses the Transport Layer Security (TLS) protocol to provide a secure, encrypted connection between the client and the server. This protocol encrypts communication to protect users from attack, for example, man in the middle attacks.

IBM Cloud Kubernetes Service provides configuration options that redirect HTTP requests to HTTPS, and it is highly recommended to enable this. If you do not use this configuration, insecure HTTP requests are not converted into HTTPS requests by default and might expose unencrypted confidential information to the public.

Impact:

Incoming requests will not be able to use HTTP because all requests will be redirected to HTTPS. Legacy clients that require TLS 1.0 or 1.1 support will not be able to access your applications.

Audit:

1. Obtain the configuration for the ibm-k8s-controller-config ConfigMap resource.

```
kubectl get cm ibm-k8s-controller-config -n kube-system -o yaml
```

2. In the **data** section, ensure that the **ssl-protocols** key is not present, or if it is present, ensure that it only includes TLSv1.2 and/or TLSv1.3.
3. In the **data** section, ensure that the **ssl-redirect** key is present and is set to **true**.

```
apiVersion: v1
data:
  ssl-protocols: "TLSv1.2 TLSv1.3"
  ssl-redirect: "true"
kind: ConfigMap
metadata:
  name: ibm-k8s-controller-config
  namespace: kube-system
```

4. Obtain the configuration for your Ingress resource by running the following command:

```
kubectl get ingress <my_ingress> -n <my_namespace> -o yaml
```

5. In the **annotations** section, ensure that the **nginx.ingress.kubernetes.io/ssl-redirect** key is present and is set to **true**.

```
apiVersion: networking.k8s.io/v1
kind: Ingress
metadata:
  name: myingress
  annotations:
    nginx.ingress.kubernetes.io/ssl-redirect: "true"
spec:
  tls:
  - hosts:
    - myhost
    secretName: mytlssecret
  rules:
  - host: myhost
    http:
      paths:
      - backend:
          service:
            name: myservice
            port:
              number: 8080
        path: /
```

Remediation:

1. Edit the configuration file for the **ibm-k8s-controller-config** ConfigMap resource by running the following command:

```
kubectl edit cm ibm-k8s-controller-config -n kube-system
```

2. In the **data** section, remove the **ssl-protocols** key, or ensure it is set to **ssl-protocols: "TLSv1.2 TLSv1.3"**.
3. In the data section, add **ssl-redirect: "true"**.

```
apiVersion: v1
data:
  ssl-protocols: "TLSv1.2 TLSv1.3"
  ssl-redirect: "true"
kind: ConfigMap
metadata:
  name: ibm-k8s-controller-config
  namespace: kube-system
```

4. Edit the configuration for your Ingress resource by running the following command:

```
kubectl edit ingress <my_ingress> -n <my_namespace>
```

5. In the **annotations** section, add **nginx.ingress.kubernetes.io/ssl-redirect: "true"**.

```
apiVersion: networking.k8s.io/v1
kind: Ingress
metadata:
  name: myingress
  annotations:
    nginx.ingress.kubernetes.io/ssl-redirect: "true"
spec:
  tls:
  - hosts:
    - myhost
    secretName: mytlssecret
  rules:
  - host: myhost
    http:
      paths:
      - backend:
          service:
            name: myservice
            port:
              number: 8080
        path: /
```

Default Value:

The default setting supports only TLS 1.2 and 1.3 for HTTPS. Redirecting HTTP requests to HTTPS is disabled by default.

References:

1. <https://cloud.ibm.com/docs/containers?topic=containers-encryption#keyprotect>
2. <https://cloud.ibm.com/docs/hs-crypto>

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.10 <u>Encrypt Sensitive Data in Transit</u> Encrypt sensitive data in transit. Example implementations can include: Transport Layer Security (TLS) and Open Secure Shell (OpenSSH).			
v7	14.4 <u>Encrypt All Sensitive Information in Transit</u> Encrypt all sensitive information in transit.			

7.1.3 Ensure IBM Cloud Kubernetes Service worker nodes are updated to the latest version to ensure patching of vulnerabilities (Automated)

Profile Applicability:

- Level 1

Description:

Update the worker nodes in a cluster to the latest patch version so that security fixes are applied to those worker nodes.

Rationale:

As security updates and patches are put in place for the API server and other master components, you must be sure that the worker nodes remain in sync. You can make two types of updates: updating only the patch version, or updating the **major.minor** version with the patch version. This benchmark is only in relation to updating the patch version, not the major or minor versions. Updating the patch version in a timely manner ensures patching of known vulnerabilities and will keep your worker nodes more secure.

Impact:

The worker node update also updates the worker node to the same **major.minor** version as the master if a **major.minor** update is also available.

Audit:

Using Console:

1. Log in to the IBM Cloud console.
2. To view a list of your clusters, go to **Menu, Containers, Clusters**.
3. From the Clusters page, select your cluster.
4. Select the **Worker Nodes** tab.
5. For each listed worker node, ensure that next to the **Version** no information icon is present indicating that an update is available. If there is an information icon indicating there is an update available, then the worker node is not running the latest available image.

Using Command Line:

1. List the clusters in your IBM Cloud account

```
ibmcloud ks cluster ls
```

2. List the workers for a given cluster.

```
ibmcloud ks workers -c <cluster_name_or_ID>
```

3. Ensure that next to the version for a worker node no asterisk (*) is present indicating that an update is available.

Here is an example output for a VPC cluster that shows that there is an available update for a worker node:

```
ibmcloud ks worker -c mykubeccluster
OK
ID                                     Primary IP
Flavor      State   Status   Zone      Version      Operating System
kube- btdsgk5d0t1lpluh7f40-mykubeccluster-default-000000d1 12.345.678.90
gx3.16x80.14 normal   Ready    ca-tor-3   1.31.11_1559* UBUNTU_24_64
* To update to 1.31.11_1560 version, run 'ibmcloud ks worker replace'. Review
and make any required version changes before you update:
'https://ibm.biz/upworker'
```

Remediation:

Using Console:

1. Complete the [prerequisite steps for VPC worker nodes](#).
2. Log in to the IBM Cloud console.
3. Optional: Add capacity to your cluster by resizing the worker pool. The pods on the worker node can be rescheduled and continue running on the added worker nodes during the update.
4. To view a list of your clusters, go to **Menu, Containers, Clusters**.
5. From the clusters page, select your cluster.
6. Select the **Worker Nodes** tab.
7. Select the checkbox for each worker node that you want to update. An action bar is displayed over the table header row.
8. From the action bar, click **Update**.

Using Command Line:

1. Complete the [prerequisite steps for VPC worker nodes](#).
2. Optional: Add capacity to your cluster by resizing the worker pool. The pods on the worker node can be rescheduled and continue running on the added worker nodes during the update.
3. List the worker nodes in your cluster and note the details of the worker node that you want to update.

```
ibmcloud ks worker ls --cluster <cluster_name_or_ID>
```

4. Replace the worker node to update the worker node to the latest patch version at the same **major.minor** version (such as from 1.31.8_1530 to 1.31.9_1533)..


```
ibmcloud ks worker replace --cluster <cluster_name_or_ID> --worker  
<worker_node_ID>
```

Using the **--update** option will update the VPC worker node to the same **major.minor** version as the master (such as from 1.31 to 1.32).

```
ibmcloud ks worker replace --cluster <cluster_name_or_ID> --worker  
<worker_node_ID> --update
```

5. Repeat these steps for each worker node that you want to update.
6. Optional: After the replaced worker nodes are in a Ready status, resize the worker pool to meet the cluster capacity that you want.

Default Value:

Worker nodes are not updated unless the user initiates an update.

References:

1. https://cloud.ibm.com/docs/containers?topic=containers-update&#vpc_worker_node
2. https://cloud.ibm.com/docs/containers?topic=containers-cs_versions#update_types

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	16.5 Use Up-to-Date and Trusted Third-Party Software Components Use up-to-date and trusted third-party software components. When possible, choose established and proven frameworks and libraries that provide adequate security. Acquire these components from trusted sources or evaluate the software for vulnerabilities before use.			
v7	18.4 Only Use Up-to-date And Trusted Third-Party Components Only use up-to-date and trusted third-party components for the software developed by the organization.			

7.1.4 Ensure IBM Cloud Kubernetes Service cluster has image pull secrets enabled (Automated)

Profile Applicability:

- Level 1

Description:

To pull container images from a registry, your IBM Cloud Kubernetes Service cluster uses a special type of Kubernetes secret - an imagePullSecret. This image pull secret stores the credentials to access a container registry.

By default, your cluster is set up to pull images from only your account's namespaces in IBM Cloud Container Registry and deploy containers from these images to the **default** Kubernetes namespace in your cluster.

Rationale:

IBM Cloud Kubernetes Service clusters pull container images from container registries to run containers. If the registry is private, the cluster needs credentials to pull images from it. Because IBM Cloud Kubernetes Service and IBM Cloud Container Registry are often used in tandem, it is important to have image pull secrets for IBM Cloud Container Registry enabled in your cluster.

Impact:

Pull secrets are created in the **default** namespace of your cluster. If you want to pull images to other Kubernetes namespaces, then you must copy the pull secrets to those other namespaces.

Audit:

1. [Login to your VPC cluster](#) and check the image pull secrets by running:

```
kubectl get secrets -n default | grep "icr-io"
```

2. As image pull secrets are automatically added to clusters at creation time, if no icr secrets are listed, the person who created the cluster might not have had the required permissions to IBM Cloud Container Registry.

Remediation:

1. Run the following command to create an IBM Cloud IAM service ID for the cluster, create a policy for the service ID that assigns the Reader service access role in IBM Cloud Container Registry, and then create an API key for the service ID. The API key is then stored in a Kubernetes image pull secret.

Note: This process happens automatically when you create a cluster, but sometimes errors can occur during the cluster creation process.

```
ibmcloud ks cluster pull-secret apply --cluster <cluster_name_or_ID>
```

2. Verify that the image pull secrets are created in your cluster.

```
kubectl get secrets | grep icr-io
```

Default Value:

Image pull secrets are enabled by default unless the user that created the cluster did not have the required permissions for IBM Cloud Container Registry in IAM. Clusters created before 25 February 2019 have token-based image pull secrets rather than API key-based image pull secrets, and therefore must be updated.

References:

1. https://cloud.ibm.com/docs/containers?topic=containers-registry#imagePullSecret_migrate_api_key
2. https://cloud.ibm.com/docs/containers?topic=containers-registry#cluster_registry_auth

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	4.6 Securely Manage Enterprise Assets and Software Securely manage enterprise assets and software. Example implementations include managing configuration through version-controlled-infrastructure-as-code and accessing administrative interfaces over secure network protocols, such as Secure Shell (SSH) and Hypertext Transfer Protocol Secure (HTTPS). Do not use insecure management protocols, such as Telnet (Teletype Network) and HTTP, unless operationally essential.			
v7	5.4 Deploy System Configuration Management Tools Deploy system configuration management tools that will automatically enforce and redeploy configuration settings to systems at regularly scheduled intervals.			

7.1.5 Ensure IBM Cloud Kubernetes Service clusters have the monitoring service enabled (Automated)

Profile Applicability:

- Level 2

Description:

The following recommendation should be considered optional, as while adhering to it would provide enhanced security, IBM Cloud Monitoring is a costed option.

IBM Cloud services, such as IBM Cloud Kubernetes Service, generate platform metrics that you can use to gain operational visibility into the performance and health of the service in your account.

Every Kubernetes master is continuously monitored by the IBM Cloud Kubernetes Service; however, you are responsible for monitoring the rest of your cluster components.

IBM Cloud Monitoring is a cloud-native, container-intelligence management system that can be included as part of your IBM Cloud architecture. It offers administrators, DevOps teams, and developers full-stack telemetry with advanced features to monitor and troubleshoot, define alerts, and design custom dashboards.

With IBM Cloud Monitoring, by deploying a monitoring agent to your worker nodes you can collect cluster and pod metrics, such as the CPU and memory usage of your worker nodes, incoming and outgoing HTTP traffic for your pods, and data about several infrastructure components. In addition, the agent can collect custom application metrics by using either a Prometheus-compatible scraper or a StatsD facade.

Rationale:

Gaining operational visibility into the performance and health of your applications and clusters not only helps you maintain operational continuity but can also act as an early warning system for anomalies caused by security incidents. Monitoring can also help identify patterns of unexpected activity on your applications and clusters, which in turn provide indicators of compromise.

IBM Cloud Monitoring includes alerts and multi-channel notifications that you can use to accelerate your reaction and response time to anomalies, downtime, and performance degradation.

Impact:

While adhering to this recommendation would provide enhanced security, IBM Cloud Monitoring is a costed option. Standard pricing for IBM Cloud Monitoring applies.

Audit:

From Console:

1. Log in to the IBM Cloud console.
2. To view a list of your clusters, go to **Menu, Containers, Clusters**.
3. From the Clusters page, select your cluster.
4. Select the **Overview** tab
5. Under **Integrations**, the **Monitoring** item should have a button to **Launch** the IBM Cloud Monitoring dashboard. If instead the button is labelled **Connect**, then Cloud Monitoring is not enabled.

From Command Line:

1. Verify the status of the monitoring agent in your cluster. You should see one or more running **sysdig-agent** pods, with the number of **sysdig-agent** pods equal to the number of worker nodes in your cluster.

```
kubectl get pods -n ibm-observe
```

Remediation:

From Console:

1. Log in to the IBM Cloud console.
2. To view a list of your clusters, go to **Menu, Containers, Clusters**.
3. From the Clusters page, select your cluster.
4. Select the **Overview** tab
5. Under **Integrations**, go to the **Monitoring** item and click **Connect**.
6. Select the **Monitoring** checkbox and select the IBM Cloud Monitoring instance that you want to use (or **create a new instance**). Click **Save**.

From Command Line:

1. If required, [provision an IBM Cloud Monitoring instance](#).
2. Obtain the access key for the monitoring instance.

```
ibmcloud resource service-key APIKEY_NAME
```

3. Obtain the ingestion URL from the [IBM Cloud Monitoring collector endpoints](#).
4. If the ibm-observe namespace is not available in your cluster, create it with:

```
kubectl create namespace ibm-observe
```

5. Add the Sysdig helm repository.

```
helm repo add sysdig https://charts.sysdig.com
```

6. Update the repos to retrieve the latest versions of all Helm charts.

```
helm repo update
```

7. Verify the Helm chart **sysdig/sysdig-deploy** is listed when listing the helm charts for the **sysdig** repo.

```
helm search repo sysdig
```

8. Define a yaml file and include the values to deploy the IBM Cloud Monitoring agent. The following yaml is a template that you can use, updating the fields as appropriate. More details [available here](#).

```
global:
  clusterConfig:
    name: CLUSTER_NAME
  sysdig:
    accessKey: SERVICE_ACCESS_KEY
agent:
  collectorSettings:
    collectorHost: INGESTION_ENDPOINT
nodeAnalyzer:
  enabled: false
```

9. Run the following command to install the agent by using the Helm chart and the variables yaml file.

```
helm install -n ibm-observe sysdig-agent sysdig/sysdig-deploy -f <agent-values yaml file>
```

10. Verify that the monitoring agent is created successfully.

```
kubectl get pods -n ibm-observe
```

Default Value:

IBM Cloud Monitoring is not enabled by default.

References:

1. <https://cloud.ibm.com/docs/containers?topic=containers-monitoring>
2. https://cloud.ibm.com/docs/monitoring?topic=monitoring-kubernetes_cluster
3. <https://cloud.ibm.com/docs/monitoring?topic=monitoring-agent-deploy-kube-helm>
4. <https://cloud.ibm.com/observability/catalog/ibm-cloud-monitoring>

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	8.2 <u>Collect Audit Logs</u> Collect audit logs. Ensure that logging, per the enterprise's audit log management process, has been enabled across enterprise assets.	●	●	●
v8	13.1 <u>Centralize Security Event Alerting</u> Centralize security event alerting across enterprise assets for log correlation and analysis. Best practice implementation requires the use of a SIEM, which includes vendor-defined event correlation alerts. A log analytics platform configured with security-relevant correlation alerts also satisfies this Safeguard.		●	●
v8	13.11 <u>Tune Security Event Alerting Thresholds</u> Tune security event alerting thresholds monthly, or more frequently.			●
v7	6.2 <u>Activate audit logging</u> Ensure that local logging has been enabled on all systems and networking devices.	●	●	●
v7	6.6 <u>Deploy SIEM or Log Analytic tool</u> Deploy Security Information and Event Management (SIEM) or log analytic tool for log correlation and analysis.		●	●

7.1.6 Ensure IBM Cloud Kubernetes Service clusters have the logging service enabled (Manual)

Profile Applicability:

- Level 2

Description:

The following recommendation should be considered optional, as while adhering to it would provide enhanced security, IBM Cloud Logs is a costed option.

By default, logs are generated and written locally for all the following IBM Cloud Kubernetes Service cluster components: worker nodes, containers, applications, persistent storage, Ingress application load balancer, Kubernetes API, and the **kube-system** namespace.

IBM Cloud Logs supports integration with common workload environments on IBM Cloud - including IBM Cloud Kubernetes Service - and provides observability services so you can view, analyze, and alert on activity tracking events and logging activity.

A logging agent collects logs with the extension ***.log** and extensionless files that are stored in the **/var/log/containers** directory of your pod from all namespaces, including **kube-system**. The agent then forwards the logs to your service IBM Cloud Logs instance. You can also track user-initiated administrative activity made in your cluster. Kubernetes Service automatically generates cluster management events and forwards these event logs to IBM Cloud Logs.

Rationale:

Logging is the foundation on which security monitoring and situational awareness are built, as logging is pivotal in identifying - and thus addressing - security risks. This is because logs record a richness of data about activity, changes, requests, interactions, connections, etc. In addition, logging data can be used to investigate performance issues, provide administrative alerts, and help verify that organisational policies are working as intended.

However, as workloads generate an expanding amount of observability data, pressure is increasing on collection tools to process it all. The data becomes expensive to manage and makes it harder to detect signal in the noise and obtain actionable insights. IBM Cloud Logs is designed to help users take control of their observability data and expedite insights to reduce application downtime, recover quickly from incidents, and develop your defences.

Impact:

While adhering to this recommendation would provide enhanced security, IBM Cloud Logs is a costed option. Standard pricing for IBM Cloud Logs applies.

Audit:

From Console:

1. Log in to the IBM Cloud console.
2. To view a list of your clusters, go to **Menu, Containers, Clusters**.
3. From the Clusters page, select your cluster.
4. Select the **Overview** tab
5. Under **Integrations**, the **Logging** item should have a button to **Launch** the IBM Cloud Log dashboard. If instead the button is labelled **Connect**, then logging is not enabled.

From Command Line:

1. Check that a daemonset logs-agent exists in the namespace **ibm-observe**.

```
kubectl get ds -n ibm-observe
```

2. Verify the log agents are started.

```
kubectl -n ibm-observe get ds logs-agent
```

3. Verify that a logs-agent pod is ready for each node in your cluster.

```
kubectl get pods -n ibm-observe -o wide
```

4. Optionally: view the logs of a pod.

```
kubectl logs <POD_NAME> -n ibm-observe
```

Remediation:

From Console:

1. Log in to the IBM Cloud console.
2. To view a list of your clusters, go to **Menu, Containers, Clusters**.
3. From the Clusters page, select your cluster.
4. Select the **Overview** tab
5. Under **Integrations**, go to the **Logging** item and click **Connect**.
6. Select the IBM Cloud Logs instance that you want to use (or **create a new instance**). Click **Connect**.

From Command Line:

The following steps deploy the agent using a service ID API key. You can also deploy the agent using a trusted profile. For more information, see [Deploying the Logging agent for Kubernetes clusters using a Helm chart](#).

1. If required, follow the steps at [create some buckets to store your data](#) to create new IBM Cloud Object Storage buckets.
2. If required, follow the steps in provisioning an instance to set up an IBM Cloud Logs instance.
3. Create a service ID.

```
ibmcloud iam service-id-create kubernetes-logs-agent --description "Service ID for sending logs from IKS"
```

4. Grant the **Sender** role for IBM Cloud Logs to the created service ID.

```
ibmcloud iam service-policy-create kubernetes-logs-agent --service-name logs --roles Sender
```

5. Create an IAM API key by running the following command. You can customize the key name (**kubernetes-logs-agent-apikey**) and description (**--d**) if needed.

```
ibmcloud iam service-api-key-create kubernetes-logs-agent-apikey kubernetes-logs-agent --description "API key for sending logs to the IBM Cloud Logs service"
```

6. Determine the logging ingestion endpoint for your IBM Cloud Logs instance.

```
ibmcloud resource service-instances --service-name logs --long --output JSON | jq '[] | {name: .name, id: .id, region: .region_id, ingestion_endpoint: .extensions.external_ingress}]'
```

7. Define a yaml file and include the values to deploy the IBM Cloud Logs agent daemonset. The following yaml is a template that you can use, updating the fields as appropriate. More details [available here](#).

```

metadata:
  name: "logs-agent"
image:
  version: "1.6.1" # required

clusterName: "ENTER_CLUSTER_NAME" # Enter the name of your cluster. This
information is used to improve the metadata and help with your filtering.

env:
  # ingestionHost is a required field. For example:
  # ingestionHost: "<logs instance>.ingress.us-east.logs.cloud.ibm.com"
  ingestionHost: "" # required

  # If you are using private CSE proxy, then use port number "3443"
  # If you are using private VPE Gateway, then use port number "443"
  # If you are using the public endpoint, then use port number "443"
  ingestionPort: "" # required

  iamMode: ""
  # trustedProfileID - trusted profile id - required for iam trusted profile
mode
  trustedProfileID: "Profile-yyyyyyyyyy-xxxx-xxxx-yyyy-zzzzzzzzzzzz" # required
if iamMode is set to TrustedProfile

```

8. Log in to the cluster. For more information, see [access your cluster](#).
9. Perform a Helm dry run to see the resources that will be created by the Helm chart. If you are using the **iamMode=IAMAPIKey** then the complete command is:

```

helm install <install-name> --dry-run oci://icr.io/ibm-observe/logs-agent-helm --
helm --version <chart-version> --values <PATH>/logs-values.yaml -n ibm-
observe --create-namespace --set secret.iamAPIKey=<APIKey-value> --hide-
secret

```

10. Once the resources to be created are verified, then run the Helm install without the --dry-run option. If you are using the iamMode=IAMAPIKey then the complete command is:

```

helm install <install-name> oci://icr.io/ibm-observe/logs-agent-helm --
version <chart-version> --values <PATH>/logs-values.yaml -n ibm-observe --
create-namespace --set secret.iamAPIKey=<APIKey-value>

```

11. Verify the log agents are started.

```

kubectl -n ibm-observe get ds logs-agent

```

12. Verify that a logs-agent pod is ready for each node in your cluster.

```
kubectl get pods -n ibm-observe -o wide
```

13. [Go to the web UI for your IBM Cloud Logs instance](#) and verify logs are being delivered to your target destination by querying for log records tagged with `kubernetes.cluster_name:<CLUSTER_NAME>`.

Default Value:

By default, logs are generated and written locally for all the following IBM Cloud Kubernetes Service cluster components: worker nodes, containers, applications, persistent storage, Ingress application load balancer, Kubernetes API, and the `kube-system` namespace.

However, by default the logging service for collecting, forwarding, and viewing these logs to IBM Cloud Logs is not enabled for IBM Cloud Kubernetes Service clusters.

References:

1. <https://cloud.ibm.com/docs/containers?topic=containers-logging>
2. <https://cloud.ibm.com/docs/cloud-logs?topic=cloud-logs-agent-helm-kube-deploy>
3. <https://cloud.ibm.com/catalog/services/cloud-logs>

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	8.2 Collect Audit Logs Collect audit logs. Ensure that logging, per the enterprise's audit log management process, has been enabled across enterprise assets.			
v8	8.5 Collect Detailed Audit Logs Configure detailed audit logging for enterprise assets containing sensitive data. Include event source, date, username, timestamp, source addresses, destination addresses, and other useful elements that could assist in a forensic investigation.			
v7	6.2 Activate audit logging Ensure that local logging has been enabled on all systems and networking devices.			
v7	6.3 Enable Detailed Logging Enable system logging to include detailed information such as an event source, date, user, timestamp, source addresses, destination addresses, and other useful elements.			

8 Security and Compliance

With IBM Cloud® Security and Compliance Center, you can embed security checks into your every day workflows to help monitor for security and compliance. By monitoring for risks, you can identify security vulnerabilities and quickly work to mitigate the impact and fix the issue.

8.1 Key Management

8.1.1 IBM Key Protect for IBM Cloud

IBM® Key Protect for IBM Cloud™ helps you provision encrypted keys for apps across IBM Cloud services.

From the Key Protect dashboard, you can create new keys for cryptography, or you can import your existing keys.

Choose from two key types:

Root keys

Root keys are symmetric key-wrapping keys that you fully manage in Key Protect. You can use a root key to protect other cryptographic keys with advanced encryption. To learn more, see [Protecting data with envelope encryption](#).

Standard keys

Standard keys are symmetric keys that are used for cryptography. You can use a standard key to directly encrypt and decrypt data.

8.1.1.1 Ensure IBM Key Protect has automated rotation for customer managed keys enabled (Automated)

Profile Applicability:

- Level 2

Description:

IBM® Key Protect for IBM Cloud® allows you to rotate your root key (CRK) which is the key material created within the KMS Hardware Security Module (HSM) when you created the root key using KP APIs. This CRK is used to encrypt the Data Encryption Key (DEK) that is used to encrypt your data. By encrypting the DEK (wDEK), wDEK can be stored with the data.

It is a best practice to rotate your CRK (that is, to create a new version of the key) on a regular basis. Regular rotations reduce what is known as the "cryptoperiod" of the key and can also be used in specific cases such as personnel turnover, process malfunctions, or the detection of a security issue.

You can set a rotation interval on the CRK or manually rotate the CRK based on your organization policy.

When it's time to rotate the key based on the rotation interval that you specify, Key Protect automatically creates a new root key in the HSM. Automated key rotation currently retains all prior CRK key versions so that only decryption of encrypted data with the older version of the CRK can take place transparently.

Frequency of key rotation After you generate a root key in Key Protect, you decide the frequency of its rotation. You might want to rotate your keys due to personnel turnover, process malfunction, or according to your organization's internal key expiration policy. Rotate your keys regularly, for example every 30 days, to meet cryptographic best practices.

Rationale:

Rotating keys on a regular basis helps you meet industry standards and cryptographic best practices. The following describes the main benefits of key rotation:

- **Cryptoperiod management for keys** - Key rotation limits how long your information is protected by a single key. By rotating your root keys at regular intervals, you also shorten the cryptoperiod of the keys. The longer the lifetime of an encryption key, the higher the probability for a security breach.
- **Incident mitigation** - If your organization detects a security issue, you can immediately rotate the key to mitigate or reduce costs that are associated with key compromise.

Impact:

After CRK is rotated, to secure your envelope encryption workflow, rewrap your DEKs after you rotate a root key so that your at-rest data is protected by the newest root key.

Alternatively, if Key Protect detects that you're using retired key versions to unwrap a DEK, the service automatically re-encrypts the DEK and returns a wrapped data encryption key (WDEK) that's based on the latest root key.

Audit:

Using Console:

1. Log in to the IBM Cloud® console.
2. Go to **Menu, Resource List** to view a list of your resources.
3. From your IBM Cloud resource list, click on **Security** select your provisioned instance of Key Protect.
4. On the left-hand panel, click on **Policies** and view the **rotation policy** enabled for the instance
5. If the rotation policy is not enabled, you can view rotation policy set per key by clicking **keys** on the left-hand panel
6. From the list of keys displayed, you can click on overflow menu (three dots) at the end of the key to view the rotation policy for the key

Using API:

You can view automatic rotation policy using GET call to the following endpoint.

<https://<region>.kms.cloud.ibm.com/api/v2/keys/{id}/policies>

API: For a high-level view, you can browse the rotation policies that are associated with a key by making a GET call to the following endpoint.

https://<region>.kms.cloud.ibm.com/api/v2/keys/<key_ID>/policies

1. Retrieve your service and authentication credentials.
2. Retrieve the rotation policy for a specified key by running the following cURL command.

```
$ curl -X GET \
  "https://<region>.kms.cloud.ibm.com/api/v2/keys/<key_ID>/policies" \
  -H "authorization: Bearer <IAM_token>" \
  -H "bluemix-instance: <instance_ID>" \
  -H "content-type: application/vnd.ibm.kms.policy+json" \ -H "correlation-id: <correlation_ID>"
```

Remediation:

Using Console:

1. Log in to the IBM Cloud console.
2. Go to **Menu, Resource List** to view a list of your resources.

3. From your IBM Cloud resource list, select your provisioned instance of Key Protect.
4. On the application details page, use the Keys table to browse the keys in your service. If you have many keys, you can narrow your search by using the search bars to only search for enabled keys (since other kinds of keys cannot be rotated), keys in a particular key ring, and keys with a particular alias.
5. Once the key has been found, click the overflow menu (three dots) to open a list of options for the key that you want to rotate.
6. From the options menu, click **Rotate** to open the Rotation side panel.
7. If your rotation policy is Enabled, you can edit this policy by changing the number of months selected. This will set the 30-day interval for your root key. If a key is set to be rotated every 2 months, for example, it will be rotated every 60 days, regardless of the number of days in a particular month. If your rotation policy is Disabled, and the key was created at a time when your instance had a rotation policy, a rotation interval number can be seen. This is the rotation policy that was written to your key in a Disabled state at key creation time. You can also change the rotation interval at this time.
8. Click **Set policy**. The policy is now in effect.

If you want to rotate the key immediately, click **Rotate key**. Note: these actions are not mutually exclusive. If your key has an existing rotation policy, the interface displays the key's existing rotation period.

Using API:

Create or update a rotation policy for your root key by making a PUT call to the following endpoint. https://<region>.kms.cloud.ibm.com/api/v2/keys/<key_ID>/policies

Create or update a rotation policy for a specified key by running the following cURL command.

```
curl -X PUT
https://<region>.kms.cloud.ibm.com/api/v2/keys/<key_ID_or_alias>/policies -
H 'authorization: Bearer <IAM_token>' -H 'bluemix-instance: <instance_ID>'
-H 'content-type: application/vnd.ibm.kms.policy+json' -d '{
  "metadata": {
    "collectionType": "application/vnd.ibm.kms.policy+json",
    "collectionTotal": 2
  },
  "resources": [
    {
      "type": "application/vnd.ibm.kms.policy+json",
      "rotation": {
        "enabled": <true|false>,
        "interval_month": <rotation_interval>
      }
    },
    {
      "type": "application/vnd.ibm.kms.policy+json",
      "dualAuthDelete": {
        "enabled": <true|false>
      }
    }
  ]
}'
```

Default Value:

By default, IBM Cloud accounts depend on the account admin or Key Management admin to set key rotation policy.

References:

1. <https://cloud.ibm.com/docs/key-protect?topic=key-protect-key-rotation>
2. <https://cloud.ibm.com/docs/key-protect?topic=key-protect-set-rotation-policy>
3. <https://cloud.ibm.com/docs/key-protect?topic=key-protect-view-key-versions>
4. <https://cloud.ibm.com/docs/key-protect?topic=key-protect-rotate-keys>
5. <https://cloud.ibm.com/docs/key-protect?topic=key-protect-cli-reference#kp-key-policies>
6. <https://cloud.ibm.com/docs/key-protect?topic=key-protect-cli-reference#kp-key-policy-update-rotation>

Additional Information:

Check whether Key Protect encryption keys are rotated at least 2 months

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.11 <u>Encrypt Sensitive Data at Rest</u> Encrypt sensitive data at rest on servers, applications, and databases containing sensitive data. Storage-layer encryption, also known as server-side encryption, meets the minimum requirement of this Safeguard. Additional encryption methods may include application-layer encryption, also known as client-side encryption, where access to the data storage device(s) does not permit access to the plain-text data.			
v7	14.8 <u>Encrypt Sensitive Information at Rest</u> Encrypt all sensitive information at rest using a tool that requires a secondary authentication mechanism not integrated into the operating system, in order to access the information.			

8.1.1.2 Ensure Keys in the IBM Cloud® Key Protect Service are configured for high availability (Manual)

Profile Applicability:

- Level 1

Description:

IBM® Key Protect for IBM Cloud® is a highly available, regional service with multiple availability zones and automatic features that help keep your applications secure and operational. Within a region high availability is achieved through routing traffic to other availability zones if one zone is down.

High Availability across regions can be achieved by two ways.

Dynamic cross-region high availability:

There are three regions, us-south (located in Dallas, Texas, United States), jp-tok (located in Tokyo, Japan), and eu-de (located in Frankfurt, Germany) where Key Protect has failover support into a separate region where data is replicated into standby infrastructure (fail-over region) if you select the Cross-region plan. This allows your keys are available in another region if the primary region goes down. In the event primary region goes down, your requests are routed to the fail-over region transparently, therefore you can continue to call same endpoint without any disruption.

Manual cross-region high availability:

In case if you cannot use any of these three regions, you can still achieve high availability, however it is your responsibility to own the process to achieve high availability for the keys. The process involves you creating a Key Protect instance in two different regions and import same root key in both regions. Because keys created using the same key material are effectively identical, either key can be used to wrap or unwrap any data encryption keys (DEKs). Note that the Key Protect endpoint, instance id and key id are different in each region, so you need to change the endpoint, instance id and key id when you switch using the other region. Also, every time a root key is rotated, new key material is added to the key, which creates a new version of the key. Therefore, import the rotated key into Key Protect in both regions. This process works only for Bring Your Own Key (root key).

Rationale:

Accessing your data requires decryption of the Data Encryption Key using Root Key, it is critical to have high availability feature for the root key. High availability of the key management service is necessary for both load balancing and fault tolerance.

Disaster recovery is about surviving a catastrophic failure or loss of availability in a single location. Key Protect takes care of disaster recovery for your keys automatically in cross-regions supported Key Protect service.

Impact:

By using high availability and disaster recovery feature, your application and services can run without disruption in the event of one region going down preventing denial of service.

Audit:

To check if a of Key Protect instance is provisioned in one of the cross-regions supported Key Protect Service, complete the following steps.

Using Console:

1. Log in to the IBM Cloud® console.
2. Go to **Menu, Resource List** to view a list of your resources.
3. From your IBM Cloud resource list, click on **Security** select to view all your provisioned Key Protect instances.
4. Click on instance you want to check cross-region high availability
5. Click on the endpoints on the left-hand panel and verify if the region in the endpoint is one of the regions that has cross-region high availability.

Remediation:

To get a list of Key Protect instances from the IBM Cloud console, complete the following steps. Log in to your IBM Cloud account.

Using Console:

1. Click **Catalog** to view the list of services that are available on IBM Cloud.
2. From the All-Categories navigation pane, click the **Security and Identity** category.
3. From the list of services, click the **Key Protect** tile.
4. Select a service plan, and click **Create** to provision an instance of Key Protect in the account, region that has cross-region support, and resource group where you are logged in.

Default Value:

By default, IBM Cloud Key Protect Service with cross-region provides High Availability. In the regions where cross-region is supported,

It is the customer discretion to configure HA according to their needs.

References:

1. <https://cloud.ibm.com/docs/key-protect?topic=key-protect-provision>
2. <https://cloud.ibm.com/docs/key-protect?topic=key-protect-regions>
3. <https://cloud.ibm.com/docs/key-protect?topic=key-protect-ha-dr>

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	11.2 <u>Perform Automated Backups</u> Perform automated backups of in-scope enterprise assets. Run backups weekly, or more frequently, based on the sensitivity of the data.			
v7	10.1 <u>Ensure Regular Automated Back Ups</u> Ensure that all system data is automatically backed up on regular basis.			

8.1.1.3 Ensure all data stores are encrypted in the IBM Cloud® (Manual)

Profile Applicability:

- Level 1

Description:

When you provision any data services in the IBM Cloud, such as Cloud Object Storage, Databases such as PostgreSQL, MongoDB, database for Elasticsearch, ETCD, backups created for any data store, and data volumes for compute etc., you want to encrypt the data-at-rest with your root key that you created in Key Protect key management service. You can use Bring Your Own Key (CRK) or provider key to enable encryption of your data-at-rest in data store associated with any of the services in the IBM Cloud that is integrated with the Key Protect Service.

Rationale:

By encrypting your data with your own root key or service provided root key, you are protecting your data from unwanted access to your data. Even if the data is accessed, attacker cannot view the data as the encryption key is not stored with the data

Impact:

Once you provide your root key (CRK) to the IBM Cloud Service where your data is stored, the service will use your root key to decrypt the Data Encryption Key, that is used to encrypt your data by the service, when you access your data. You need to have the required role to do this operation.

Audit:

Using Console:

1. Log in to the IBM Cloud® console.
2. Go to **Menu, Resource List** to view a list of your resources.
3. From your IBM Cloud resource list, click on **Storage**
4. From the list of Cloud Object Storage instances, click on one of the Instances
5. Cloud Object Storage dashboard shows a list of created buckets in that instance
6. Click on a bucket name to look at the details
7. Click on **Key Management** to see if the bucket is encrypted with an encryption key

Remediation:

After you designate a root key in Key Protect and grant access between your services, you can enable envelope encryption for a specified storage bucket by using the IBM Cloud Object Storage GUI.

Tip: To enable advanced configuration options for your storage bucket, ensure that an authorization exists between your IBM Cloud Object Storage and Key Protect instances.

Using Console:

To add envelope encryption to your storage bucket:

1. From your IBM Cloud® Object Storage dashboard, click **Create bucket**.
2. Specify the bucket's details.
3. In the **Advanced Configuration** section, select **Add Key Protect Keys**.
4. From the list of Key Protect service instances, select the instance that contains the root key that you want to use for key wrapping.
5. For Key Name, select the alias of the root key.
6. Click **Create** to confirm the bucket creation.

From the IBM Cloud® Object Storage GUI, you can browse the buckets that are protected by a Key Protect root key.

Default Value:

User has to select encryption at the data source service.

References:

1. <https://cloud.ibm.com/docs/solution-tutorials?topic=solution-tutorials-cloud-e2e-security>
2. <https://cloud.ibm.com/docs/key-protect?topic=key-protect-integrate-services>
3. <https://cloud.ibm.com/docs/key-protect?topic=key-protect-integrate-services#grant-access>
4. <https://cloud.ibm.com/docs/key-protect?topic=key-protect-integrate-cos>

Additional Information:

1. Check whether Databases for PostgreSQL are encrypted with customer managed keys
2. Check whether Databases for PostgreSQL backups are encrypted with customer-managed keys
3. Check whether Databases for MongoDB are encrypted with customer-managed keys
4. Check whether Databases for MongoDB backups are encrypted with customer-managed keys
5. Check whether Databases for Redis are encrypted with customer-managed keys
6. Check whether Databases for Redis backups are encrypted with customer-managed keys
7. Check whether Databases for Elasticsearch are encrypted with customer-managed keys
8. Check whether Databases for Elasticsearch backups are encrypted with customer-managed keys

9. Check whether data disks are encrypted with customer-managed keys
10. Check whether Virtual Servers for VPC boot volumes are encrypted with customer-managed keys
11. Check whether OS disks are encrypted with customer-managed keys
12. Check whether Kubernetes Service Cluster is enabled with customer-managed encryption
13. Check whether Event Streams is enabled with customer-managed encryption
14. Check whether Databases for MySQL is enabled with encryption
15. Check whether IBM Activity Tracker logs are encrypted at rest
16. Check whether Block Storage Snapshots for VPC is enabled with customer-managed encryption
17. Check whether Virtual Servers for VPC data volumes are enabled with customer-managed encryption
18. Check whether Virtual Servers for VPC boot volumes are enabled with customer-managed encryption

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.11 <u>Encrypt Sensitive Data at Rest</u> Encrypt sensitive data at rest on servers, applications, and databases containing sensitive data. Storage-layer encryption, also known as server-side encryption, meets the minimum requirement of this Safeguard. Additional encryption methods may include application-layer encryption, also known as client-side encryption, where access to the data storage device(s) does not permit access to the plain-text data.		●	●
v7	14.8 <u>Encrypt Sensitive Information at Rest</u> Encrypt all sensitive information at rest using a tool that requires a secondary authentication mechanism not integrated into the operating system, in order to access the information.			●

8.2 IBM Cloud Secrets Manager

IBM Cloud® Secrets Manager is a single tenant, dedicated service that is managed by both you and IBM Cloud to secure and centrally manage your secrets such as credentials, certificates etc., With Secrets Manager, you can create, lease, and centrally manage secrets that are used in IBM Cloud services or your custom-built applications. Secrets are stored in a dedicated Secrets Manager instance, built on HashiCorp Vault.

8.2.1 Ensure certificates imported into or generated through IBM Cloud® Secrets Manager are automatically renewed before expiration (Automated)

Profile Applicability:

- Level 1

Description:

You can use the IBM Cloud Secrets Manager service dashboard to set the renewable period for the certificates that you manage in the Secrets Manager service. Private certificates generated through Secrets Manager are rotated by replacing existing certificate value with new certificate version. Public certificates generated in Secrets Manager are moved to Active, Rotation Pending status to indicate that the request to renew the certificate is being processed. Secrets Manager does DNS validation to verify that you own the domain listed in the certificate, if succeeded, Secrets Manager gets a new certificate and status changes back to Active. if validation failed, the status of the certificate changes to Active, Rotation failed.

Rationale:

Cloud applications and services running on the platform might use certificate for different purposes - TLS or mTLS, client/server authentication and more. Ensuring your certificates are stored securely, and renewed before they expired is crucial to maintaining high security posture.

Impact:

Without proper Certificate Management practices in place organization risk to be vulnerable to impersonation attacks in case certificates used for authentication will be leaked and service outages in case certificates are not renewed on time.

Audit:

Using Console:

1. You can view the certificate renewal settings such as expiration date, rotation interval or state
2. Log in to the IBM Cloud® console.
3. Go to **Menu**, **Resource List** to view a list of your resources.
4. Click on **Security** and click on the Secrets Manager instance that you want to use
5. In the **Secrets** table, click the Actions menu to open a list of options for your secret
6. To view the secret value, click **Details**

To download a certificate by using Secrets Manager UI, complete the following steps

1. In the Secrets table, open the **overflow** menu for the certificate that you want to download
2. Click **Download**, the certificate file is downloaded to your local system

Remediation:

Using Console:

1. Log in to the IBM Cloud® console.
2. Go to **Menu**, **Resource List** to view a list of your resources.
3. Click on **Security** and click on the Secrets Manager instance that you want to use
4. If you're ordering a public certificate, enable the rotation options.
 - a. To rotate the certificate automatically, switch the rotation toggle to **On**. Your certificate is automatically reordered 31 days before its expiration date.
 - b. To request a new private key for the certificate on each rotation, switch the rekey toggle to **On**.
5. If you're editing an existing public certificate, schedule automatic rotation by updating its details.
 - a. In the **Secrets** table, view a list of your existing Public certificates.
 - b. In the row for the certificate that you want to edit, click the **Actions** menu, **Edit details**
 - c. Use the **Automatic rotation** option to add or remove a rotation policy for the secret
6. If you're creating private certificates, enable the rotation options.
 - a. To rotate the certificate automatically, switch the rotation toggle to **ON**
 - b. Select an interval and unit that specifies the number of days between scheduled rotations. Note: Note: Depending on the certificate template that is associated with your private certificate, some restrictions on the rotation interval for the certificate might apply. For example, the rotation interval can't exceed the time-to-live (TTL) that is defined in the template. For more information, see Certificate templates.
7. If you're editing an existing private certificate, schedule automatic rotation by updating its details.
 - a. In the Secrets table, view a list of your existing Private certificates.
 - b. In the row for the certificate that you want to edit, click the **Actions** menu, **Edit details**
 - c. Use the **Automatic rotation** option to add or remove a rotation policy for the secret

References:

1. <https://cloud.ibm.com/docs/secrets-manager?topic=secrets-manager-automatic-rotation&interface=ui>
2. <https://cloud.ibm.com/docs/secrets-manager?topic=secrets-manager-access-secrets&interface=cli>
3. <https://cloud.ibm.com/docs/secrets-manager?topic=secrets-manager-access-secrets&interface=api>

Additional Information:

Check whether certificates in Secrets Manager are automatically renewed before expiration

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.10 <u>Encrypt Sensitive Data in Transit</u> Encrypt sensitive data in transit. Example implementations can include: Transport Layer Security (TLS) and Open Secure Shell (OpenSSH).			
v7	14.4 <u>Encrypt All Sensitive Information in Transit</u> Encrypt all sensitive information in transit.			

8.2.2 Ensure access settings to secrets follow least privilege rule and allow access for a limited time to applications and non-administrative users as needed (Manual)

Profile Applicability:

- Level 1

Description:

You can enable different levels of access to IBM Cloud® Secrets Manager resources in your IBM Cloud account by creating and modifying IBM Cloud IAM access policies. As an account owner, determine an access policy type for users, service IDs, and access groups based on your internal access control requirements. For example, if you want to grant user access to Secrets Manager at the most minimal scope available, you can assign access to a secret group in an instance.

Review your IAM settings to confirm that permissive access to the Secrets Manager service is not allowed. Grant access to secrets for non-administrative users and applications only for the duration necessary to complete their tasks and promptly revoke access when it is no longer required.

Limit access to specific Secrets Manager instances or secret groups and assign only the minimum service role necessary for the required operations. Additionally, you can configure custom IAM roles to restrict access to a specific set of Secrets Manager actions tailored to a workload's needs.

Rationale:

Adopting least privilege rule improves organizations security posture and using secrets that are valid only for a limited time reduces blast radius. Also using secrets groups to assign needed access enables to follow least privilege strategy.

Impact:

Controlled access to secrets as needed for a limited time enables automation of applications and services seamlessly use secrets.

Audit:

Using Console:

1. Log in to the IBM Cloud® console.
2. Go to **Manage, Access (IAM)** and assign access to your Secrets Manager instance:

- a. Create an access group for the users and service IDs that you want to give access to and add those users to the access group in IAM. For example, you might have a group of security admins that might need the same level of access.
 - b. After you create an access group and add users, go to **Manage, Access (IAM), Access Groups**.
 - c. Select a table row and click the Actions menu to open a list of options for that access group.
 - d. Click **Assign Access**.
 - e. From the list of services, select **Secrets Manager** and click **Next**.
 - f. In the Resources section, select Specific resources. Choose a region and Secrets Manager service instance. Then, click **Next**. If you choose not to provide a specific instance, access is assigned for all instances of the service within the region that you selected. If you choose not to select a region, access is granted for all instances of the service in your account. Choose a combination of platform and service access roles to assign access for access group.
 - g. Review your selections and click **Add**.
 - h. Click **Assign**.
 - i. Now you can add users and service IDs to the access group so that you can assign access to Secrets Manager with a single access policy. For more information, see Setting up access groups.
3. Go to **Menu, Resource list** to view a list of your resources.
 4. Click on **Security** and click on the Secrets Manager instance that you want to use.
 5. Assign access to a secret group.
 - a. In the navigation, click **Secret groups**.
 - b. Use the Secret groups table to browse the groups in your instance.
 - c. In the row of the group that you want to manage, click the Actions menu **Manage access**.
 - d. Select an access group to give its contained users and service IDs access to your secret group.
 - e. Choose a combination of access roles to assign.
 - f. Click **Review**.
 - g. Review your selections and click **Assign**.

Remediation:

Using Console:

Remove a user from an Access Group

1. Log in to the IBM Cloud® console.
2. Go to **Manage, Access (IAM), Access Groups**
 - a. Select your Access Group and click the Actions menu to open a list of options for that access group.
 - b. Click **Manage group**.
 - c. Select the user you would like to remove and click the Actions menu to remove it.

Default Value:

User has to set access controls to secrets.

References:

1. <https://cloud.ibm.com/docs/account?topic=account-custom-roles&interface=ui>
2. <https://cloud.ibm.com/docs/secrets-manager?topic=secrets-manager-assign-access&interface=ui>
3. https://cloud.ibm.com/docs/account?topic=account-groups&interface=ui#create_ag

Additional Information:

1. Check whether permissive access is given to Secrets Manager service
2. Check whether Secrets Manager default secret group contains no secrets

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	6 Access Control Management Use processes and tools to create, assign, manage, and revoke access credentials and privileges for user, administrator, and service accounts for enterprise assets and software.			
v7	4 Controlled Use of Administrative Privileges Controlled Use of Administrative Privileges			

Controls Version	Control	IG 1	IG 2	IG 3
v7	<u>4.5 Use Multifactor Authentication For All Administrative Access</u> Use multi-factor authentication and encrypted channels for all administrative account access.		●	●

8.2.3 Ensure notification service is enabled in the IBM Cloud Secrets Manager to notify life cycle events (Manual)

Profile Applicability:

- Level 2

Description:

Secrets stored in the Secrets Manager go through life-cycle changes, as an administrator of your Secrets Manager instance, you may want to notify your users, applications through available delivery channels such as email, SMS etc., or through event-driven programming using webhooks.

Rationale:

Ensuring all secrets life cycle management is handled on-time to ensure users are not locked out and applications run without disruptions.

Impact:

Relevant personal gets notification and take action.

Additional cost may be incurred by enabling notification services.

Audit:

Using Console:

1. Log in to the IBM Cloud® console.
2. Go to **Menu, Resource List** to view a list of your resources.
3. Click on **Security** and click on the Secrets Manager instance that you want to use
4. Click on **Settings** on the left-hand panel to check if event notification is configured for the instance.

Remediation:

Using Console:

1. Log in to the IBM Cloud® console.
2. Go to **Menu, Resource List** to view a list of your resources.
3. Click on **Security** and click on the Secrets Manager instance that you want to use
4. In the Secrets Manager navigation, click **Settings**.
5. In the Event Notifications section and click **Connect**.
6. In the side panel, review the source details for the connection.

7. Select the resource group and Event Notifications service instance that you want to connect.
8. To confirm the connection, click `Connect`.
9. A success message is displayed to indicate that Secrets Manager is now connected to Event Notifications.

If an IAM authorization between Secrets Manager and Event Notifications doesn't exist in your account, a dialog is displayed. Follow the prompts to grant access between the services.

1. To grant access between Secrets Manager and Event Notifications, click **Authorize**.
2. In the side panel, select **Event Notifications** as the target service.
3. From the list of instances, select the Event Notifications service instance that you want to authorize.
4. Select the **Event Source Manager** role.
5. Click **Review**.
6. Click **Assign**.

Default Value:

Event Notification is not enabled by default.

References:

1. <https://cloud.ibm.com/docs/secrets-manager?topic=secrets-manager-event-notifications&interface=ui>

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	13.1 Centralize Security Event Alerting Centralize security event alerting across enterprise assets for log correlation and analysis. Best practice implementation requires the use of a SIEM, which includes vendor-defined event correlation alerts. A log analytics platform configured with security-relevant correlation alerts also satisfies this Safeguard.			
v8	13.11 Tune Security Event Alerting Thresholds Tune security event alerting thresholds monthly, or more frequently.			

8.2.4 Ensure secrets stored in the IBM Cloud® Secrets Manager are rotated periodically (Automated)

Profile Applicability:

- Level 2

Description:

As you use Secrets Manager to design your secrets management strategy, consider how often you want to rotate your secrets based on the internal guidelines for your organization. Determine ahead of time which users or service IDs require access to rotate secrets, and how those secrets can be rotated to avoid interruptions to your applications.

By scheduling automatic rotation of secrets at regular intervals, you reduce the likelihood of compromised credentials. When it's time to rotate the secret based on the rotation interval that you specify, Secrets Manager automatically creates a new version of your secret. You can safely delete old version of the secrets only after their newest versions are fully deployed to your applications. If any secrets are in use, you can use Secrets Manager LOCK feature to lock the secrets from getting deleted.

Rationale:

Rotating secrets enables to meet your internal and external regulatory requirements. Compromised secrets can be removed by rotating secrets.

Impact:

Rotated secrets (new version) need to be updated in the applications, services that are using the secrets to avoid interruptions to applications and services functioning.

Additional cost may be incurred by scheduling automatic rotation of secrets

Audit:

Using Console:

1. Log in to the IBM Cloud® console.
2. Go to **Menu**, **Resource List** to view a list of your resources.
3. Click on **Security** and click on the Secrets Manager instance that you want to view
4. In the Secrets table, click the Actions menu to open a list of options for your secret
5. To view the secret value, click **View Secret**
6. Click **Confirm** after you ensure that you are in a safe environment
7. To retrieve a secret's details such as rotation interval or state; In the Secrets table, click the Actions menu, to open a list of options for your secret
8. To view the secret value, click **Details**.

Remediation:

Using Console:

1. Log in to the IBM Cloud® console.
2. Go to **Menu**, **Resource List** to view a list of your resources.
3. Click on **Security** and click on the Secrets Manager instance that you want to use
4. If you're adding a secret, enable the **rotation** option.
5. If you're editing an existing secret, enable automatic rotation by updating its details.
6. In the Secrets table, view a list of your existing secrets.
7. In the row for the secret that you want to edit, click the Actions menu, **Edit details**
8. Use the **Automatic rotation** option to enable or disable automatic rotation for the secret.

Default Value:

Rotation is not enabled, user has to enable it for the service to rotate automatically based on selected interval.

References:

1. <https://cloud.ibm.com/docs/secrets-manager?topic=secrets-manager-automatic-rotation&interface=ui>
2. <https://cloud.ibm.com/docs/secrets-manager?topic=secrets-manager-manual-rotation&interface=cli>
3. <https://cloud.ibm.com/docs/secrets-manager?topic=secrets-manager-manual-rotation&interface=api>

Additional Information:

1. Check whether secrets stored in Secrets Manager are set to automatically rotated
2. Check whether Secrets Manager user credentials are rotated at least every 60 days
3. Check whether Secrets Manager user credentials are not expired

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	0.0 <u>Explicitly Not Mapped</u> Explicitly Not Mapped			

9 IBM Power Virtual Server on IBM Cloud (PowerVS)

This section covers rules specific to the IBM Power Virtual Server on IBM Cloud service, also referred to as PowerVS.

9.1 Ensure the Default Network Security Group of Every Workspace Restricts All Traffic (Manual)

Profile Applicability:

- Level 1

Description:

It is recommended that the default security group for every workspace restricts all inbound (ingress) traffic, to enforce a least-privilege security posture and reduce unintended exposure of PowerVS resources.

Rationale:

Starting with a default security group configuration that restricts all inbound (ingress) traffic reduces the chance of exposing PowerVS resources to unintended risks.

Audit:

Perform the following tasks to determine if the account is configured as prescribed:

Using Console:

1. Login to the IBM Cloud Portal at <https://cloud.ibm.com> and select **Power Virtual Server** user interface.
2. In the navigation panel, click **Workspaces**, then for each workspace that contains Network Security Groups, open the **Workspace details** page.
3. From the workspace details page, click **view virtual servers**.
4. In the left navigation panel, expand Networking and then select **Network Security Groups**.
5. For the default security group, perform the following:
 - a. Ensure no rule exists that allows inbound (ingress) traffic flow to the Virtual Servers in the group.

Remediation:

Using Console:

1. Login to the IBM Cloud Portal at <https://cloud.ibm.com> and select **Power Virtual Server** user interface.
2. In the navigation panel, click **Workspaces**, then for each workspace that contains Network Security Groups, open the **Workspace details** page.
3. From the workspace details page, click **view virtual servers**.
4. In the left navigation panel, expand Networking and then select **Network Security Groups**.
5. For the default security group, perform the following:

- a. Identify the rule that allows inbound (ingress) traffic flows.
- b. Remove the rule.

References:

1. 1. <https://cloud.ibm.com/docs/power-iaas?topic=power-iaas-nsg>
2. 2. <https://cloud.ibm.com/apidocs/power-cloud#v1-networksecuritygroups-list>
3. 3. IBM Power Virtual Server Security Essentials: NSGs and NAGs Explained

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	4.4 <u>Implement and Manage a Firewall on Servers</u> Implement and manage a firewall on servers, where supported. Example implementations include a virtual firewall, operating system firewall, or a third-party firewall agent.			
v8	4.5 <u>Implement and Manage a Firewall on End-User Devices</u> Implement and manage a host-based firewall or port-filtering tool on end-user devices, with a default-deny rule that drops all traffic except those services and ports that are explicitly allowed.			
v7	9.2 <u>Ensure Only Approved Ports, Protocols and Services Are Running</u> Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.			

9.2 Ensure no workspace security groups allow ingress from 0.0.0.0/0 to port 3389 (Manual)

Profile Applicability:

- Level 1

Description:

It is recommended that workspace security groups do not allow unrestricted ingress access from 0.0.0.0/0 to port 3389, which is the Remote Desktop Protocol (RDP) port used for remote server administration.

Rationale:

Restricting access to the RDP port reduces the attack surface and lowers risk to PowerVS resources by preventing access to a critical administrative port.

Audit:

Perform the following tasks to determine if the account is configured as prescribed:

1. Login to the IBM Cloud Portal at <https://cloud.ibm.com> and select **Power Virtual Server** user interface.
2. In the navigation panel, click **Workspaces**, then select the workspace that contains the Network Security Groups to review and open the **Workspace details** page.
3. From the workspace details page, click **view virtual servers**.
4. In the left navigation panel, expand **Networking** and then select Network security groups. For each NSG perform the following:
 - a. Select the access control list name
 - b. Ensure no Inbound Rule exists that has a port range that includes port 22 and has a Source of 0.0.0.0/0. Note that a port range value of ALL or a port range that includes port 3389, e.g. 3300-3400, are inclusive of port 3389.

Remediation:

1. Login to the IBM Cloud Portal at <https://cloud.ibm.com> and select **Power Virtual Server** user interface.
2. In the navigation panel, click **Workspaces**, then select the workspace that contains the Network Security Groups to review and open the **Workspace details** page.
3. From the workspace details page, click **view virtual servers**.
4. For each network security group, perform the following:
 - a. Select the network security group name.

- b. Identify the Inbound rule to be removed, then select **Delete**.

References:

1. <https://cloud.ibm.com/docs/power-iaas?topic=power-iaas-nsg>
2. <https://cloud.ibm.com/apidocs/power-cloud#v1-networksecuritygroups-list>
3. IBM Power Virtual Server Security Essentials: NSGs and NAGs Explained

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	4.4 Implement and Manage a Firewall on Servers Implement and manage a firewall on servers, where supported. Example implementations include a virtual firewall, operating system firewall, or a third-party firewall agent.			
v8	4.5 Implement and Manage a Firewall on End-User Devices Implement and manage a host-based firewall or port-filtering tool on end-user devices, with a default-deny rule that drops all traffic except those services and ports that are explicitly allowed.			
v7	9.2 Ensure Only Approved Ports, Protocols and Services Are Running Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.			

9.3 Ensure no workspace network security groups allow ingress from 0.0.0.0/0 to port 22 (Manual)

Profile Applicability:

- Level 1

Description:

It is recommended that no workspace security groups allow unrestricted ingress access to SSH on port 22.

Rationale:

This control is intended to reduce the PowerVS resource attack surface and risk of compromise by preventing access to administrative ports, like SSH.

Impact:

When updating an existing environment, care should be taken to ensure that administrators currently relying on an ingress from 0.0.0.0/0 have access to ports 22 through another, more restrictive, access control list, private network connection or VPN as a Service.

Audit:

Perform the following tasks to determine if the account is configured as prescribed:

1. Login to the IBM Cloud Portal at <https://cloud.ibm.com> and select **Power Virtual Server** user interface.
2. In the navigation panel, click **Workspaces**, then select the workspace that contains the Network Security Groups to review and open the **Workspace details** page.
3. From the workspace details page, click **view virtual servers**.
4. In the left navigation panel, expand **Networking** and then select Network security groups. For each NSG perform the following:
 - a. Select the access control list name
 - b. Ensure no Inbound Rule exists that has a port range that includes port 22 and has a Source of 0.0.0.0/0. A port range value of ALL or a port range that includes port 22, e.g. 0-1024, are inclusive of port 22.

Remediation:

1. Login to the IBM Cloud Portal at <https://cloud.ibm.com> and select **Power Virtual Server** user interface.

2. In the navigation panel, click **Workspaces**, then select the workspace that contains the Network Security Groups to review and open the **Workspace details** page.
3. From the workspace details page, click **view virtual servers**.
4. For each network security group, perform the following:
 - a. Select the network security group name.
 - b. Identify the Inbound rule to be removed, then select **Delete**.

References:

1. <https://cloud.ibm.com/docs/power-iaas?topic=power-iaas-nsg>
2. <https://cloud.ibm.com/apidocs/power-cloud#v1-networksecuritygroups-list>
3. <https://community.ibm.com/community/user/blogs/arka-chakraborty/2025/03/03/ibm-powervs-security-essentials-nsgs-and-nags>

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	4.4 Implement and Manage a Firewall on Servers Implement and manage a firewall on servers, where supported. Example implementations include a virtual firewall, operating system firewall, or a third-party firewall agent.			
v8	4.5 Implement and Manage a Firewall on End-User Devices Implement and manage a host-based firewall or port-filtering tool on end-user devices, with a default-deny rule that drops all traffic except those services and ports that are explicitly allowed.			
v7	9.2 Ensure Only Approved Ports, Protocols and Services Are Running Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.			

9.4 Ensure no workspace network security groups allow inbound traffic from the Internet from 0.0.0.0/0 to any infrastructure ports (Manual)

Profile Applicability:

- Level 1

Description:

It is recommended that inbound traffic from the Internet to high-risk ports is restricted, following the principle of least privilege access. The ports specified in this control are DNS (53), POP3 (110), SMTP (25), DHCP (67, 68), SNMP (161, 162).

Rationale:

Removing unrestricted inbound connectivity from the Internet to infrastructure ports and services, such as DNS and DHCP, reduces PowerVS resources' exposure to risk.

Audit:

Perform the following tasks to determine if the account is configured as prescribed:

1. Login to the IBM Cloud Portal at <https://cloud.ibm.com> and select **Power Virtual Server** user interface.
2. In the navigation panel, click **Workspaces**, then select the workspace that contains the Network Security Groups to review and open the **Workspace details** page.
3. From the workspace details page, click **view virtual servers**.
4. In the left navigation panel, expand **Networking** and then select Network security groups. For each NSG perform the following:
 - a. Select the access control list name
 - b. Ensure no Inbound Rule exists that has a port range that includes ports 53, 110, 25, 67, 68, 161 or 162 and has a Source of 0.0.0.0/0.

Remediation:

1. Login to the IBM Cloud Portal at <https://cloud.ibm.com> and select **Power Virtual Server** user interface.
2. In the navigation panel, click **Workspaces**, then select the workspace that contains the Network Security Groups to review and open the **Workspace details** page.
3. From the workspace details page, click **view virtual servers**.
4. For each network security group, perform the following:

- a. Select the network security group name.
- b. Identify the Inbound rule to be removed, then select **Delete**.

References:

1. <https://cloud.ibm.com/docs/power-iaas?topic=power-iaas-nsg>
2. <https://cloud.ibm.com/apidocs/power-cloud#v1-networksecuritygroups-list>
3. <https://community.ibm.com/community/user/blogs/arka-chakraborty/2025/03/03/ibm-powervs-security-essentials-nsgs-and-nags>

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	4.4 <u>Implement and Manage a Firewall on Servers</u> Implement and manage a firewall on servers, where supported. Example implementations include a virtual firewall, operating system firewall, or a third-party firewall agent.			
v8	4.5 <u>Implement and Manage a Firewall on End-User Devices</u> Implement and manage a host-based firewall or port-filtering tool on end-user devices, with a default-deny rule that drops all traffic except those services and ports that are explicitly allowed.			
v7	9.2 <u>Ensure Only Approved Ports, Protocols and Services Are Running</u> Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.			

9.5 Ensure no workspace network security groups allow inbound traffic from the Internet from 0.0.0.0/0 to any administrative ports (Manual)

Profile Applicability:

- Level 1

Description:

It is recommended that inbound traffic from the Internet to administrative ports is restricted, following the principle of least privilege access. These ports are RDP (3389), SSH (22), VNC (Listener: 5500, Server: 5900) and RPC (135, 111).

Rationale:

Removing unrestricted connectivity from the Internet to administrative services, such as SSH, reduces a PowerVS resources risk exposure.

Impact:

When updating an existing environment, care should be taken to ensure that administrators currently relying on an ingress from 0.0.0.0/0 have access to administrative ports through another, more restrictive, access control list, private network connection or VPN as a Service.

Audit:

Perform the following tasks to determine if the account is configured as prescribed:

1. Login to the IBM Cloud Portal at <https://cloud.ibm.com> and select **Power Virtual Server** user interface.
2. In the navigation panel, click **Workspaces**, then select the workspace that contains the Network Security Groups to review and open the **Workspace details** page.
3. From the workspace details page, click **view virtual servers**.
4. In the left navigation panel, expand **Networking** and then select Network security groups. For each NSG perform the following:
 - a. Select the access control list name
 - b. Ensure no Inbound Rule exists that has a port range that includes ports 3389, 22, 5500, 5900, 135 or 111 and has a Source of 0.0.0.0/0.

Remediation:

1. Login to the IBM Cloud Portal at <https://cloud.ibm.com> and select **Power Virtual Server** user interface.

2. In the navigation panel, click **Workspaces**, then select the workspace that contains the Network Security Groups to review and open the **Workspace details** page.
3. From the workspace details page, click **view virtual servers**.
4. For each network security group, perform the following:
 - a. Select the network security group name.
 - b. Identify the Inbound rule to be removed, then select **Delete**.

References:

1. <https://cloud.ibm.com/docs/power-iaas?topic=power-iaas-nsg>
2. <https://cloud.ibm.com/apidocs/power-cloud#v1-networksecuritygroups-list>
3. <https://community.ibm.com/community/user/blogs/arka-chakraborty/2025/03/03/ibm-powervs-security-essentials-nsgs-and-nags>

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	4.4 Implement and Manage a Firewall on Servers Implement and manage a firewall on servers, where supported. Example implementations include a virtual firewall, operating system firewall, or a third-party firewall agent.			
v8	4.5 Implement and Manage a Firewall on End-User Devices Implement and manage a host-based firewall or port-filtering tool on end-user devices, with a default-deny rule that drops all traffic except those services and ports that are explicitly allowed.			
v7	9.2 Ensure Only Approved Ports, Protocols and Services Are Running Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.			

9.6 Ensure no workspace network security groups allow inbound traffic from the Internet from 0.0.0.0/0 to any fileshare port (Manual)

Profile Applicability:

- Level 1

Description:

It is recommended that inbound traffic from the Internet to file sharing application ports is restricted, following the principle of least privilege access. These ports are NetBIOS (139), SMB (445), FTP (21).

Rationale:

Removing uncontrolled connectivity from the Internet to file sharing services, such as SMB, reduces a PowerVS resources' risk exposure.

Audit:

1. Login to the IBM Cloud Portal at <https://cloud.ibm.com> and select **Power Virtual Server** user interface.
2. In the navigation panel, click **Workspaces**, then select the workspace that contains the Network Security Groups to review and open the **Workspace details** page.
3. From the workspace details page, click **view virtual servers**.
4. In the left navigation panel, expand **Networking** and then select **Network security groups**. For each NSG perform the following:
 - a. Select the access control list name
 - b. Ensure no Inbound Rule exists that has a port range that includes ports 139, 445 or 21 and has a Source of 0.0.0.0/0.

Remediation:

1. Login to the IBM Cloud Portal at <https://cloud.ibm.com> and select **Power Virtual Server** user interface.
2. In the navigation panel, click **Workspaces**, then select the workspace that contains the Network Security Groups to review and open the **Workspace details** page.
3. From the workspace details page, click **view virtual servers**.
4. For each network security group, perform the following:
 - a. Select the network security group name.

b. Identify the Inbound rule to be removed, then select **Delete**.

References:

1. <https://cloud.ibm.com/docs/power-iaas?topic=power-iaas-nsg>
2. <https://cloud.ibm.com/apidocs/power-cloud#v1-networksecuritygroups-list>
3. <https://community.ibm.com/community/user/blogs/arka-chakraborty/2025/03/03/ibm-powervs-security-essentials-nsgs-and-nags>

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	4.4 Implement and Manage a Firewall on Servers Implement and manage a firewall on servers, where supported. Example implementations include a virtual firewall, operating system firewall, or a third-party firewall agent.			
v8	4.5 Implement and Manage a Firewall on End-User Devices Implement and manage a host-based firewall or port-filtering tool on end-user devices, with a default-deny rule that drops all traffic except those services and ports that are explicitly allowed.			
v7	9.2 Ensure Only Approved Ports, Protocols and Services Are Running Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.			
v7	12.4 Deny Communication over Unauthorized Ports Deny communication over unauthorized TCP or UDP ports or application traffic to ensure that only authorized protocols are allowed to cross the network boundary in or out of the network at each of the organization's network boundaries.			

9.7 Ensure no workspace network security groups allow inbound traffic from the Internet allowing access from 0.0.0.0/0 to telnet port (23) or RSH port (514) (Manual)

Profile Applicability:

- Level 1

Description:

It is recommended the inbound traffic from the Internet to telnet port (23) or remote shell (RSH, port 514) is restricted.

Rationale:

These protocols are insecure/deprecated and should not be used in general.

Audit:

Perform the following tasks to determine if the account is configured as prescribed:

1. Login to the IBM Cloud Portal at <https://cloud.ibm.com> and select Power Virtual Server user interface.
2. In the navigation panel, click Workspaces, then select the workspace that contains the Network Security Groups to review and open the **Workspace details** page.
3. From the workspace details page, click **view virtual servers**.
4. In the left navigation panel, expand **Networking** and then select **Network security groups**. For each NSG perform the following:
 - a. Select the access control list name
 - b. Ensure no Inbound Rule exists that has a port range that includes ports 23 or 514 and has a Source of 0.0.0.0/0.

Remediation:

1. Login to the IBM Cloud Portal at <https://cloud.ibm.com> and select Power Virtual Server user interface.
2. In the navigation panel, click Workspaces, then select the workspace that contains the Network Security Groups to review and open the **Workspace details** page.
3. From the workspace details page, click **view virtual servers**.
4. For each network security group, perform the following:
 - a. Select the network security group name.
 - b. Identify the Inbound rule to be removed, then select **Delete**.

References:

1. <https://cloud.ibm.com/docs/power-iaas?topic=power-iaas-nsg>
2. <https://cloud.ibm.com/apidocs/power-cloud#v1-networksecuritygroups-list>
3. <https://community.ibm.com/community/user/blogs/arka-chakraborty/2025/03/03/ibm-powervs-security-essentials-nsgs-and-nags>

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	4.4 Implement and Manage a Firewall on Servers Implement and manage a firewall on servers, where supported. Example implementations include a virtual firewall, operating system firewall, or a third-party firewall agent.			
v8	4.5 Implement and Manage a Firewall on End-User Devices Implement and manage a host-based firewall or port-filtering tool on end-user devices, with a default-deny rule that drops all traffic except those services and ports that are explicitly allowed.			
v7	9.2 Ensure Only Approved Ports, Protocols and Services Are Running Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.			
v7	12.4 Deny Communication over Unauthorized Ports Deny communication over unauthorized TCP or UDP ports or application traffic to ensure that only authorized protocols are allowed to cross the network boundary in or out of the network at each of the organization's network boundaries.			

Appendix: Summary Table

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
1	Identity and Access Management (IAM)		
1.1	Monitor account owner for frequent, unexpected, or unauthorized logins (Manual)	☐	☐
1.2	Ensure API keys unused for 180 days are detected and optionally disabled (Manual)	☐	☐
1.3	Ensure API keys are rotated every 90 days (Manual)	☐	☐
1.4	Restrict user API key creation and service ID creation in the account via IAM roles (Manual)	☐	☐
1.5	Ensure no owner account API key exists (Manual)	☐	☐
1.6	Ensure multi-factor authentication (MFA) is enabled for all users in account (Manual)	☐	☐
1.7	Ensure multi-factor authentication (MFA) is enabled for the account owner and all administrative users (Manual)	☐	☐
1.8	Ensure multi-factor authentication (MFA) is enabled at the account level (Manual)	☐	☐
1.9	Ensure contact email is valid (Manual)	☐	☐
1.10	Ensure contact phone number is valid (Manual)	☐	☐
1.11	Ensure Trusted Profiles are used in place of ServiceIDs wherever feasible (Manual)	☐	☐
1.12	Ensure Context-Based Restrictions are implemented to enforce secure, conditional access to critical resources based on network location, IP range, or identity attributes (Manual)	☐	☐
1.13	Ensure limitations on External Identity Interactions are Enabled (Manual)	☐	☐

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
1.14	Ensure IAM users with the same level of access are members of access groups and IAM policies are assigned only to access groups or Trusted Profiles (Manual)	☐	☐
1.15	Ensure a support access group has been created to manage incidents with IBM Support (Manual)	☐	☐
1.16	Ensure Minimal Number of Users are Granted Administrative Privileges (Manual)	☐	☐
1.17	Ensure Minimal Number of Service IDs are Granted Administrative Privileges (Manual)	☐	☐
1.18	Ensure IAM Does Not Allow Public Access to Cloud Services (Manual)	☐	☐
1.19	Ensure Inactive User Accounts are Suspend (Manual)	☐	☐
1.20	Enable audit logging for IBM Cloud Identity and Access Management (Manual)	☐	☐
2	Storage		
2.1	Cloud Object Storage		
2.1.1	Cloud Object Storage Encryption		
2.1.1.1	Ensure Cloud Object Storage encryption is done with customer managed keys (Manual)	☐	☐
2.1.1.2	Ensure Cloud Object Storage Encryption is set to On with BYOK (Manual)	☐	☐
2.1.1.3	Ensure Cloud Object Storage Encryption is set to On with KYOK (Manual)	☐	☐
2.1.2	Ensure network access for Cloud Object Storage is restricted to specific IP range (Manual)	☐	☐
2.1.3	Ensure network access for Cloud Object Storage is set to be exposed only on Private end-points (Manual)	☐	☐

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
2.1.4	Ensure Cloud Object Storage bucket access is restricted by using IAM and S3 access control (Manual)	☐	☐
2.1.5	Ensure Public (anonymous) Access to IBM Cloud Object Storage buckets is Disabled (Manual)	☐	☐
2.2	Block and File Storage		
2.2.1	Cloud Block Storage Encryption		
2.2.1.1	Ensure IBM Cloud® Block Storage for Virtual Private Cloud is encrypted with BYOK (Manual)	☐	☐
2.2.1.2	Ensure IBM Cloud® Block Storage for Virtual Private Cloud is encrypted with KYOK (Manual)	☐	☐
2.2.2	Cloud File Storage Encryption		
2.2.2.1	Ensure IBM Cloud® File Storage for Virtual Private Cloud is encrypted with provider managed keys (Manual)	☐	☐
2.2.2.2	Ensure IBM Cloud® File Storage for Virtual Private Cloud is encrypted with BYOK (Manual)	☐	☐
2.2.2.3	Ensure IBM Cloud® File Storage for Virtual Private Cloud is encrypted with KYOK (Manual)	☐	☐
2.2.3	Ensure boot volumes are encrypted with Customer managed keys (Manual)	☐	☐
2.2.4	Ensure secondary volumes are encrypted with customer managed keys (Manual)	☐	☐
2.2.5	Ensure unattached volumes are encrypted with customer managed keys (Manual)	☐	☐
3	Maintenance, Monitoring and Analysis of Audit Logs		
3.1	Ensure auditing is configured in the IBM Cloud account (Manual)	☐	☐
3.2	Ensure data retention for audit events (Manual)	☐	☐

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
3.3	Ensure that events are collected and processed to identify anomalies or abnormal events (Manual)	☐	☐
3.4	Ensure alerts are defined on custom views to notify of unauthorized requests, critical account actions, and high-impact operations in your account (Manual)	☐	☐
3.5	Ensure the account owner can login only from a list of authorized countries/IP ranges (Manual)	☐	☐
3.6	Ensure Activity Tracker data is encrypted at rest (Manual)	☐	☐
4	IBM Cloud Databases Family		
4.1	Ensure IBM Cloud Databases disk encryption is enabled with customer managed keys (Manual)	☐	☐
4.2	Ensure network access to IBM Cloud Databases service is set to be exposed on "Private end points only" (Manual)	☐	☐
4.3	Ensure incoming connections are limited to allowed sources (Manual)	☐	☐
5	Cloudant		
5.1	Ensure IBM Cloudant encryption is enabled with customer managed keys (Manual)	☐	☐
6	Networking		
6.1	IBM Cloud Internet Services		
6.1.1	Enable TLS 1.2 at minimum for all inbound traffic on IBM Cloud Internet Services Proxy (Manual)	☐	☐
6.1.2	Ensure Web application firewall is ENABLED in IBM Cloud Internet Services (CIS) (Manual)	☐	☐
6.1.3	Ensure DDoS protection is Active on IBM Cloud Internet Services (Manual)	☐	☐

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
6.2	IBM Virtual Private Cloud (VPC)		
6.2.1	Ensure no VPC access control lists allow ingress from 0.0.0.0/0 to port 22 (Manual)	☐	☐
6.2.2	Ensure the default security group of every VPC restricts all traffic (Manual)	☐	☐
6.2.3	Ensure no VPC security groups allow ingress from 0.0.0.0/0 to port 3389 (Manual)	☐	☐
6.2.4	Ensure no VPC security groups allow ingress from 0.0.0.0/0 to port 22 (Manual)	☐	☐
6.2.5	Ensure no VPC access control lists allow ingress from 0.0.0.0/0 to port 3389 (Manual)	☐	☐
7	Containers		
7.1	IBM Cloud Kubernetes Service		
7.1.1	Ensure data in Kubernetes secrets is encrypted using a Key Management Service (KMS) provider (Manual)	☐	☐
7.1.2	Ensure TLS 1.2+ for all inbound traffic at IBM Cloud Kubernetes Service Ingress (Automated)	☐	☐
7.1.3	Ensure IBM Cloud Kubernetes Service worker nodes are updated to the latest version to ensure patching of vulnerabilities (Automated)	☐	☐
7.1.4	Ensure IBM Cloud Kubernetes Service cluster has image pull secrets enabled (Automated)	☐	☐
7.1.5	Ensure IBM Cloud Kubernetes Service clusters have the monitoring service enabled (Automated)	☐	☐
7.1.6	Ensure IBM Cloud Kubernetes Service clusters have the logging service enabled (Manual)	☐	☐
8	Security and Compliance		

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
8.1	Key Management		
8.1.1	IBM Key Protect for IBM Cloud		
8.1.1.1	Ensure IBM Key Protect has automated rotation for customer managed keys enabled (Automated)	☐	☐
8.1.1.2	Ensure Keys in the IBM Cloud® Key Protect Service are configured for high availability (Manual)	☐	☐
8.1.1.3	Ensure all data stores are encrypted in the IBM Cloud® (Manual)	☐	☐
8.2	IBM Cloud Secrets Manager		
8.2.1	Ensure certificates imported into or generated through IBM Cloud® Secrets Manager are automatically renewed before expiration (Automated)	☐	☐
8.2.2	Ensure access settings to secrets follow least privilege rule and allow access for a limited time to applications and non-administrative users as needed (Manual)	☐	☐
8.2.3	Ensure notification service is enabled in the IBM Cloud Secrets Manager to notify life cycle events (Manual)	☐	☐
8.2.4	Ensure secrets stored in the IBM Cloud® Secrets Manager are rotated periodically (Automated)	☐	☐
9	IBM Power Virtual Server on IBM Cloud (PowerVS)		
9.1	Ensure the Default Network Security Group of Every Workspace Restricts All Traffic (Manual)	☐	☐
9.2	Ensure no workspace security groups allow ingress from 0.0.0.0/0 to port 3389 (Manual)	☐	☐
9.3	Ensure no workspace network security groups allow ingress from 0.0.0.0/0 to port 22 (Manual)	☐	☐

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
9.4	Ensure no workspace network security groups allow inbound traffic from the Internet from 0.0.0.0/0 to any infrastructure ports (Manual)	☐	☐
9.5	Ensure no workspace network security groups allow inbound traffic from the Internet from 0.0.0.0/0 to any administrative ports (Manual)	☐	☐
9.6	Ensure no workspace network security groups allow inbound traffic from the Internet from 0.0.0.0/0 to any fileshare port (Manual)	☐	☐
9.7	Ensure no workspace network security groups allow inbound traffic from the Internet allowing access from 0.0.0.0/0 to telnet port (23) or RSH port (514) (Manual)	☐	☐

Appendix: CIS Controls v7 IG 1 Mapped Recommendations

Recommendation		Set Correctly	
		Yes	No
1.2	Ensure API keys unused for 180 days are detected and optionally disabled	☐	☐
1.4	Restrict user API key creation and service ID creation in the account via IAM roles	☐	☐
1.9	Ensure contact email is valid	☐	☐
1.10	Ensure contact phone number is valid	☐	☐
1.14	Ensure IAM users with the same level of access are members of access groups and IAM policies are assigned only to access groups or Trusted Profiles	☐	☐
1.15	Ensure a support access group has been created to manage incidents with IBM Support	☐	☐
1.17	Ensure Minimal Number of Service IDs are Granted Administrative Privileges	☐	☐
1.18	Ensure IAM Does Not Allow Public Access to Cloud Services	☐	☐
1.19	Ensure Inactive User Accounts are Suspend	☐	☐
2.1.3	Ensure network access for Cloud Object Storage is set to be exposed only on Private end-points	☐	☐
2.1.5	Ensure Public (anonymous) Access to IBM Cloud Object Storage buckets is Disabled	☐	☐
3.1	Ensure auditing is configured in the IBM Cloud account	☐	☐
4.2	Ensure network access to IBM Cloud Databases service is set to be exposed on "Private end points only"	☐	☐
4.3	Ensure incoming connections are limited to allowed sources	☐	☐
7.1.5	Ensure IBM Cloud Kubernetes Service clusters have the monitoring service enabled	☐	☐
7.1.6	Ensure IBM Cloud Kubernetes Service clusters have the logging service enabled	☐	☐
8.1.1.2	Ensure Keys in the IBM Cloud® Key Protect Service are configured for high availability	☐	☐

Recommendation		Set Correctly	
		Yes	No
9.6	Ensure no workspace network security groups allow inbound traffic from the Internet from 0.0.0.0/0 to any fileshare port	☐	☐
9.7	Ensure no workspace network security groups allow inbound traffic from the Internet allowing access from 0.0.0.0/0 to telnet port (23) or RSH port (514)	☐	☐

Appendix: CIS Controls v7 IG 2 Mapped Recommendations

Recommendation		Set Correctly	
		Yes	No
1.2	Ensure API keys unused for 180 days are detected and optionally disabled	☐	☐
1.3	Ensure API keys are rotated every 90 days	☐	☐
1.4	Restrict user API key creation and service ID creation in the account via IAM roles	☐	☐
1.5	Ensure no owner account API key exists	☐	☐
1.6	Ensure multi-factor authentication (MFA) is enabled for all users in account	☐	☐
1.7	Ensure multi-factor authentication (MFA) is enabled for the account owner and all administrative users	☐	☐
1.8	Ensure multi-factor authentication (MFA) is enabled at the account level	☐	☐
1.9	Ensure contact email is valid	☐	☐
1.10	Ensure contact phone number is valid	☐	☐
1.14	Ensure IAM users with the same level of access are members of access groups and IAM policies are assigned only to access groups or Trusted Profiles	☐	☐
1.15	Ensure a support access group has been created to manage incidents with IBM Support	☐	☐
1.16	Ensure Minimal Number of Users are Granted Administrative Privileges	☐	☐
1.17	Ensure Minimal Number of Service IDs are Granted Administrative Privileges	☐	☐
1.18	Ensure IAM Does Not Allow Public Access to Cloud Services	☐	☐
1.19	Ensure Inactive User Accounts are Suspend	☐	☐
1.20	Enable audit logging for IBM Cloud Identity and Access Management	☐	☐
2.1.2	Ensure network access for Cloud Object Storage is restricted to specific IP range	☐	☐

Recommendation		Set Correctly	
		Yes	No
2.1.3	Ensure network access for Cloud Object Storage is set to be exposed only on Private end-points	☐	☐
2.1.5	Ensure Public (anonymous) Access to IBM Cloud Object Storage buckets is Disabled	☐	☐
3.1	Ensure auditing is configured in the IBM Cloud account	☐	☐
3.2	Ensure data retention for audit events	☐	☐
3.3	Ensure that events are collected and processed to identify anomalies or abnormal events	☐	☐
3.4	Ensure alerts are defined on custom views to notify of unauthorized requests, critical account actions, and high-impact operations in your account	☐	☐
4.2	Ensure network access to IBM Cloud Databases service is set to be exposed on "Private end points only"	☐	☐
4.3	Ensure incoming connections are limited to allowed sources	☐	☐
6.1.1	Enable TLS 1.2 at minimum for all inbound traffic on IBM Cloud Internet Services Proxy	☐	☐
6.1.3	Ensure DDoS protection is Active on IBM Cloud Internet Services	☐	☐
6.2.1	Ensure no VPC access control lists allow ingress from 0.0.0.0/0 to port 22	☐	☐
6.2.2	Ensure the default security group of every VPC restricts all traffic	☐	☐
6.2.3	Ensure no VPC security groups allow ingress from 0.0.0.0/0 to port 3389	☐	☐
6.2.4	Ensure no VPC security groups allow ingress from 0.0.0.0/0 to port 22	☐	☐
6.2.5	Ensure no VPC access control lists allow ingress from 0.0.0.0/0 to port 3389	☐	☐
7.1.2	Ensure TLS 1.2+ for all inbound traffic at IBM Cloud Kubernetes Service Ingress	☐	☐
7.1.3	Ensure IBM Cloud Kubernetes Service worker nodes are updated to the latest version to ensure patching of vulnerabilities	☐	☐
7.1.4	Ensure IBM Cloud Kubernetes Service cluster has image pull secrets enabled	☐	☐

Recommendation		Set Correctly	
		Yes	No
7.1.5	Ensure IBM Cloud Kubernetes Service clusters have the monitoring service enabled	☐	☐
7.1.6	Ensure IBM Cloud Kubernetes Service clusters have the logging service enabled	☐	☐
8.1.1.2	Ensure Keys in the IBM Cloud® Key Protect Service are configured for high availability	☐	☐
8.2.1	Ensure certificates imported into or generated through IBM Cloud® Secrets Manager are automatically renewed before expiration	☐	☐
8.2.2	Ensure access settings to secrets follow least privilege rule and allow access for a limited time to applications and non-administrative users as needed	☐	☐
9.1	Ensure the Default Network Security Group of Every Workspace Restricts All Traffic	☐	☐
9.2	Ensure no workspace security groups allow ingress from 0.0.0.0/0 to port 3389	☐	☐
9.3	Ensure no workspace network security groups allow ingress from 0.0.0.0/0 to port 22	☐	☐
9.4	Ensure no workspace network security groups allow inbound traffic from the Internet from 0.0.0.0/0 to any infrastructure ports	☐	☐
9.5	Ensure no workspace network security groups allow inbound traffic from the Internet from 0.0.0.0/0 to any administrative ports	☐	☐
9.6	Ensure no workspace network security groups allow inbound traffic from the Internet from 0.0.0.0/0 to any fileshare port	☐	☐
9.7	Ensure no workspace network security groups allow inbound traffic from the Internet allowing access from 0.0.0.0/0 to telnet port (23) or RSH port (514)	☐	☐

Appendix: CIS Controls v7 IG 3 Mapped Recommendations

Recommendation		Set Correctly	
		Yes	No
1.1	Monitor account owner for frequent, unexpected, or unauthorized logins	☐	☐
1.2	Ensure API keys unused for 180 days are detected and optionally disabled	☐	☐
1.3	Ensure API keys are rotated every 90 days	☐	☐
1.4	Restrict user API key creation and service ID creation in the account via IAM roles	☐	☐
1.5	Ensure no owner account API key exists	☐	☐
1.6	Ensure multi-factor authentication (MFA) is enabled for all users in account	☐	☐
1.7	Ensure multi-factor authentication (MFA) is enabled for the account owner and all administrative users	☐	☐
1.8	Ensure multi-factor authentication (MFA) is enabled at the account level	☐	☐
1.9	Ensure contact email is valid	☐	☐
1.10	Ensure contact phone number is valid	☐	☐
1.14	Ensure IAM users with the same level of access are members of access groups and IAM policies are assigned only to access groups or Trusted Profiles	☐	☐
1.15	Ensure a support access group has been created to manage incidents with IBM Support	☐	☐
1.16	Ensure Minimal Number of Users are Granted Administrative Privileges	☐	☐
1.17	Ensure Minimal Number of Service IDs are Granted Administrative Privileges	☐	☐
1.18	Ensure IAM Does Not Allow Public Access to Cloud Services	☐	☐
1.19	Ensure Inactive User Accounts are Suspend	☐	☐
1.20	Enable audit logging for IBM Cloud Identity and Access Management	☐	☐

Recommendation		Set Correctly	
		Yes	No
2.1.1.1	Ensure Cloud Object Storage encryption is done with customer managed keys	☐	☐
2.1.1.2	Ensure Cloud Object Storage Encryption is set to On with BYOK	☐	☐
2.1.1.3	Ensure Cloud Object Storage Encryption is set to On with KYOK	☐	☐
2.1.2	Ensure network access for Cloud Object Storage is restricted to specific IP range	☐	☐
2.1.3	Ensure network access for Cloud Object Storage is set to be exposed only on Private end-points	☐	☐
2.1.5	Ensure Public (anonymous) Access to IBM Cloud Object Storage buckets is Disabled	☐	☐
2.2.1.1	Ensure IBM Cloud® Block Storage for Virtual Private Cloud is encrypted with BYOK	☐	☐
2.2.1.2	Ensure IBM Cloud® Block Storage for Virtual Private Cloud is encrypted with KYOK	☐	☐
2.2.2.1	Ensure IBM Cloud® File Storage for Virtual Private Cloud is encrypted with provider managed keys	☐	☐
2.2.2.2	Ensure IBM Cloud® File Storage for Virtual Private Cloud is encrypted with BYOK	☐	☐
2.2.2.3	Ensure IBM Cloud® File Storage for Virtual Private Cloud is encrypted with KYOK	☐	☐
2.2.3	Ensure boot volumes are encrypted with Customer managed keys	☐	☐
2.2.4	Ensure secondary volumes are encrypted with customer managed keys	☐	☐
2.2.5	Ensure unattached volumes are encrypted with customer managed keys	☐	☐
3.1	Ensure auditing is configured in the IBM Cloud account	☐	☐
3.2	Ensure data retention for audit events	☐	☐
3.3	Ensure that events are collected and processed to identify anomalies or abnormal events	☐	☐
3.4	Ensure alerts are defined on custom views to notify of unauthorized requests, critical account actions, and high-impact operations in your account	☐	☐

Recommendation		Set Correctly	
		Yes	No
3.5	Ensure the account owner can login only from a list of authorized countries/IP ranges	☐	☐
3.6	Ensure Activity Tracker data is encrypted at rest	☐	☐
4.1	Ensure IBM Cloud Databases disk encryption is enabled with customer managed keys	☐	☐
4.2	Ensure network access to IBM Cloud Databases service is set to be exposed on "Private end points only"	☐	☐
4.3	Ensure incoming connections are limited to allowed sources	☐	☐
5.1	Ensure IBM Cloudant encryption is enabled with customer managed keys	☐	☐
6.1.1	Enable TLS 1.2 at minimum for all inbound traffic on IBM Cloud Internet Services Proxy	☐	☐
6.1.2	Ensure Web application firewall is ENABLED in IBM Cloud Internet Services (CIS)	☐	☐
6.1.3	Ensure DDoS protection is Active on IBM Cloud Internet Services	☐	☐
6.2.1	Ensure no VPC access control lists allow ingress from 0.0.0.0/0 to port 22	☐	☐
6.2.2	Ensure the default security group of every VPC restricts all traffic	☐	☐
6.2.3	Ensure no VPC security groups allow ingress from 0.0.0.0/0 to port 3389	☐	☐
6.2.4	Ensure no VPC security groups allow ingress from 0.0.0.0/0 to port 22	☐	☐
6.2.5	Ensure no VPC access control lists allow ingress from 0.0.0.0/0 to port 3389	☐	☐
7.1.1	Ensure data in Kubernetes secrets is encrypted using a Key Management Service (KMS) provider	☐	☐
7.1.2	Ensure TLS 1.2+ for all inbound traffic at IBM Cloud Kubernetes Service Ingress	☐	☐
7.1.3	Ensure IBM Cloud Kubernetes Service worker nodes are updated to the latest version to ensure patching of vulnerabilities	☐	☐
7.1.4	Ensure IBM Cloud Kubernetes Service cluster has image pull secrets enabled	☐	☐

Recommendation		Set Correctly	
		Yes	No
7.1.5	Ensure IBM Cloud Kubernetes Service clusters have the monitoring service enabled	☐	☐
7.1.6	Ensure IBM Cloud Kubernetes Service clusters have the logging service enabled	☐	☐
8.1.1.1	Ensure IBM Key Protect has automated rotation for customer managed keys enabled	☐	☐
8.1.1.2	Ensure Keys in the IBM Cloud® Key Protect Service are configured for high availability	☐	☐
8.1.1.3	Ensure all data stores are encrypted in the IBM Cloud®	☐	☐
8.2.1	Ensure certificates imported into or generated through IBM Cloud® Secrets Manager are automatically renewed before expiration	☐	☐
8.2.2	Ensure access settings to secrets follow least privilege rule and allow access for a limited time to applications and non-administrative users as needed	☐	☐
9.1	Ensure the Default Network Security Group of Every Workspace Restricts All Traffic	☐	☐
9.2	Ensure no workspace security groups allow ingress from 0.0.0.0/0 to port 3389	☐	☐
9.3	Ensure no workspace network security groups allow ingress from 0.0.0.0/0 to port 22	☐	☐
9.4	Ensure no workspace network security groups allow inbound traffic from the Internet from 0.0.0.0/0 to any infrastructure ports	☐	☐
9.5	Ensure no workspace network security groups allow inbound traffic from the Internet from 0.0.0.0/0 to any administrative ports	☐	☐
9.6	Ensure no workspace network security groups allow inbound traffic from the Internet from 0.0.0.0/0 to any fileshare port	☐	☐
9.7	Ensure no workspace network security groups allow inbound traffic from the Internet allowing access from 0.0.0.0/0 to telnet port (23) or RSH port (514)	☐	☐

Appendix: CIS Controls v7 Unmapped Recommendations

Recommendation		Set Correctly	
		Yes	No
1.11	Ensure Trusted Profiles are used in place of ServiceIDs wherever feasible	☐	☐
1.12	Ensure Context-Based Restrictions are implemented to enforce secure, conditional access to critical resources based on network location, IP range, or identity attributes	☐	☐
1.13	Ensure limitations on External Identity Interactions are Enabled	☐	☐
2.1.4	Ensure Cloud Object Storage bucket access is restricted by using IAM and S3 access control	☐	☐
8.2.3	Ensure notification service is enabled in the IBM Cloud Secrets Manager to notify life cycle events	☐	☐
8.2.4	Ensure secrets stored in the IBM Cloud® Secrets Manager are rotated periodically	☐	☐

Appendix: CIS Controls v8 IG 1 Mapped Recommendations

Recommendation		Set Correctly	
		Yes	No
1.1	Monitor account owner for frequent, unexpected, or unauthorized logins	☐	☐
1.2	Ensure API keys unused for 180 days are detected and optionally disabled	☐	☐
1.4	Restrict user API key creation and service ID creation in the account via IAM roles	☐	☐
1.6	Ensure multi-factor authentication (MFA) is enabled for all users in account	☐	☐
1.7	Ensure multi-factor authentication (MFA) is enabled for the account owner and all administrative users	☐	☐
1.8	Ensure multi-factor authentication (MFA) is enabled at the account level	☐	☐
1.9	Ensure contact email is valid	☐	☐
1.10	Ensure contact phone number is valid	☐	☐
1.14	Ensure IAM users with the same level of access are members of access groups and IAM policies are assigned only to access groups or Trusted Profiles	☐	☐
1.15	Ensure a support access group has been created to manage incidents with IBM Support	☐	☐
1.16	Ensure Minimal Number of Users are Granted Administrative Privileges	☐	☐
1.17	Ensure Minimal Number of Service IDs are Granted Administrative Privileges	☐	☐
1.19	Ensure Inactive User Accounts are Suspend	☐	☐
1.20	Enable audit logging for IBM Cloud Identity and Access Management	☐	☐
2.1.3	Ensure network access for Cloud Object Storage is set to be exposed only on Private end-points	☐	☐
2.1.4	Ensure Cloud Object Storage bucket access is restricted by using IAM and S3 access control	☐	☐

Recommendation		Set Correctly	
		Yes	No
2.1.5	Ensure Public (anonymous) Access to IBM Cloud Object Storage buckets is Disabled	☐	☐
3.1	Ensure auditing is configured in the IBM Cloud account	☐	☐
3.2	Ensure data retention for audit events	☐	☐
4.2	Ensure network access to IBM Cloud Databases service is set to be exposed on "Private end points only"	☐	☐
4.3	Ensure incoming connections are limited to allowed sources	☐	☐
6.2.1	Ensure no VPC access control lists allow ingress from 0.0.0.0/0 to port 22	☐	☐
6.2.2	Ensure the default security group of every VPC restricts all traffic	☐	☐
6.2.3	Ensure no VPC security groups allow ingress from 0.0.0.0/0 to port 3389	☐	☐
6.2.4	Ensure no VPC security groups allow ingress from 0.0.0.0/0 to port 22	☐	☐
6.2.5	Ensure no VPC access control lists allow ingress from 0.0.0.0/0 to port 3389	☐	☐
7.1.4	Ensure IBM Cloud Kubernetes Service cluster has image pull secrets enabled	☐	☐
7.1.5	Ensure IBM Cloud Kubernetes Service clusters have the monitoring service enabled	☐	☐
7.1.6	Ensure IBM Cloud Kubernetes Service clusters have the logging service enabled	☐	☐
8.1.1.2	Ensure Keys in the IBM Cloud® Key Protect Service are configured for high availability	☐	☐
9.1	Ensure the Default Network Security Group of Every Workspace Restricts All Traffic	☐	☐
9.2	Ensure no workspace security groups allow ingress from 0.0.0.0/0 to port 3389	☐	☐
9.3	Ensure no workspace network security groups allow ingress from 0.0.0.0/0 to port 22	☐	☐
9.4	Ensure no workspace network security groups allow inbound traffic from the Internet from 0.0.0.0/0 to any infrastructure ports	☐	☐

Recommendation		Set Correctly	
		Yes	No
9.5	Ensure no workspace network security groups allow inbound traffic from the Internet from 0.0.0.0/0 to any administrative ports	☐	☐
9.6	Ensure no workspace network security groups allow inbound traffic from the Internet from 0.0.0.0/0 to any fileshare port	☐	☐
9.7	Ensure no workspace network security groups allow inbound traffic from the Internet allowing access from 0.0.0.0/0 to telnet port (23) or RSH port (514)	☐	☐

Appendix: CIS Controls v8 IG 2 Mapped Recommendations

Recommendation		Set Correctly	
		Yes	No
1.1	Monitor account owner for frequent, unexpected, or unauthorized logins	☐	☐
1.2	Ensure API keys unused for 180 days are detected and optionally disabled	☐	☐
1.4	Restrict user API key creation and service ID creation in the account via IAM roles	☐	☐
1.6	Ensure multi-factor authentication (MFA) is enabled for all users in account	☐	☐
1.7	Ensure multi-factor authentication (MFA) is enabled for the account owner and all administrative users	☐	☐
1.8	Ensure multi-factor authentication (MFA) is enabled at the account level	☐	☐
1.9	Ensure contact email is valid	☐	☐
1.10	Ensure contact phone number is valid	☐	☐
1.14	Ensure IAM users with the same level of access are members of access groups and IAM policies are assigned only to access groups or Trusted Profiles	☐	☐
1.15	Ensure a support access group has been created to manage incidents with IBM Support	☐	☐
1.16	Ensure Minimal Number of Users are Granted Administrative Privileges	☐	☐
1.17	Ensure Minimal Number of Service IDs are Granted Administrative Privileges	☐	☐
1.19	Ensure Inactive User Accounts are Suspend	☐	☐
1.20	Enable audit logging for IBM Cloud Identity and Access Management	☐	☐
2.1.1.1	Ensure Cloud Object Storage encryption is done with customer managed keys	☐	☐
2.1.1.2	Ensure Cloud Object Storage Encryption is set to On with BYOK	☐	☐

Recommendation		Set Correctly	
		Yes	No
2.1.1.3	Ensure Cloud Object Storage Encryption is set to On with KYOK	☐	☐
2.1.2	Ensure network access for Cloud Object Storage is restricted to specific IP range	☐	☐
2.1.3	Ensure network access for Cloud Object Storage is set to be exposed only on Private end-points	☐	☐
2.1.4	Ensure Cloud Object Storage bucket access is restricted by using IAM and S3 access control	☐	☐
2.1.5	Ensure Public (anonymous) Access to IBM Cloud Object Storage buckets is Disabled	☐	☐
2.2.1.1	Ensure IBM Cloud® Block Storage for Virtual Private Cloud is encrypted with BYOK	☐	☐
2.2.1.2	Ensure IBM Cloud® Block Storage for Virtual Private Cloud is encrypted with KYOK	☐	☐
2.2.2.1	Ensure IBM Cloud® File Storage for Virtual Private Cloud is encrypted with provider managed keys	☐	☐
2.2.2.2	Ensure IBM Cloud® File Storage for Virtual Private Cloud is encrypted with BYOK	☐	☐
2.2.2.3	Ensure IBM Cloud® File Storage for Virtual Private Cloud is encrypted with KYOK	☐	☐
2.2.3	Ensure boot volumes are encrypted with Customer managed keys	☐	☐
2.2.4	Ensure secondary volumes are encrypted with customer managed keys	☐	☐
2.2.5	Ensure unattached volumes are encrypted with customer managed keys	☐	☐
3.1	Ensure auditing is configured in the IBM Cloud account	☐	☐
3.2	Ensure data retention for audit events	☐	☐
3.3	Ensure that events are collected and processed to identify anomalies or abnormal events	☐	☐
3.4	Ensure alerts are defined on custom views to notify of unauthorized requests, critical account actions, and high-impact operations in your account	☐	☐
3.5	Ensure the account owner can login only from a list of authorized countries/IP ranges	☐	☐
3.6	Ensure Activity Tracker data is encrypted at rest	☐	☐

Recommendation		Set Correctly	
		Yes	No
4.1	Ensure IBM Cloud Databases disk encryption is enabled with customer managed keys	☐	☐
4.2	Ensure network access to IBM Cloud Databases service is set to be exposed on "Private end points only"	☐	☐
4.3	Ensure incoming connections are limited to allowed sources	☐	☐
5.1	Ensure IBM Cloudant encryption is enabled with customer managed keys	☐	☐
6.1.1	Enable TLS 1.2 at minimum for all inbound traffic on IBM Cloud Internet Services Proxy	☐	☐
6.2.1	Ensure no VPC access control lists allow ingress from 0.0.0.0/0 to port 22	☐	☐
6.2.2	Ensure the default security group of every VPC restricts all traffic	☐	☐
6.2.3	Ensure no VPC security groups allow ingress from 0.0.0.0/0 to port 3389	☐	☐
6.2.4	Ensure no VPC security groups allow ingress from 0.0.0.0/0 to port 22	☐	☐
6.2.5	Ensure no VPC access control lists allow ingress from 0.0.0.0/0 to port 3389	☐	☐
7.1.1	Ensure data in Kubernetes secrets is encrypted using a Key Management Service (KMS) provider	☐	☐
7.1.2	Ensure TLS 1.2+ for all inbound traffic at IBM Cloud Kubernetes Service Ingress	☐	☐
7.1.3	Ensure IBM Cloud Kubernetes Service worker nodes are updated to the latest version to ensure patching of vulnerabilities	☐	☐
7.1.4	Ensure IBM Cloud Kubernetes Service cluster has image pull secrets enabled	☐	☐
7.1.5	Ensure IBM Cloud Kubernetes Service clusters have the monitoring service enabled	☐	☐
7.1.6	Ensure IBM Cloud Kubernetes Service clusters have the logging service enabled	☐	☐
8.1.1.1	Ensure IBM Key Protect has automated rotation for customer managed keys enabled	☐	☐

Recommendation		Set Correctly	
		Yes	No
8.1.1.2	Ensure Keys in the IBM Cloud® Key Protect Service are configured for high availability	☐	☐
8.1.1.3	Ensure all data stores are encrypted in the IBM Cloud®	☐	☐
8.2.1	Ensure certificates imported into or generated through IBM Cloud® Secrets Manager are automatically renewed before expiration	☐	☐
8.2.3	Ensure notification service is enabled in the IBM Cloud Secrets Manager to notify life cycle events	☐	☐
9.1	Ensure the Default Network Security Group of Every Workspace Restricts All Traffic	☐	☐
9.2	Ensure no workspace security groups allow ingress from 0.0.0.0/0 to port 3389	☐	☐
9.3	Ensure no workspace network security groups allow ingress from 0.0.0.0/0 to port 22	☐	☐
9.4	Ensure no workspace network security groups allow inbound traffic from the Internet from 0.0.0.0/0 to any infrastructure ports	☐	☐
9.5	Ensure no workspace network security groups allow inbound traffic from the Internet from 0.0.0.0/0 to any administrative ports	☐	☐
9.6	Ensure no workspace network security groups allow inbound traffic from the Internet from 0.0.0.0/0 to any fileshare port	☐	☐
9.7	Ensure no workspace network security groups allow inbound traffic from the Internet allowing access from 0.0.0.0/0 to telnet port (23) or RSH port (514)	☐	☐

Appendix: CIS Controls v8 IG 3 Mapped Recommendations

Recommendation		Set Correctly	
		Yes	No
1.1	Monitor account owner for frequent, unexpected, or unauthorized logins	☐	☐
1.2	Ensure API keys unused for 180 days are detected and optionally disabled	☐	☐
1.4	Restrict user API key creation and service ID creation in the account via IAM roles	☐	☐
1.6	Ensure multi-factor authentication (MFA) is enabled for all users in account	☐	☐
1.7	Ensure multi-factor authentication (MFA) is enabled for the account owner and all administrative users	☐	☐
1.8	Ensure multi-factor authentication (MFA) is enabled at the account level	☐	☐
1.9	Ensure contact email is valid	☐	☐
1.10	Ensure contact phone number is valid	☐	☐
1.14	Ensure IAM users with the same level of access are members of access groups and IAM policies are assigned only to access groups or Trusted Profiles	☐	☐
1.15	Ensure a support access group has been created to manage incidents with IBM Support	☐	☐
1.16	Ensure Minimal Number of Users are Granted Administrative Privileges	☐	☐
1.17	Ensure Minimal Number of Service IDs are Granted Administrative Privileges	☐	☐
1.18	Ensure IAM Does Not Allow Public Access to Cloud Services	☐	☐
1.19	Ensure Inactive User Accounts are Suspend	☐	☐
1.20	Enable audit logging for IBM Cloud Identity and Access Management	☐	☐
2.1.1.1	Ensure Cloud Object Storage encryption is done with customer managed keys	☐	☐

Recommendation		Set Correctly	
		Yes	No
2.1.1.2	Ensure Cloud Object Storage Encryption is set to On with BYOK	☐	☐
2.1.1.3	Ensure Cloud Object Storage Encryption is set to On with KYOK	☐	☐
2.1.2	Ensure network access for Cloud Object Storage is restricted to specific IP range	☐	☐
2.1.3	Ensure network access for Cloud Object Storage is set to be exposed only on Private end-points	☐	☐
2.1.4	Ensure Cloud Object Storage bucket access is restricted by using IAM and S3 access control	☐	☐
2.1.5	Ensure Public (anonymous) Access to IBM Cloud Object Storage buckets is Disabled	☐	☐
2.2.1.1	Ensure IBM Cloud® Block Storage for Virtual Private Cloud is encrypted with BYOK	☐	☐
2.2.1.2	Ensure IBM Cloud® Block Storage for Virtual Private Cloud is encrypted with KYOK	☐	☐
2.2.2.1	Ensure IBM Cloud® File Storage for Virtual Private Cloud is encrypted with provider managed keys	☐	☐
2.2.2.2	Ensure IBM Cloud® File Storage for Virtual Private Cloud is encrypted with BYOK	☐	☐
2.2.2.3	Ensure IBM Cloud® File Storage for Virtual Private Cloud is encrypted with KYOK	☐	☐
2.2.3	Ensure boot volumes are encrypted with Customer managed keys	☐	☐
2.2.4	Ensure secondary volumes are encrypted with customer managed keys	☐	☐
2.2.5	Ensure unattached volumes are encrypted with customer managed keys	☐	☐
3.1	Ensure auditing is configured in the IBM Cloud account	☐	☐
3.2	Ensure data retention for audit events	☐	☐
3.3	Ensure that events are collected and processed to identify anomalies or abnormal events	☐	☐
3.4	Ensure alerts are defined on custom views to notify of unauthorized requests, critical account actions, and high-impact operations in your account	☐	☐

Recommendation		Set Correctly	
		Yes	No
3.5	Ensure the account owner can login only from a list of authorized countries/IP ranges	☐	☐
3.6	Ensure Activity Tracker data is encrypted at rest	☐	☐
4.1	Ensure IBM Cloud Databases disk encryption is enabled with customer managed keys	☐	☐
4.2	Ensure network access to IBM Cloud Databases service is set to be exposed on "Private end points only"	☐	☐
4.3	Ensure incoming connections are limited to allowed sources	☐	☐
5.1	Ensure IBM Cloudant encryption is enabled with customer managed keys	☐	☐
6.1.1	Enable TLS 1.2 at minimum for all inbound traffic on IBM Cloud Internet Services Proxy	☐	☐
6.1.2	Ensure Web application firewall is ENABLED in IBM Cloud Internet Services (CIS)	☐	☐
6.2.1	Ensure no VPC access control lists allow ingress from 0.0.0.0/0 to port 22	☐	☐
6.2.2	Ensure the default security group of every VPC restricts all traffic	☐	☐
6.2.3	Ensure no VPC security groups allow ingress from 0.0.0.0/0 to port 3389	☐	☐
6.2.4	Ensure no VPC security groups allow ingress from 0.0.0.0/0 to port 22	☐	☐
6.2.5	Ensure no VPC access control lists allow ingress from 0.0.0.0/0 to port 3389	☐	☐
7.1.1	Ensure data in Kubernetes secrets is encrypted using a Key Management Service (KMS) provider	☐	☐
7.1.2	Ensure TLS 1.2+ for all inbound traffic at IBM Cloud Kubernetes Service Ingress	☐	☐
7.1.3	Ensure IBM Cloud Kubernetes Service worker nodes are updated to the latest version to ensure patching of vulnerabilities	☐	☐
7.1.4	Ensure IBM Cloud Kubernetes Service cluster has image pull secrets enabled	☐	☐
7.1.5	Ensure IBM Cloud Kubernetes Service clusters have the monitoring service enabled	☐	☐

Recommendation		Set Correctly	
		Yes	No
7.1.6	Ensure IBM Cloud Kubernetes Service clusters have the logging service enabled	☐	☐
8.1.1.1	Ensure IBM Key Protect has automated rotation for customer managed keys enabled	☐	☐
8.1.1.2	Ensure Keys in the IBM Cloud® Key Protect Service are configured for high availability	☐	☐
8.1.1.3	Ensure all data stores are encrypted in the IBM Cloud®	☐	☐
8.2.1	Ensure certificates imported into or generated through IBM Cloud® Secrets Manager are automatically renewed before expiration	☐	☐
8.2.3	Ensure notification service is enabled in the IBM Cloud Secrets Manager to notify life cycle events	☐	☐
9.1	Ensure the Default Network Security Group of Every Workspace Restricts All Traffic	☐	☐
9.2	Ensure no workspace security groups allow ingress from 0.0.0.0/0 to port 3389	☐	☐
9.3	Ensure no workspace network security groups allow ingress from 0.0.0.0/0 to port 22	☐	☐
9.4	Ensure no workspace network security groups allow inbound traffic from the Internet from 0.0.0.0/0 to any infrastructure ports	☐	☐
9.5	Ensure no workspace network security groups allow inbound traffic from the Internet from 0.0.0.0/0 to any administrative ports	☐	☐
9.6	Ensure no workspace network security groups allow inbound traffic from the Internet from 0.0.0.0/0 to any fileshare port	☐	☐
9.7	Ensure no workspace network security groups allow inbound traffic from the Internet allowing access from 0.0.0.0/0 to telnet port (23) or RSH port (514)	☐	☐

Appendix: CIS Controls v8 Unmapped Recommendations

Recommendation		Set Correctly	
		Yes	No
	No unmapped recommendations to CIS Controls v8	☐	☐

Appendix: Change History

Date	Version	Changes for this version
Aug 25, 2025	2.0.0	UPDATE - IBM Cloud Certificate Manager - Change section to IBM Cloud Secrets Manager (Ticket 25736)
Sep 4, 2025	2.0.0	UPDATE - Identity and Access Management (IAM) section - Clarify wording (Ticket 25848)
Sep 4, 2025	2.0.0	UPDATE - Ensure API keys are rotated every 90 days - add reference and remediation option (Ticket 25857)
Sep 4, 2025	2.0.0	UPATE - Ensure compliance with IBM Cloud password requirements - update minimum length value (Ticket 25861)
Sep 4, 2025	2.0.0	UPDATE - Ensure multi-factor authentication (MFA) is enabled for all users in account - update remediation steps (Ticket 25862)
Sep 4, 2025	2.0.0	UPDATE - Ensure multi-factor authentication (MFA) is enabled for the account owner - update title and remediation steps (Ticket 25865)
Sep 4, 2025	2.0.0	UPDATE - Ensure multi-factor authentication (MFA) is enabled at the account level - Update default value (Ticket 25866)
Sep 4, 2025	2.0.0	UPDATE - Ensure IAM users are members of access groups and IAM policies are assigned only to access groups - update title and remediation steps (Ticket 25867)
Sep 4, 2025	2.0.0	UPDATE - Minimize the number of users with admin privileges in the account - Added trusted profiles and adjusted title wording (Ticket 25868)
Sep 4, 2025	2.0.0	UPDATE - Minimize the number of Service IDs with admin privileges in the account - Add trusted profile and adjust title wording (Ticket 25869)
Sep 4, 2025	2.0.0	UPDATE - Ensure IAM does not allow public access to Cloud Object Storage- Remove COS wording (Ticket 25870)

Date	Version	Changes for this version
Sep 5, 2025	2.0.0	UPDATE - Ensure Inactive User Accounts are Suspend - update audit steps and description wording (Ticket 25872)
Sep 5, 2025	2.0.0	UPDATE - Enable audit logging for IBM Cloud Identity and Access Management - replace LogDNA references (Ticket 25873)
Sep 5, 2025	2.0.0	UPDATE - Multiple Recommendations - change to use Context-based Restriction (Ticket 25240)
Sep 5, 2025	2.0.0	UPDATE - Disable public (anonymous) access to IBM Cloud Object Storage buckets - change title to fit standard. (Ticket 25938)
Sep 5, 2025	2.0.0	UPDATE - Ensure Block Storage is encrypted with customer managed keys - add impact statement (Ticket 25939)
Sep 22, 2025	2.0.0	UPDATE - Ensure API keys unused for 180 days are detected and optionally disabled - update audit and remediation steps (Ticket 25856)
Sep 22, 2025	2.0.0	UPDATE - Ensure no owner account API key exists - update description and rational wording (Ticket 25860)
Sep 22, 2025	2.0.0	UPDATE - Ensure multi-factor authentication (MFA) is enabled for all users in account - Update broken MFA link (Ticket 25922)
Sep 22, 2025	2.0.0	UPDATE - Ensure multi-factor authentication (MFA) is enabled for the account owner and all administrative users - Update MFA link that was broken (Ticket 25923)
Sep 22, 2025	2.0.0	UPDATE - Ensure multi-factor authentication (MFA) is enabled at the account level - Fix MFA link in References section (Ticket 25925)
Sep 25, 2025	2.0.0	UPDATE - Ensure IAM users with the same level of access are members of access groups and IAM policies are assigned only to access groups or Trusted Profiles - updated reference link (Ticket 25920)
Sep 25, 2025	2.0.0	UPDATE - Ensure a support access group has been created to manage incidents with IBM Support - Updated broken support link (Ticket 25921)

Date	Version	Changes for this version
Sep 25, 2025	2.0.0	UPDATE - Ensure Minimal Number of Users are Granted Administrative Privileges - Updated reference link for user roles (Ticket 25916)
Sep 25, 2025	2.0.0	UPDATE - Ensure Minimal Number of Service IDs are Granted Administrative Privileges - Updated user roles link reference (Ticket 25917)
Sep 25, 2025	2.0.0	UPDATE - Ensure IAM Does Not Allow Public Access to Cloud Services - Remove broken References link (Ticket 25919)
Sep 25, 2025	2.0.0	UPDATE - Ensure Inactive User Accounts are Suspend - Corrected broken link (Ticket 25941)
Sep 25, 2025	2.0.0	UPDATE - Ensure Block Storage is encrypted with BYOK - update recommendation wording (Ticket 25812)
Sep 25, 2025	2.0.0	UPDATE - Ensure Block Storage is encrypted with KYOK - Update recommendation wording (Ticket 25813)
Sep 25, 2025	2.0.0	DELETE - Ensure Identity Federation is set up with a Corporate IDP (Ticket 25936)
Sep 25, 2025	2.0.0	DELETE - Ensure compliance with IBM Cloud password requirements (Ticket 25906)
Sep 25, 2025	2.0.0	DELETE - Ensure alerts are enabled for vulnerabilities discovered in container images in Container Registry - product no longer exists (Ticket 25830)
Sep 25, 2025	2.0.0	UPDATE - structure of sections 8, 9, and 10 (Ticket 26090)
Oct 16, 2025	2.0.0	UPDATE - Ensure 'OS disk' are encrypted with Customer managed keys - update wording throughout recommendation (Ticket 25814)
Oct 16, 2025	2.0.0	UPDATE - Ensure 'Data disks' are encrypted with customer managed keys - update wording throughout recommendation (Ticket 25815)
Oct 16, 2025	2.0.0	UPDATE - Ensure 'Unattached disks' are encrypted with customer managed keys - update terminology (Ticket 25816)

Date	Version	Changes for this version
Oct 16, 2025	2.0.0	UPDATE - Ensure auditing is configured in the IBM Cloud account - IBM Cloud Activity Tracker Event Routing implementation (Ticket 25847)
Oct 16, 2025	2.0.0	UPDATE - Ensure that archiving is enabled for audit events - update from LogDNA to Cloud Logs (Ticket 25853)
Oct 16, 2025	2.0.0	UPDATE - Ensure that events are collected and processed to identify anomalies or abnormal events - update from LogDNA to Cloud Logs (Ticket 25864)
Oct 16, 2025	2.0.0	UPDATE - Ensure alerts are defined on custom views to notify ... - update from LogDNA to Cloud Logs (Ticket 25871)
Oct 16, 2025	2.0.0	UPDATE - Ensure the account owner can login only from a list of authorized countries/IP ranges - add context-based restrictions feature and capability (Ticket 25874)
Oct 17, 2025	2.0.0	UPDATE - Ensure Activity Tracker data is encrypted at rest - add IBM Cloud Logs content (Ticket 25875)
Oct 17, 2025	2.0.0	DELETE - Ensure Activity Tracker trails are integrated with LogDNA Logs (Ticket 25876)
Oct 17, 2025	2.0.0	UPDATE - Ensure IBM Cloud Databases disk encryption is enabled with customer managed keys - Update description and audit steps (Ticket 25786)
Oct 20, 2025	2.0.0	UPDATE - Ensure Web application firewall is ENABLED in IBM Cloud Internet Services (CIS) - Update to audit/remediation steps and rational (Ticket 25802)
Oct 20, 2025	2.0.0	UPDATE - Ensure no VPC access control lists allow ingress from 0.0.0.0/0 to port 22 - Update Console Audit and remediation steps (Ticket 25797)
Oct 20, 2025	2.0.0	UPDATE- Ensure no VPC security groups allow ingress from 0.0.0.0/0 to port 3389 - fix audit and remediation steps (Ticket 25799)
Oct 20, 2025	2.0.0	UPDATE - Ensure no VPC access control lists allow ingress from 0.0.0.0/0 to port 3389 - Fix Audit and remediation steps (Ticket 25798)

Date	Version	Changes for this version
Oct 20, 2025	2.0.0	UPDATE - Ensure no VPC security groups allow ingress from 0.0.0.0/0 to port 22 - Update Console Audit and remediation steps (Ticket 25800)
Oct 20, 2025	2.0.0	UPDATE - IBM Cloud Databases Family Section - Removed Databases that been deprecated and will get deprecated soon. Add Databases for MySQL to the list of databases (Ticket 25784)
Oct 20, 2025	2.0.0	UPDATE - Ensure TLS 1.2 for all inbound traffic at IBM Cloud Kubernetes Service Ingress - Update wording and steps throughout (Ticket 25838)
Oct 20, 2025	2.0.0	UPDATE - Ensure IBM Cloud Kubernetes Service worker nodes are updated to the latest image to ensure patching of vulnerabilities - multiple changes (Ticket 25839)
Oct 20, 2025	2.0.0	DELETE - Ensure that clusters are accessible only by using private endpoints (Ticket 25840)
Oct 20, 2025	2.0.0	UPDATE - Ensure IBM Cloud Kubernetes Service clusters have the monitoring service enabled - Mutiple changes (Ticket 26371)
Oct 20, 2025	2.0.0	UPDATE - Ensure IBM Cloud Kubernetes Service clusters have the logging service enabled - Multiple changes (Ticket 25844)
Oct 20, 2025	2.0.0	ADD - Ensure all data stores are encrypted in the IBM Cloud® (Ticket 25733)
Oct 20, 2025	2.0.0	UPDATE - Ensure IBM Key Protect has automated rotation for customer managed keys enabled - Update audit and remediation steps (Ticket 25731)
Oct 20, 2025	2.0.0	UPDATE - Ensure the IBM Key Protect service has high availability - Multiple changes (Ticket 25732)
Oct 20, 2025	2.0.0	UPDATE - Ensure certificates generated through IBM Cloud Certificate Manager are automatically renewed before expiration - Multiple changes (Ticket 25734)

Date	Version	Changes for this version
Oct 20, 2025	2.0.0	ADD - Ensure access settings to secrets follow least privilege rule and allow access for a limited time to applications and non-administrative users as needed (Ticket 25737)
Oct 20, 2025	2.0.0	ADD - Ensure secrets stored in the IBM Cloud® Secrets Manager are rotated periodically (Ticket 25772)
Oct 20, 2025	2.0.0	ADD - Ensure notification service is enabled in the IBM Cloud Secrets Manager to notify life cycle events (Ticket 25773)
Oct 23, 2025	2.0.0	ADD - Ensure limitations on External Identity Interactions are Enabled (Ticket 25993)
Oct 23, 2025	2.0.0	ADD - Ensure Trusted Profiles are used in place of ServiceIDs wherever feasible (Ticket 26424)
Oct 23, 2025	2.0.0	ADD - Ensure Context-Based Restrictions are implemented to enforce secure, conditional access to critical resources based on network location, IP range, or identity attributes (Ticket 26425)
Oct 27, 2025	2.0.0	DELETE - Ensure Block Storage is encrypted with customer managed keys (Ticket 25806)
Oct 27, 2025	2.0.0	ADD - Ensure IBM Cloud File Storage for Virtual Private Cloud is encrypted with provider managed keys (Ticket 26087)
Oct 27, 2025	2.0.0	ADD - Ensure IBM Cloud File Storage for Virtual Private Cloud is encrypted with BYOK (Ticket 26088)
Oct 27, 2025	2.0.0	ADD - Ensure IBM Cloud File Storage for Virtual Private Cloud is encrypted with KYOK (Ticket 26089)
Oct 27, 2025	2.0.0	DELETE - Ensure Kubernetes secrets data is encrypted with bring your own key (BYOK) - Changing to L2 (Ticket 26369)
Oct 27, 2025	2.0.0	DELETE - Ensure Kubernetes secrets data is encrypted with keep your own key (KYOK) - Change to L2 (Ticket 26370)

Date	Version	Changes for this version
Oct 27, 2025	2.0.0	DELETE - Use a Key Management Service (KMS) provider to encrypt data in Kubernetes secrets (Ticket 26443)
Oct 27, 2025	2.0.0	ADD - Ensure data in Kubernetes secrets is encrypted using a Key Management Service (KMS) provider (Ticket 25842)
Oct 27, 2025	2.0.0	ADD - IBM Power Virtual Server on IBM Cloud (PowerVS) section and recommendations (Ticket 25905)
Oct 28, 2025	2.0.0	UPDATE - Ensure IBM Cloud Kubernetes Service cluster has image pull secrets enabled - update audit and remediation steps (Ticket 25841)
Oct 28, 2025	2.0.0	DELETE - Block deployments of vulnerable images to Kubernetes clusters (Ticket 25673)
Oct 28, 2025	2.0.0	UPDATE - Monitor account owner for frequent, unexpected, or unauthorized logins - update audit procedures to reflect ATracker and use of IBM Cloud Logs (Ticket 25817)
Nov 4, 2025	2.0.0	DELETE - Ensure Cloudant encryption is set to On (Ticket 26362)
Nov 4, 2025	2.0.0	UPDATE - Ensure IBM Cloudant encryption is enabled with customer managed keys - make recommendation L2 (Ticket 26363)
Nov 4, 2025	2.0.0	DELETE - Ensure IBM Cloudant is only accessible via HTTPS or TLS Connections (Ticket 26364)
Nov 4, 2025	2.0.0	DELETE - Ensure IBM Cloud Databases are only accessible via HTTPS or TLS Connections (Ticket 25787)
Nov 4, 2025	2.0.0	UPDATE - IBM Cloud Databases Family section description (Ticket 26500)
Nov 4, 2025	2.0.0	DELETE - Ensure IBM Cloud Databases disk encryption is set to On (Ticket 25789)
Nov 4, 2025	2.0.0	UPDATE - Ensure DDoS protection is Active on IBM Cloud Internet Services - Updated the audit procedure and add latest examples (Ticket 25801)

Date	Version	Changes for this version
Nov 7, 2025	2.0.0	UPDATE - Ensure network access to IBM Cloud Databases service is set to be exposed on "Private end points only" - Description changes and content correction (Ticket 25788)
Nov 21, 2025	2.0.0	ADD - Ensure incoming connections are limited to allowed sources (Ticket 26365)
Nov 18, 2022	1.1.0	UPDATE - Ensure API keys unused for 180 days are detected and optionally disabled - The 3 links of IBM Cloud docs have expired (Ticket 13413)
Nov 18, 2022	1.1.0	UPDATE - Multiple recommendations - Updated Critical Controls mapping (Ticket 17043)
Nov 12, 2020	1.0.0	Document Created